

ĐẠI HỌC PHENIKAA
TRƯỜNG CÔNG NGHỆ THÔNG TIN



BÀI TẬP LỚN

ĐÁNH GIÁ KIỂM ĐỊNH CHẤT LƯỢNG PHẦN MỀM

Đề bài: “Phát triển ứng dụng mạng xã hội”

Nhóm: 2

Phạm Quang Minh 23010489 K17-CNTT5

Nguyễn Thị Mai 22010787 K16-CNTT3

Lớp: Đánh giá và kiểm định chất lượng phần mềm*-1-3-25

Giáo viên giảng dạy: TS. Trịnh Thanh Bình

HÀ NỘI, THÁNG 6/2024

PHÂN CÔNG NHIỆM VỤ

Danh sách các công việc/nhiệm vụ	Mô tả tóm tắt công việc
Công việc 1	Phân tích và Đặc tả Usecase
Công việc 2	Xây dựng Sơ đồ quy trình
Công việc 3	Thiết kế Sơ đồ tuần tự
Công việc 4	Thực hiện Kiểm thử Hộp đen
Công việc 5	Thực hiện Kiểm thử Hộp trắng
Công việc 6	Kiểm thử tự động với Selenium
Công việc 7	Kiểm thử hiệu năng bằng JMeter
Công việc 8	Kiểm thử api với Postman

STT	Mã sinh viên	Tên công việc	Nhiệm vụ được	Đánh giá đóng góp cả dự án
1	Phạm Quang Minh - 23010489	Công việc 1	Phân tích và đặc tả các usecase	55%
		Công việc 2	Xây dựng các Sơ đồ quy trình	
		Công việc 3	Thiết kế Sơ đồ tuần tự	
		Công việc 4	Kiểm thử hộp đen cho các chức năng: Post, Chat-realtime	
		Công việc 5	Kiểm thử hộp trắng cho các chức năng: POST, Chat-realtime, Recommend	
		Công việc 6	Kiểm thử tự động với Selenium IDE	
		Công việc 7	Kiểm thử hiệu năng với JMeter	
		Công việc 8	Kiểm thử api với Postman	
2	Nguyễn Thị Mai - 22010787	Công việc 1	Phân tích và đặc tả các usecase	45%
		Công việc 2	Xây dựng các Sơ đồ quy trình	
		Công việc 3	Thiết kế Sơ đồ tuần tự	

		Công việc 4	Kiểm thử hộp đen cho các chức năng: Authentication, Admin	
		Công việc 5	Kiểm thử hộp trắng các chức năng: Authentication, Admin	
		Công việc 6	Kiểm thử tự động với Selenium	

Link github: https://github.com/miin000/MiniSocial_BE

MỤC LỤC

PHÂN CÔNG NHIỆM VỤ	1
MỤC LỤC	3
DANH MỤC BẢNG BIỂU VÀ HÌNH ẢNH	6
PHẦN I: TÀI LIỆU ĐẶC TẢ YÊU CẦU PHẦN MỀM (SRS)	7
1. Giới thiệu	7
1.1 Mục đích dự án	7
1.2 Phạm vi dự án	7
1.3 Các định nghĩa, thuật ngữ	8
1.4 Tổng quan hệ thống mạng xã hội	9
2. Yêu cầu chức năng	10
2.1 Các tác nhân (User, Admin, Moderator,...)	10
2.2 Các chức năng của hệ thống	10
2.3 Sơ đồ chức năng	12
2.4 Biểu đồ Use Case tổng quan	14
2.5 Quy trình nghiệp vụ	15
2.6 Biểu đồ tuần tự (sequence diagrams)	18
2.6.1. Tuần tự đăng nhập	18
2.6.2. Tuần tự tạo bài viết	19
2.6.3. Tuần tự Like/Unlike bài viết	20
2.6.4. Tuần tự nhắn tin realtime	21
2.6.5. Tuần tự Admin xử lý báo cáo vi phạm	22
2.7. Đặc tả Use Case	23
2.6.1. Use Case: Đăng ký tài khoản	23
2.6.2. Use Case: Đăng nhập	23
2.6.3. Use Case: Cập nhật hồ sơ cá nhân	24
2.6.4. Use Case: Tạo bài viết	25
2.6.5. Use Case: Sửa bài viết	26
2.6.6. Use Case: Xóa bài viết	26
2.6.7. Use Case: Like/Unlike bài viết	27
2.6.8. Use Case: Bình luận bài viết	27
2.6.9. Use Case: Gửi tin nhắn realtime	28
2.6.10. Use Case: Gợi ý nội dung	29
2.6.11. Use Case: Báo cáo bài viết vi phạm	29
2.6.12. Use Case: Admin khóa tài khoản người dùng	30
2.6.13. Use Case: Admin xử lý bài viết vi phạm	31
3. Yêu cầu phi chức năng	31
3.1 Giao diện người dùng	31
3.2 Tính bảo mật	32
3.3 Hiệu năng	32
3.4 Tính tương thích	32
3.5 Độ tin cậy và khả năng phục hồi	33
3.6. Tính ràng buộc	33
3.7. Khả năng mở rộng	33

PHẦN II: KẾ HOẠCH KIỂM THỬ PHẦN MỀM (TEST PLAN)	34
1. Giới thiệu	34
1.1 Mục đích	34
1.2 Tổng quan dự án	34
1.3 Danh sách các test case	35
2. Yêu cầu tài nguyên	38
2.1 Phần cứng	38
2.2 Phần mềm	38
2.3 Công cụ hỗ trợ kiểm thử	39
2.4 Môi trường kiểm thử	39
3. Phạm vi kiểm thử	40
3.1 Các chức năng được kiểm thử	40
3.2 Các chức năng chưa kiểm thử	42
4. Chiến lược kiểm thử	43
4.1. Sơ đồ tổng quan quy trình kiểm thử	43
4.2. Các mức kiểm thử	44
4.3 Các loại kiểm thử	46
4.4 Ma trận kỹ thuật kiểm thử	53
5. Điều kiện chấp nhận	54
6. Defect Tracking	55
6.1. Mục đích quản lý lỗi	55
6.2. Phân loại lỗi	55
6.3. Quy trình xử lý lỗi	56
PHẦN III: THỰC HIỆN KIỂM THỬ (TEST EXECUTION)	57
1. Cài đặt môi trường kiểm thử	57
1.1 Thiết lập máy chủ và cơ sở dữ liệu	57
1.2. Cài đặt môi trường phát triển và công cụ kiểm thử	57
2. Kiểm thử hộp trắng	58
2.1. Unit testing	58
2.2. Branch / Condition / Path testing	63
2.3. Integration testing	68
2.4. Kết quả kiểm thử hộp trắng	69
3. Kiểm thử hộp đen	71
3.1 Kiểm thử hộp đen chức năng Post	71
3.2. Kiểm thử hộp đen chức năng Chat realtime	80
3.3. Kiểm thử giá trị biên	83
4. Kiểm thử hiệu năng bằng Apache JMeter	84
4.1. Mục tiêu kiểm thử hiệu năng	84
4.2. Công cụ sử dụng	85
4.3. Chuẩn bị môi trường kiểm thử	86
4.4. Cấu hình Test Plan trong JMeter	86
4.5. Cấu hình Thread Group	87
4.6. Cấu hình HTTP Request Defaults	87
4.7. Cấu hình HTTP Header Manager	88

4.8. Cấu hình CSV Data Set Config	88
4.9. Cấu hình request đăng nhập	89
4.10. Cấu hình request lấy danh sách bài viết	90
4.11. Cấu hình request tạo bài viết	90
4.12. Cấu hình Timer	91
4.13. Cấu hình Listener	91
4.14. Kết quả kiểm thử	92
5. Kiểm thử giao diện bằng Selenium	94
5.1. Mục tiêu kiểm thử	94
5.2. Công cụ sử dụng	95
5.3. Môi trường kiểm thử	95
5.4. Phạm vi kiểm thử	95
5.5. Các kịch bản kiểm thử giao diện	96
5.6. Quy trình thực hiện kiểm thử	96
5.7. Kết quả kiểm thử	96
5.8. Kiểm thử thêm với Selenium IDE	98
PHẦN IV: BÁO CÁO PHÂN TÍCH TỔNG HỢP (TEST REPORT)	102
1. Phạm vi báo cáo	102
2. Báo lỗi và Rủi ro nổi bật	102
3. Tổng kết kiểm tra	103
4. Đánh giá & Đề xuất	103
TÀI LIỆU THAM KHẢO	104

DANH MỤC BẢNG BIỂU VÀ HÌNH ẢNH

Hình 1.1. Sơ đồ chức năng tổng quát của hệ thống MiniSocial	13
Hình 1.2. Biểu đồ Use Case tổng quan của hệ thống MiniSocial	15
Hình 1.3. Sơ đồ quy trình đăng ký và đăng nhập	16
Hình 1.4. Sơ đồ quy trình tạo bài viết và tương tác	17
Hình 1.6. Sơ đồ quy trình nhắn tin	17
Hình 1.9 Sơ đồ tuần tự đăng nhập	18
Hình 1.10 Sơ đồ tuần tự tạo bài viết có ảnh	19
Hình 1.11 Sơ đồ tuần tự Like/Unlike bài viết	20
Hình 1.12 Sơ đồ tuần tự nhắn tin realtime	21
Hình 1.13 Sơ đồ tuần tự Admin xử lý báo cáo vi phạm	22
Hình 2.7. Sơ đồ quy trình kiểm thử tổng quát của MiniSocial	43
Hình 2.11. Sơ đồ CFG cho Login Flow	48
Hình 2.15. Sơ đồ quy trình kiểm thử hồi quy	52
Hình 2.19. Sơ đồ quy trình xử lý lỗi	56
Hình 3.10 Sơ đồ branch testing tạo bài viết	64
Hình 3.11 Sơ đồ branch testing gửi tin nhắn	66
Hình 3.12 Sơ đồ branch testing like/unlike bài viết	67
Hình 3.1 Giao diện kiểm thử dung lượng ảnh bài viết	72
Hình 3.2 Giao diện kiểm thử độ dài nội dung bài viết	72
Hình 3.11 POST-POSTS tạo bài viết bằng api với POSTMAN	73
Hình 3.3 Giao diện kiểm thử like bài viết	76
Hình 3.4 Giao diện kiểm thử comment bài viết	76
Hình 3.12 POST-LOGIN đăng nhập bằng api với POSTMAN	78
Hình 3.13 GET-USER lấy danh sách user bằng api với POSTMAN	80
Hình 3.5 Giao diện người block và người bị block	82
Hình 3.6. Cấu hình và kết quả kiểm thử hiệu năng trong View Results in Table	93
Hình 3.7. Response data của API POST- Login trong View Results Tree	93
Hình 3.8. Tổng hợp số lượng request, thời gian trung bình, lỗi	94
Hình 3.9. Tổng hợp chi tiết hơn về min, max, average, throughput	94
Hình 3.14: Giao diện đăng nhập quản trị (URL: http://localhost:3000/login)	98
Hình 3.15: Giao diện Dashboard sau khi đăng nhập thành công	98
Hình 3.16: Giao diện Màn hình Selenium IDE đang ghi lại	99
Hình 3.17: Giao diện Màn hình Danh sách các bước test case	100
Hình 3.18: Giao diện Màn hình Selenium IDE đang ghi lại	101

PHẦN I: TÀI LIỆU ĐẶC TẢ YÊU CẦU PHẦN MỀM (SRS)

1. Giới thiệu

1.1 Mục đích dự án

Trong thời đại công nghệ số hiện nay, mạng xã hội đã trở thành một trong những nền tảng quan trọng giúp người dùng kết nối, chia sẻ thông tin, trao đổi nội dung và tương tác với nhau một cách nhanh chóng. Các ứng dụng mạng xã hội không chỉ phục vụ mục đích giao tiếp cá nhân mà còn hỗ trợ xây dựng cộng đồng, truyền tải thông tin, quảng bá nội dung và tạo ra môi trường tương tác trực tuyến đa dạng.

Dự án MiniSocial được xây dựng nhằm mô phỏng một hệ thống mạng xã hội cơ bản, trong đó người dùng có thể đăng ký tài khoản, đăng nhập, cập nhật hồ sơ cá nhân, tạo bài viết, tương tác với bài viết, bình luận, nhắn tin thời gian thực và nhận gợi ý nội dung phù hợp. Bên cạnh đó, hệ thống còn có trang quản trị dành cho Admin để quản lý người dùng, kiểm duyệt nội dung và xử lý các bài viết vi phạm.

Mục đích của tài liệu đặc tả yêu cầu phần mềm này là mô tả rõ các chức năng chính, các tác nhân tham gia hệ thống, quy trình nghiệp vụ, các yêu cầu chức năng và phi chức năng của MiniSocial. Tài liệu này là cơ sở để nhóm xây dựng kế hoạch kiểm thử, thiết kế test case và đánh giá chất lượng phần mềm trong các phần tiếp theo của báo cáo.

1.2 Phạm vi dự án

Hệ thống MiniSocial được thiết kế cho hai nhóm người dùng chính: người dùng mạng xã hội và người quản trị hệ thống.

Đối với người dùng thông thường, hệ thống hỗ trợ các chức năng:

- Đăng ký tài khoản.
- Đăng nhập, đăng xuất.
- Cập nhật thông tin hồ sơ cá nhân.
- Tạo, sửa, xóa bài viết.
- Đăng bài viết có nội dung văn bản và hình ảnh.
- Xem bảng tin.
- Like/unlike bài viết.
- Bình luận bài viết.
- Báo cáo bài viết vi phạm.
- Gửi và nhận tin nhắn thời gian thực.

- Nhận gợi ý nội dung hoặc bài viết phù hợp.

Đối với Admin, hệ thống hỗ trợ các chức năng:

- Đăng nhập vào trang quản trị.
- Quản lý danh sách người dùng.
- Khóa hoặc mở khóa tài khoản người dùng.
- Quản lý bài viết.
- Ẩn hoặc xóa bài viết vi phạm.
- Xem danh sách báo cáo vi phạm.
- Kiểm tra quyền truy cập và lịch sử thao tác quản trị.

Phạm vi của tài liệu này tập trung vào các module lõi của hệ thống gồm: **Authentication, Post & Interaction, Chat realtime, Recommendation** và **Admin**. Một số chức năng nâng cao như gọi video, livestream, thanh toán, quảng cáo hoặc phân tích dữ liệu chuyên sâu không nằm trong phạm vi của báo cáo này.

1.3 Các định nghĩa, thuật ngữ

Thuật ngữ	Ý nghĩa
SRS	Software Requirement Specification – Tài liệu đặc tả yêu cầu phần mềm
Use Case	Biểu đồ hoặc mô tả ca sử dụng, thể hiện cách tác nhân tương tác với hệ thống
User	Người dùng thông thường của ứng dụng mạng xã hội
Admin	Người quản trị hệ thống, có quyền quản lý người dùng và nội dung
Moderator	Người kiểm duyệt nội dung, có thể xử lý báo cáo vi phạm nếu hệ thống hỗ trợ
Authentication	Quá trình xác thực người dùng, gồm đăng ký, đăng nhập, đăng xuất
JWT	JSON Web Token, dùng để xác thực phiên đăng nhập của người dùng
Post	Bài viết do người dùng tạo trên mạng xã hội

Like/Unlike	Hành động thích hoặc bỏ thích bài viết
Comment	Bình luận của người dùng dưới bài viết
Realtime Chat	Chức năng nhắn tin thời gian thực giữa các người dùng
Recommendation	Chức năng gợi ý nội dung hoặc bài viết dựa trên dữ liệu tương tác
API	Giao diện lập trình ứng dụng, dùng để client giao tiếp với backend
Backend	Phần xử lý nghiệp vụ phía máy chủ
Frontend	Phần giao diện người dùng
Database	Cơ sở dữ liệu lưu trữ thông tin hệ thống
Cloudinary	Dịch vụ lưu trữ và xử lý ảnh/video trên cloud
Firebase	Nền tảng hỗ trợ thông báo, xác thực hoặc dịch vụ realtime tùy theo cấu hình
MongoDB	Hệ quản trị cơ sở dữ liệu NoSQL dùng để lưu trữ dữ liệu
Flutter	Framework dùng để xây dựng ứng dụng mobile
Next.js	Framework dùng để xây dựng Admin Web
NestJS	Framework backend dùng để xây dựng API phía server

1.4 Tổng quan hệ thống mạng xã hội

Hệ thống MiniSocial được xây dựng theo mô hình client-server. Ứng dụng người dùng được phát triển bằng Flutter, trang quản trị được phát triển bằng Next.js, backend được xây dựng bằng NestJS và cơ sở dữ liệu sử dụng MongoDB. Ngoài ra, hệ thống có thể tích hợp Cloudinary để lưu trữ hình ảnh, Firebase để hỗ trợ thông báo hoặc các dịch vụ liên quan, đồng thời có module gợi ý nội dung nhằm nâng cao trải nghiệm người dùng.

Nội dung phần đặc tả yêu cầu phần mềm được chia thành ba nhóm chính:

- Phần giới thiệu tổng quan hệ thống, phạm vi sử dụng và thuật ngữ.

- Phần mô tả yêu cầu chức năng, bao gồm tác nhân, chức năng chính, sơ đồ chức năng, use case và quy trình nghiệp vụ.
- Phần mô tả yêu cầu phi chức năng, bao gồm giao diện, bảo mật, hiệu năng, độ tin cậy, khả năng tương thích và các ràng buộc kỹ thuật.

2. Yêu cầu chức năng

2.1 Các tác nhân (User, Admin, Moderator,...)

Hệ thống MiniSocial có các tác nhân chính sau:

STT	Tác nhân	Mô tả
1	Khách truy cập	Người chưa đăng nhập vào hệ thống. Có thể đăng ký tài khoản hoặc đăng nhập nếu đã có tài khoản.
2	Người dùng	Người đã đăng ký và đăng nhập thành công. Có thể sử dụng các chức năng chính như tạo bài viết, like, comment, nhắn tin, xem gợi ý nội dung.
3	Admin	Người quản trị hệ thống. Có quyền quản lý tài khoản người dùng, xử lý bài viết vi phạm và kiểm soát nội dung trên hệ thống.
4	Hệ thống	Thành phần xử lý tự động các nghiệp vụ như xác thực, lưu dữ liệu, gửi thông báo, xử lý gợi ý nội dung và đồng bộ tin nhắn realtime.

2.2 Các chức năng của hệ thống

2.2.1. Chức năng đăng ký tài khoản

Chức năng này cho phép khách truy cập tạo tài khoản mới trên hệ thống. Người dùng cần nhập các thông tin cơ bản như họ tên, email, mật khẩu và xác nhận mật khẩu. Hệ thống kiểm tra tính hợp lệ của dữ liệu, kiểm tra email đã tồn tại hay chưa, sau đó tạo tài khoản nếu thông tin hợp lệ.

2.2.2. Chức năng đăng nhập

Chức năng đăng nhập cho phép người dùng xác thực danh tính để truy cập vào hệ thống. Người dùng nhập email và mật khẩu. Hệ thống kiểm tra thông tin đăng nhập, trạng thái tài khoản và sinh token đăng nhập nếu xác thực thành công. Nếu tài khoản bị khóa hoặc thông tin đăng nhập không chính xác, hệ thống hiển thị thông báo lỗi phù hợp.

2.2.3. Chức năng đăng xuất

Chức năng đăng xuất cho phép người dùng kết thúc phiên làm việc hiện tại. Sau khi đăng xuất, token hoặc trạng thái đăng nhập của người dùng không còn được sử dụng để truy cập các chức năng yêu cầu xác thực.

2.2.4. Chức năng quản lý hồ sơ cá nhân

Người dùng có thể xem và cập nhật thông tin cá nhân như tên hiển thị, ảnh đại diện, tiểu sử, ngày sinh hoặc các thông tin mô tả khác. Hệ thống cần kiểm tra dữ liệu nhập vào và cập nhật thông tin nếu hợp lệ.

2.2.5. Chức năng tạo bài viết

Người dùng đã đăng nhập có thể tạo bài viết mới với nội dung văn bản và có thể đính kèm hình ảnh. Hệ thống kiểm tra nội dung bài viết, kiểm tra định dạng file ảnh, tải ảnh lên dịch vụ lưu trữ nếu có và lưu bài viết vào cơ sở dữ liệu.

2.2.6. Chức năng sửa bài viết

Người dùng có thể chỉnh sửa bài viết do chính mình tạo ra. Hệ thống cần kiểm tra bài viết có tồn tại hay không và người thực hiện thao tác có phải chủ sở hữu bài viết hay không. Nếu không có quyền, hệ thống từ chối thao tác.

2.2.7. Chức năng xóa bài viết

Người dùng có thể xóa bài viết của mình. Admin cũng có thể xóa hoặc ẩn bài viết vi phạm. Khi bài viết bị xóa hoặc ẩn, bài viết không còn hiển thị trên bảng tin hoặc trang cá nhân.

2.2.8. Chức năng xem bảng tin

Bảng tin hiển thị danh sách bài viết của người dùng khác hoặc các bài viết được hệ thống gợi ý. Mỗi bài viết có thể bao gồm nội dung, ảnh, thông tin người đăng, số lượt thích, số bình luận và các thao tác tương tác.

2.2.9. Chức năng like/unlike bài viết

Người dùng có thể thích hoặc bỏ thích một bài viết. Nếu người dùng chưa like bài viết, hệ thống ghi nhận lượt like mới và tăng số lượt thích. Nếu người dùng đã like trước đó, hệ thống thực hiện unlike và giảm số lượt thích.

2.2.10. Chức năng bình luận bài viết

Người dùng có thể bình luận dưới bài viết. Hệ thống kiểm tra nội dung bình luận không được rỗng, không vượt quá giới hạn ký tự và lưu bình luận vào cơ sở dữ liệu. Các bình luận được hiển thị bên dưới bài viết tương ứng.

2.2.11. Chức năng báo cáo bài viết vi phạm

Người dùng có thể báo cáo bài viết có nội dung không phù hợp. Khi nhận được báo cáo, hệ thống lưu thông tin báo cáo để Admin xem xét và xử lý.

2.2.12. Chức năng nhắn tin thời gian thực

Người dùng có thể gửi và nhận tin nhắn với người dùng khác. Hệ thống cần đảm bảo tin nhắn được lưu vào cơ sở dữ liệu và được gửi đến người nhận theo thời gian thực nếu người nhận đang online. Nếu người nhận offline, tin nhắn vẫn được lưu và hiển thị khi người nhận truy cập lại.

2.2.13. Chức năng gợi ý nội dung

Hệ thống gợi ý bài viết hoặc nội dung phù hợp dựa trên dữ liệu tương tác của người dùng như lượt xem, like, comment hoặc các tiêu chí liên quan. Trong trường hợp người dùng mới chưa có dữ liệu tương tác, hệ thống có thể hiển thị nội dung phổ biến hoặc nội dung mặc định.

2.2.14. Chức năng quản trị người dùng

Admin có thể xem danh sách người dùng, tìm kiếm người dùng, khóa hoặc mở khóa tài khoản. Khi tài khoản bị khóa, người dùng không thể đăng nhập hoặc sử dụng các chức năng chính của hệ thống.

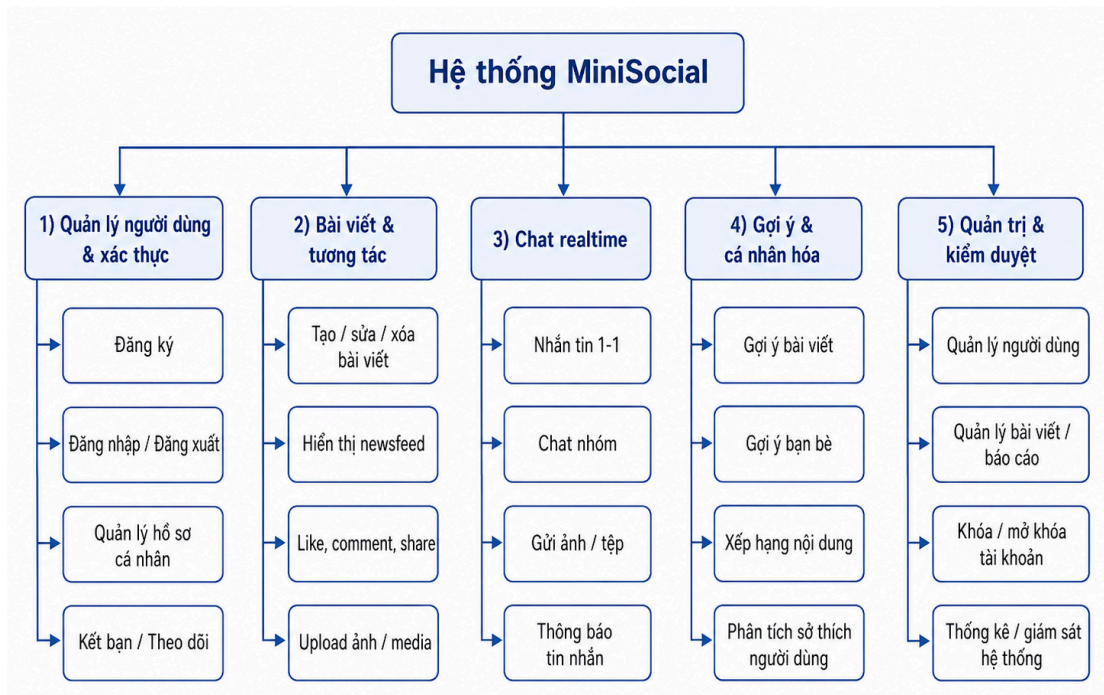
2.2.15. Chức năng quản lý nội dung vi phạm

Admin có thể xem danh sách bài viết bị báo cáo, kiểm tra nội dung bài viết, sau đó quyết định giữ nguyên, ẩn hoặc xóa bài viết. Chức năng này giúp hệ thống đảm bảo tính an toàn và phù hợp của nội dung.

2.3 Sơ đồ chức năng

Sơ đồ chức năng mô tả cấu trúc tổng quát của hệ thống MiniSocial theo hướng phân rã từ chức năng lớn đến các chức năng con. Hệ thống được chia thành hai nhóm chính: nhóm chức năng dành cho người dùng mạng xã hội và nhóm chức năng dành cho Admin quản trị hệ thống.

Người dùng có thể thực hiện các chức năng cơ bản như đăng ký, đăng nhập, quản lý hồ sơ cá nhân, tạo bài viết, tương tác với bài viết, nhắn tin realtime và xem nội dung được gợi ý. Admin có thể quản lý người dùng, quản lý bài viết, xử lý báo cáo vi phạm và kiểm tra các thao tác quản trị.



Hình 1.1. Sơ đồ chức năng tổng quát của hệ thống MiniSocial

Nhóm chức năng	Chức năng con	Mô tả
Authentication	Đăng ký, đăng nhập, đăng xuất, JWT/token, tài khoản bị khóa	Quản lý việc xác thực người dùng, cấp quyền truy cập và kiểm tra trạng thái tài khoản
Profile	Xem hồ sơ, cập nhật hồ sơ, cập nhật ảnh đại diện, đổi mật khẩu	Cho phép người dùng quản lý thông tin cá nhân trong hệ thống
Post Management	Tạo, sửa, xóa bài viết, xem bảng tin, upload ảnh	Xử lý các chức năng liên quan đến bài viết và nội dung do người dùng tạo
Interaction	Like/unlike, bình luận, chia sẻ, báo cáo bài viết	Cho phép người dùng tương tác với nội dung trên mạng xã hội
Chat Realtime	Gửi tin nhắn, nhận tin nhắn, lưu lịch sử chat, xác thực socket, tin nhắn offline	Hỗ trợ trao đổi tin nhắn giữa người dùng theo thời gian thực

Recommendation	Gợi ý bài viết, tính điểm tương tác, hybrid score, fallback khi thiếu dữ liệu	Đề xuất nội dung phù hợp dựa trên dữ liệu tương tác của người dùng
Admin Management	Quản lý người dùng, khóa/mở tài khoản, quản lý bài viết, xử lý báo cáo, phân quyền	Cho phép Admin kiểm duyệt nội dung, quản lý tài khoản và đảm bảo an toàn hệ thống

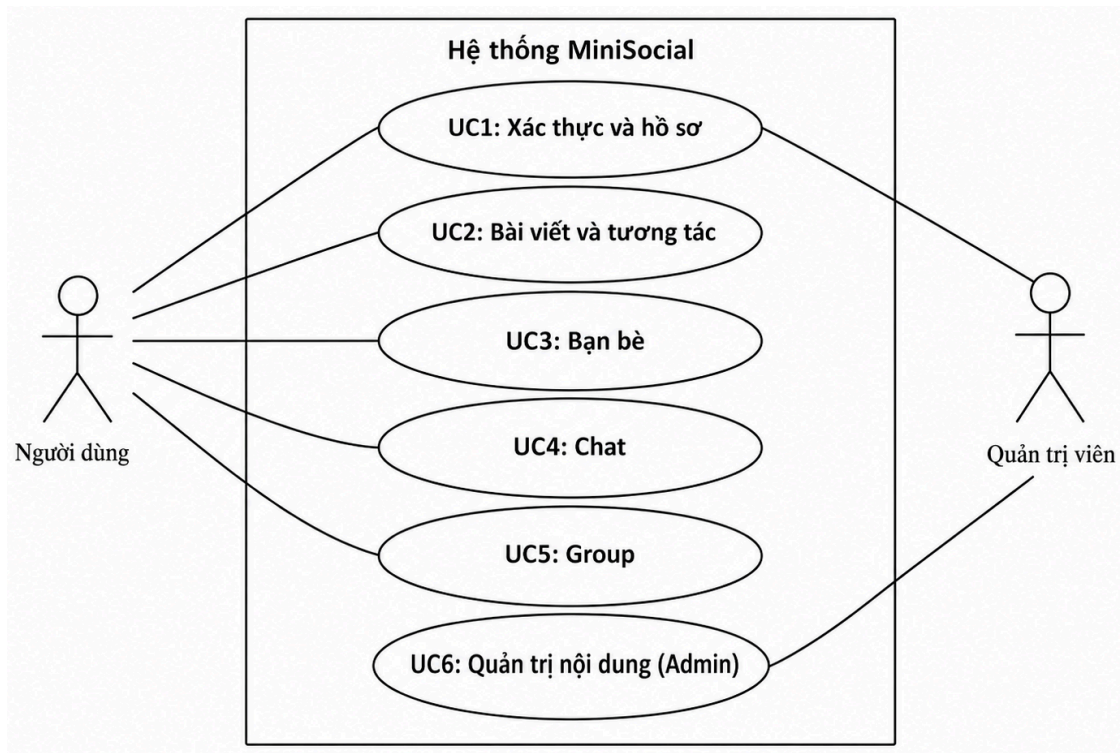
2.4 Biểu đồ Use Case tổng quan

Biểu đồ Use Case tổng quan mô tả các tác nhân chính của hệ thống MiniSocial và những chức năng mà từng tác nhân có thể thực hiện. Hệ thống gồm ba nhóm tác nhân chính: Khách truy cập, Người dùng và Admin.

Khách truy cập là người chưa đăng nhập vào hệ thống, có thể đăng ký tài khoản hoặc đăng nhập nếu đã có tài khoản. Người dùng là người đã đăng nhập thành công, có thể sử dụng các chức năng chính của mạng xã hội như cập nhật hồ sơ cá nhân, tạo bài viết, tương tác bài viết, bình luận, nhấn tin và xem nội dung gợi ý. Admin là người quản trị hệ thống, có quyền quản lý người dùng, khóa/mở khóa tài khoản, kiểm duyệt bài viết và xử lý báo cáo vi phạm.

Tác nhân	Chức năng liên quan	Mô tả
Khách truy cập	Đăng ký, đăng nhập	Người chưa có phiên đăng nhập, có thể tạo tài khoản mới hoặc đăng nhập vào hệ thống
Người dùng	Quản lý hồ sơ, bài viết, tương tác, chat, gợi ý nội dung	Người đã đăng nhập và sử dụng các chức năng chính của mạng xã hội
Admin	Quản lý người dùng, quản lý bài viết, xử lý báo cáo	Người có quyền quản trị, kiểm duyệt và xử lý các hành vi vi phạm trong hệ thống
Hệ thống	Xác thực, lưu dữ liệu, xử lý realtime, gợi ý nội dung	Thành phần xử lý tự động phía backend và database

Biểu đồ trên cho thấy hầu hết các chức năng chính như tạo bài viết, bình luận, nhấn tin và báo cáo bài viết đều yêu cầu người dùng phải đăng nhập. Riêng các chức năng quản trị như khóa tài khoản, ẩn/xóa bài viết và xử lý báo cáo chỉ được thực hiện bởi Admin.



Hình 1.2. Biểu đồ Use Case tổng quan của hệ thống MiniSocial

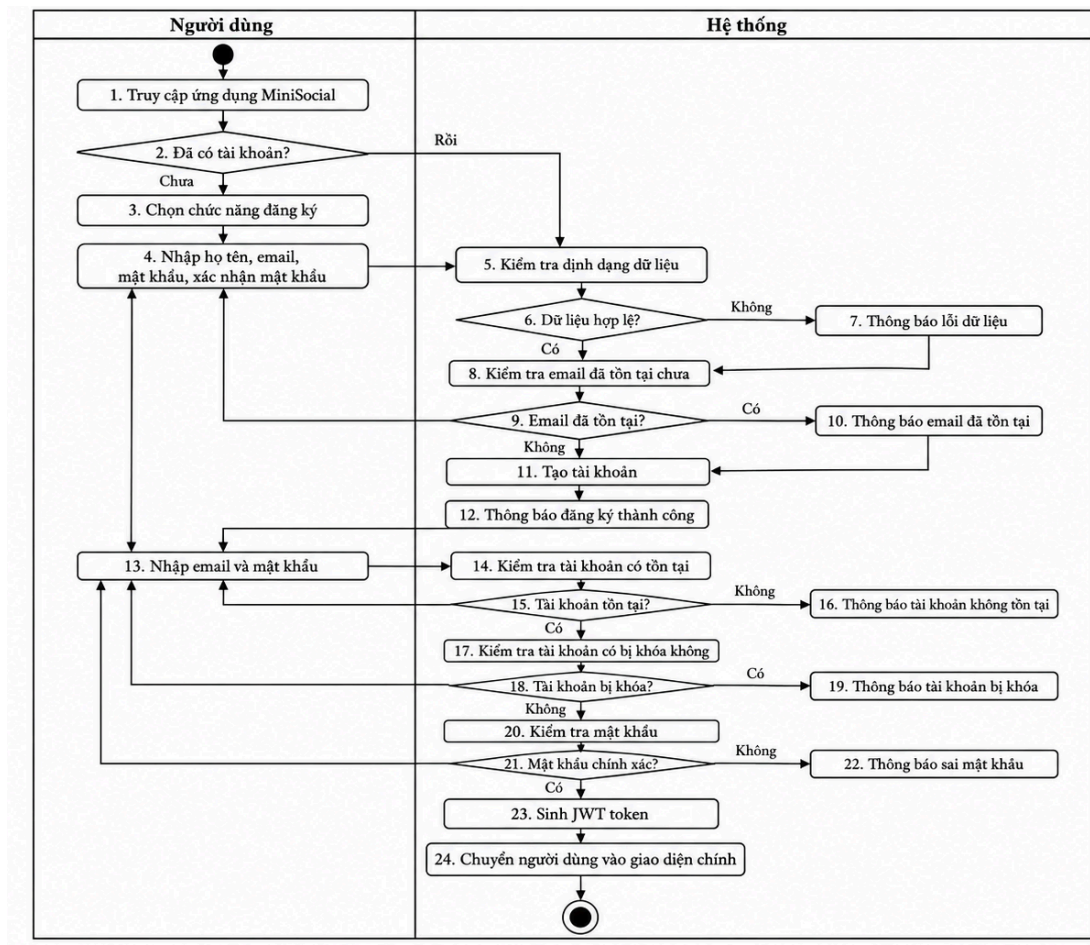
2.5 Quy trình nghiệp vụ

Quy trình nghiệp vụ của MiniSocial mô tả các luồng xử lý chính từ khi người dùng bắt đầu sử dụng hệ thống đến khi thực hiện các thao tác tương tác trong mạng xã hội. Các quy trình quan trọng gồm: đăng ký/đăng nhập, tạo bài viết và tương tác, nhắn tin realtime, gợi ý nội dung và Admin xử lý nội dung vi phạm.

2.5.1 Đăng ký, đăng nhập

Người dùng truy cập vào ứng dụng MiniSocial. Nếu chưa có tài khoản, người dùng chọn chức năng đăng ký, nhập thông tin cá nhân gồm họ tên, email, mật khẩu và xác nhận mật khẩu. Hệ thống kiểm tra định dạng dữ liệu, kiểm tra email đã tồn tại hay chưa và tạo tài khoản nếu dữ liệu hợp lệ.

Sau khi có tài khoản, người dùng nhập email và mật khẩu để đăng nhập. Hệ thống kiểm tra tài khoản có tồn tại không, tài khoản có bị khóa không và mật khẩu có chính xác không. Nếu đăng nhập thành công, hệ thống sinh JWT token và chuyển người dùng vào giao diện chính.

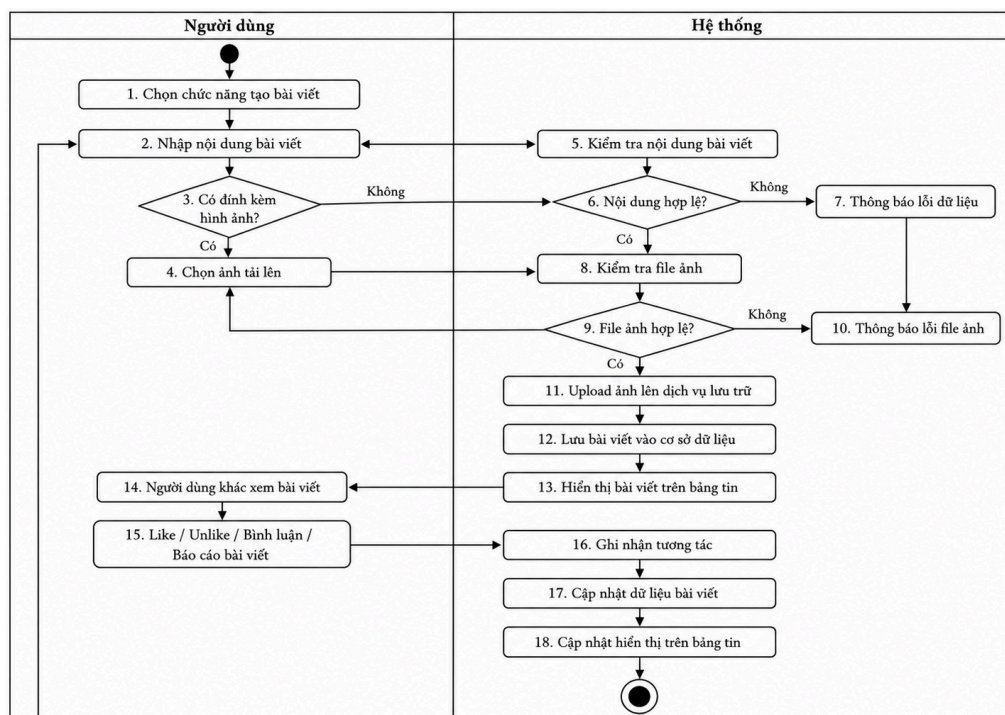


Hình 1.3. Sơ đồ quy trình đăng ký và đăng nhập

2.5.2 Đăng bài, like, comment

Người dùng sau khi đăng nhập có thể tạo bài viết mới. Khi tạo bài, người dùng nhập nội dung văn bản và có thể đính kèm hình ảnh. Hệ thống kiểm tra nội dung bài viết, kiểm tra file ảnh nếu có, upload ảnh lên dịch vụ lưu trữ và lưu bài viết vào cơ sở dữ liệu.

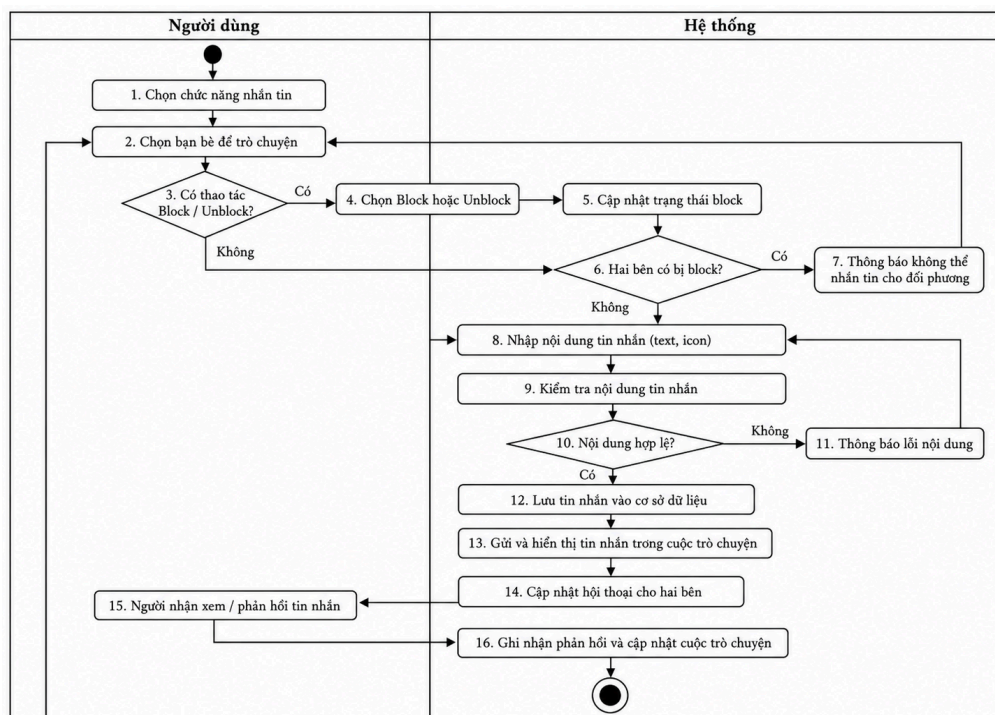
Sau khi bài viết được hiển thị trên bảng tin, những người dùng khác có thể thực hiện các thao tác như like/unlike, bình luận hoặc báo cáo bài viết. Các tương tác này được hệ thống ghi nhận và cập nhật lại dữ liệu bài viết.



Hình 1.4. Sơ đồ quy trình tạo bài viết và tương tác

2.5.3 Nhắn tin

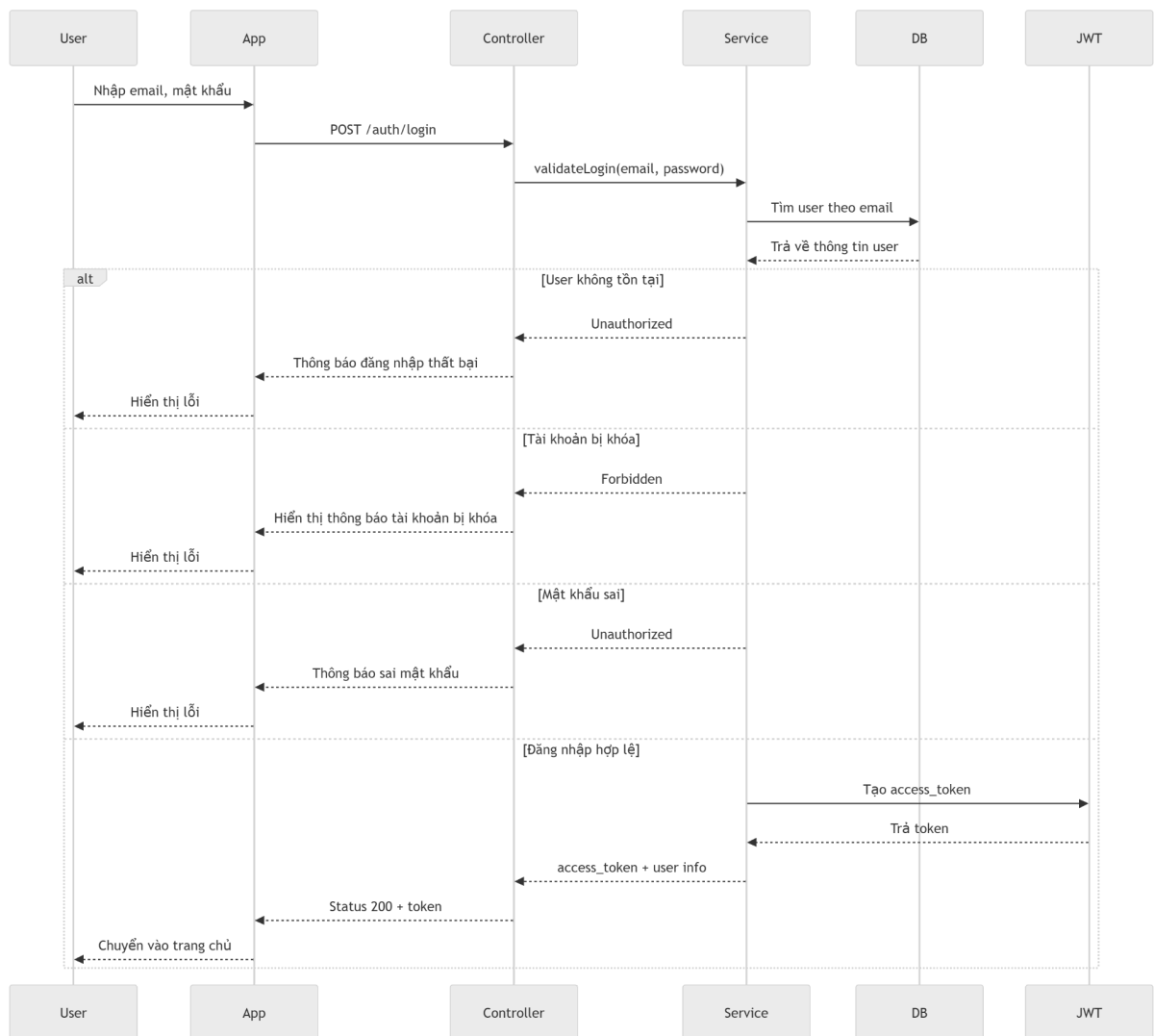
Người dùng sau khi đăng nhập có thể nhắn tin với bạn bè. Khi nhắn tin nội dung tin nhắn có thể nhắn text, icon. Người dùng có thể block, unblock bạn bè. Khi block bạn bè thì cả người block và bị block đều không thể nhắn tin cho đối phương.



Hình 1.6. Sơ đồ quy trình nhắn tin

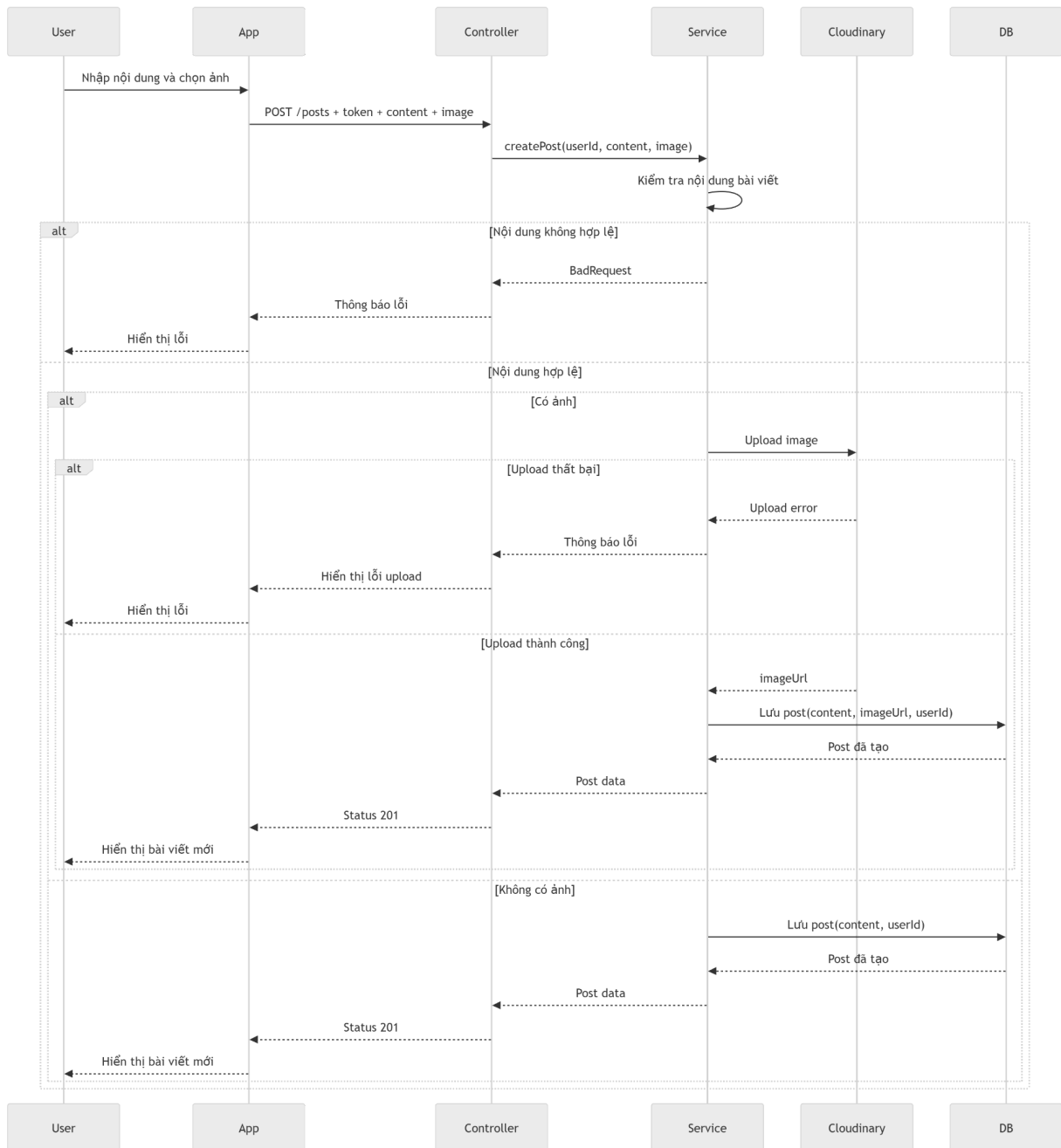
2.6 Biểu đồ tuần tự (sequence diagrams)

2.6.1. Tuần tự đăng nhập



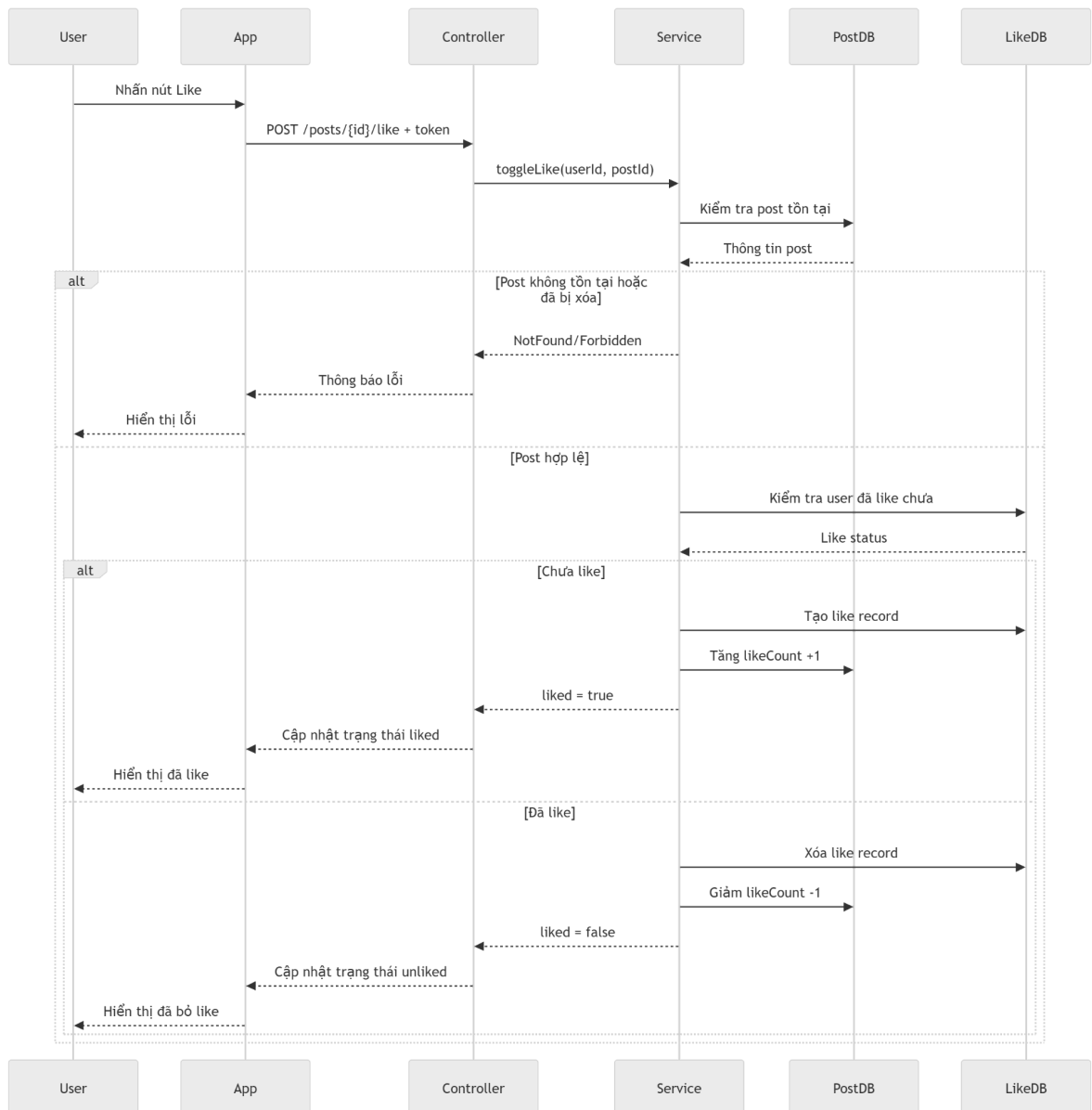
Hình 1.9 Sơ đồ tuần tự đăng nhập

2.6.2. Tuần tự tạo bài viết



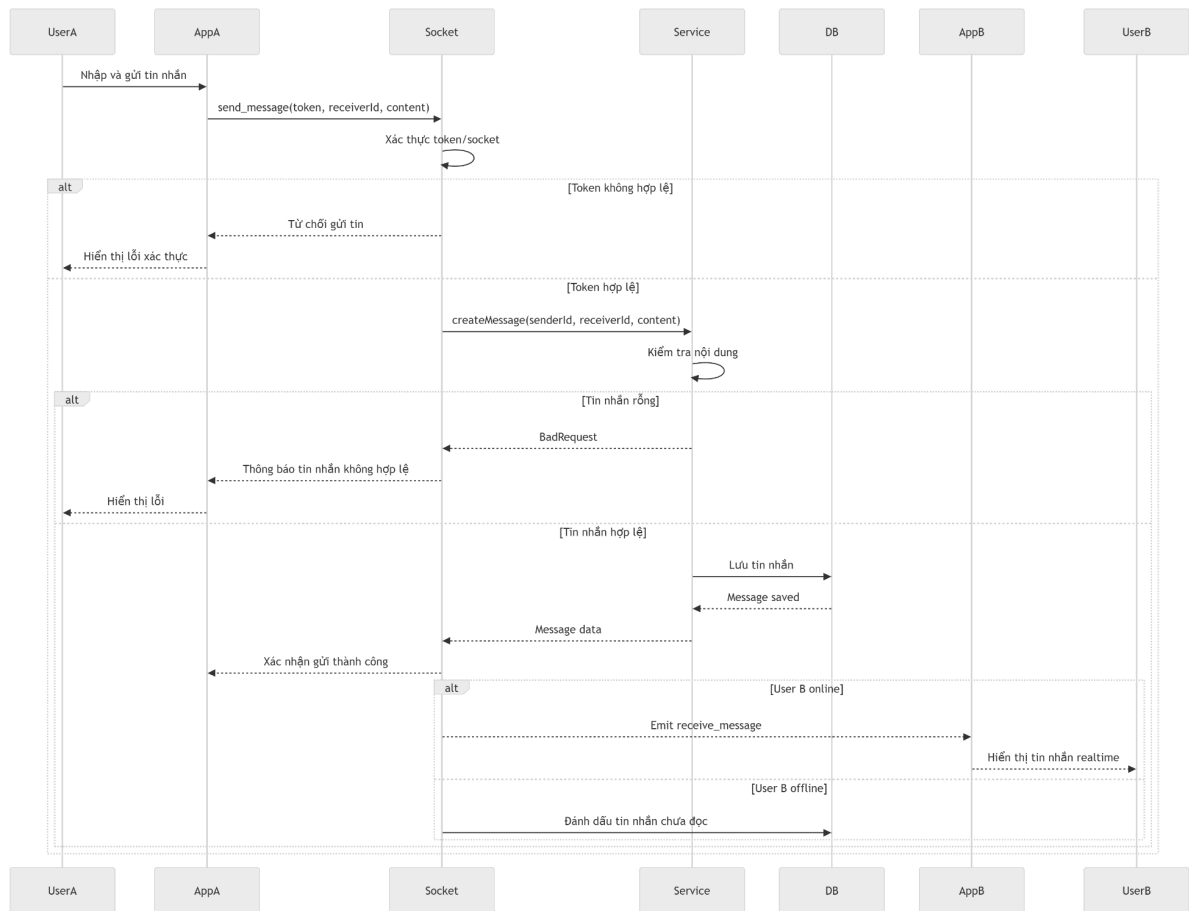
Hình 1.10 Sơ đồ tuần tự tạo bài viết có ảnh

2.6.3. Tuần tự Like/Unlike bài viết



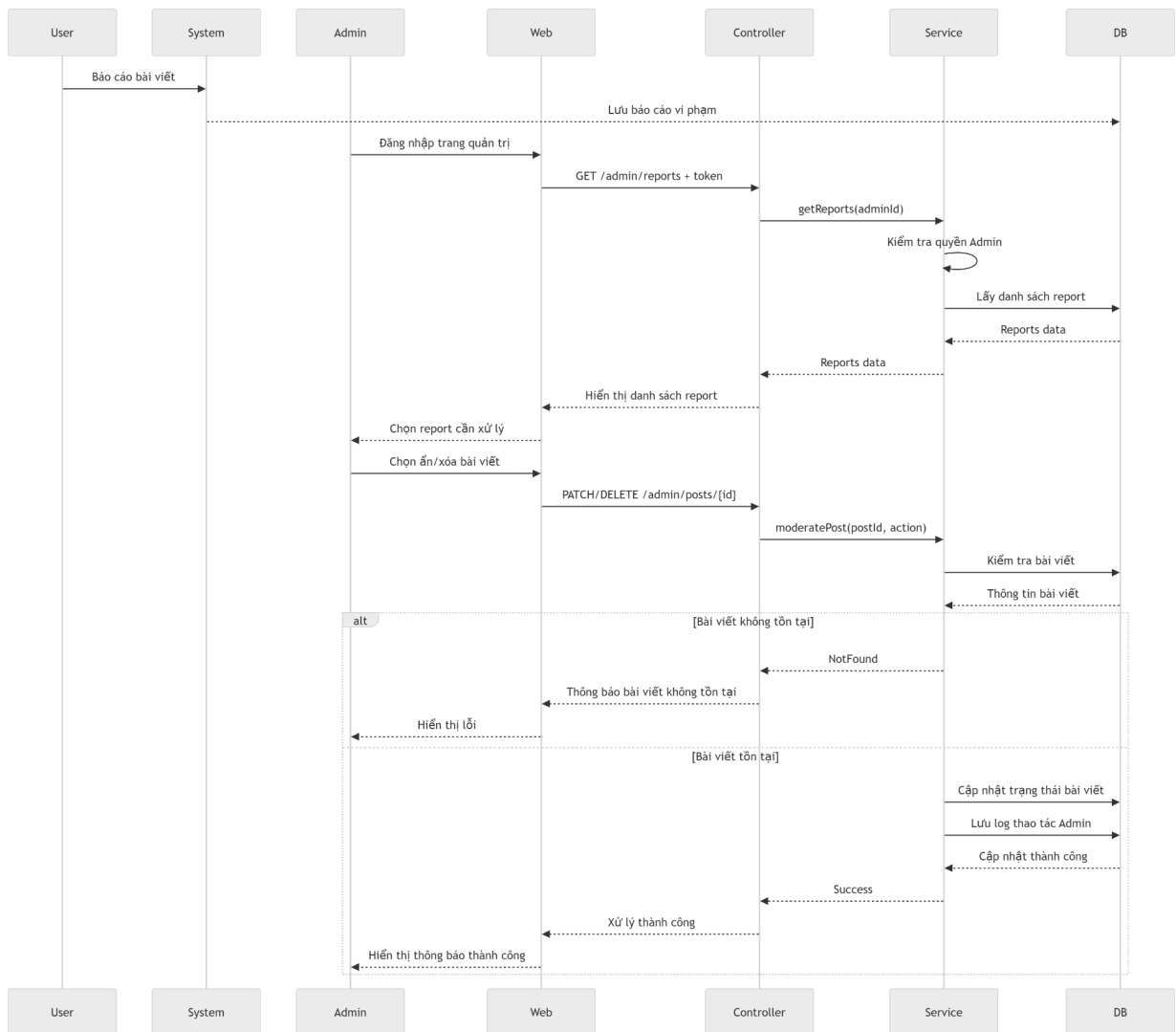
Hình 1.11 Sơ đồ tuần tự Like/Unlike bài viết

2.6.4. Tuần tự nhắn tin realtime



Hình 1.12 Sơ đồ tuần tự nhắn tin realtime

2.6.5. Tuần tự Admin xử lý báo cáo vi phạm



Hình 1.13 Sơ đồ tuần tự Admin xử lý báo cáo vi phạm

2.7. Đặc tả Use Case

2.6.1. Use Case: Đăng ký tài khoản

Thành phần	Nội dung
Mã Use Case	UC01
Tên Use Case	Đăng ký tài khoản
Tác nhân	Khách truy cập
Mục đích	Cho phép người dùng tạo tài khoản mới để sử dụng hệ thống MiniSocial
Tiền điều kiện	Người dùng chưa đăng nhập; email đăng ký chưa tồn tại trong hệ thống
Hậu điều kiện	Tài khoản mới được tạo thành công và có thể dùng để đăng nhập
Luồng cơ bản	1. Người dùng mở màn hình đăng ký. 2. Người dùng nhập họ tên, email, mật khẩu và xác nhận mật khẩu. 3. Hệ thống kiểm tra dữ liệu nhập. 4. Hệ thống kiểm tra email đã tồn tại chưa. 5. Nếu hợp lệ, hệ thống tạo tài khoản mới. 6. Hệ thống thông báo đăng ký thành công.
Luồng ngoại lệ	1. Email sai định dạng. 2. Email đã tồn tại. 3. Mật khẩu quá ngắn hoặc không đạt yêu cầu. 4. Mật khẩu xác nhận không khớp. 5. Hệ thống hiển thị thông báo lỗi và yêu cầu nhập lại.

2.6.2. Use Case: Đăng nhập

Thành phần	Nội dung
Mã Use Case	UC02
Tên Use Case	Đăng nhập

Tác nhân	Người dùng, Admin
Mục đích	Xác thực tài khoản để truy cập vào hệ thống
Tiền điều kiện	Người dùng đã có tài khoản trong hệ thống
Hậu điều kiện	Người dùng đăng nhập thành công và nhận token xác thực
Luồng cơ bản	1. Người dùng mở màn hình đăng nhập. 2. Người dùng nhập email và mật khẩu. 3. Hệ thống kiểm tra tài khoản có tồn tại không. 4. Hệ thống kiểm tra tài khoản có bị khóa không. 5. Hệ thống kiểm tra mật khẩu. 6. Nếu hợp lệ, hệ thống sinh JWT token và cho phép đăng nhập.
Luồng ngoại lệ	1. Email không tồn tại. 2. Mật khẩu sai. 3. Tài khoản bị khóa. 4. Dữ liệu nhập bị bỏ trống. 5. Hệ thống thông báo lỗi và từ chối đăng nhập.

2.6.3. Use Case: Cập nhật hồ sơ cá nhân

Thành phần	Nội dung
Mã Use Case	UC03
Tên Use Case	Cập nhật hồ sơ cá nhân
Tác nhân	Người dùng
Mục đích	Cho phép người dùng chỉnh sửa thông tin cá nhân
Tiền điều kiện	Người dùng đã đăng nhập
Hậu điều kiện	Thông tin hồ sơ cá nhân được cập nhật thành công

Luồng cơ bản	1. Người dùng vào trang cá nhân. 2. Người dùng chọn chỉnh sửa hồ sơ. 3. Hệ thống hiển thị form thông tin. 4. Người dùng cập nhật tên, ảnh đại diện, tiểu sử hoặc thông tin khác. 5. Người dùng nhấn lưu. 6. Hệ thống kiểm tra dữ liệu và cập nhật thông tin.
Luồng ngoại lệ	1. Dữ liệu nhập không hợp lệ. 2. Ảnh đại diện sai định dạng hoặc vượt dung lượng. 3. Hệ thống hiển thị thông báo lỗi và không cập nhật dữ liệu.

2.6.4. Use Case: Tạo bài viết

Thành phần	Nội dung
Mã Use Case	UC04
Tên Use Case	Tạo bài viết
Tác nhân	Người dùng
Mục đích	Cho phép người dùng đăng nội dung lên mạng xã hội
Tiền điều kiện	Người dùng đã đăng nhập
Hậu điều kiện	Bài viết được lưu và hiển thị trên bảng tin
Luồng cơ bản	1. Người dùng chọn chức năng tạo bài viết. 2. Người dùng nhập nội dung bài viết. 3. Người dùng có thể chọn hình ảnh đính kèm. 4. Người dùng nhấn nút đăng. 5. Hệ thống kiểm tra nội dung và file đính kèm. 6. Hệ thống lưu bài viết vào cơ sở dữ liệu. 7. Bài viết hiển thị trên bảng tin.
Luồng ngoại lệ	1. Nội dung bài viết rỗng. 2. Nội dung vượt quá giới hạn ký tự. 3. File ảnh sai định dạng hoặc vượt dung lượng. 4. Lỗi upload ảnh. 5. Hệ thống thông báo lỗi và không tạo bài viết.

2.6.5. Use Case: Sửa bài viết

Thành phần	Nội dung
Mã Use Case	UC05
Tên Use Case	Sửa bài viết
Tác nhân	Người dùng
Mục đích	Cho phép người dùng chỉnh sửa bài viết đã tạo
Tiền điều kiện	Người dùng đã đăng nhập; bài viết tồn tại; người dùng là chủ bài viết
Hậu điều kiện	Nội dung bài viết được cập nhật
Luồng cơ bản	1. Người dùng mở bài viết của mình. 2. Người dùng chọn sửa bài viết. 3. Hệ thống hiển thị nội dung hiện tại. 4. Người dùng chỉnh sửa nội dung. 5. Người dùng nhấn lưu. 6. Hệ thống kiểm tra quyền sở hữu và cập nhật bài viết.
Luồng ngoại lệ	1. Bài viết không tồn tại. 2. Người dùng không phải chủ bài viết. 3. Nội dung mới không hợp lệ. 4. Hệ thống từ chối thao tác và hiển thị lỗi.

2.6.6. Use Case: Xóa bài viết

Thành phần	Nội dung
Mã Use Case	UC06
Tên Use Case	Xóa bài viết
Tác nhân	Người dùng, Admin
Mục đích	Cho phép xóa bài viết khỏi hệ thống hoặc ẩn khỏi bảng tin
Tiền điều kiện	Người dùng đã đăng nhập; bài viết tồn tại

Hậu điều kiện	Bài viết không còn hiển thị trên hệ thống
Luồng cơ bản	1. Người dùng hoặc Admin chọn bài viết. 2. Chọn chức năng xóa/ẩn bài viết. 3. Hệ thống yêu cầu xác nhận. 4. Người dùng hoặc Admin xác nhận. 5. Hệ thống kiểm tra quyền. 6. Hệ thống xóa hoặc ẩn bài viết.
Luồng ngoại lệ	1. Bài viết không tồn tại. 2. Người dùng không có quyền xóa bài. 3. Hệ thống hiển thị thông báo lỗi.

2.6.7. Use Case: Like/Unlike bài viết

Thành phần	Nội dung
Mã Use Case	UC07
Tên Use Case	Like/Unlike bài viết
Tác nhân	Người dùng
Mục đích	Cho phép người dùng thể hiện tương tác với bài viết
Tiền điều kiện	Người dùng đã đăng nhập; bài viết tồn tại
Hậu điều kiện	Trạng thái like và số lượng like được cập nhật
Luồng cơ bản	1. Người dùng xem bài viết. 2. Người dùng nhấn nút like. 3. Nếu chưa like, hệ thống thêm lượt like. 4. Nếu đã like, hệ thống bỏ lượt like. 5. Hệ thống cập nhật số lượt like.
Luồng ngoại lệ	1. Bài viết không tồn tại. 2. Bài viết đã bị ẩn hoặc xóa. 3. Request lặp quá nhanh gây sai lệch dữ liệu. 4. Hệ thống xử lý và đảm bảo likeCount không bị sai.

2.6.8. Use Case: Bình luận bài viết

Thành phần	Nội dung
Mã Use Case	UC08

Tên Use Case	Bình luận bài viết
Tác nhân	Người dùng
Mục đích	Cho phép người dùng bình luận dưới bài viết
Tiền điều kiện	Người dùng đã đăng nhập; bài viết tồn tại
Hậu điều kiện	Bình luận được lưu và hiển thị dưới bài viết
Luồng cơ bản	1. Người dùng mở bài viết. 2. Người dùng nhập nội dung bình luận. 3. Người dùng nhấn gửi. 4. Hệ thống kiểm tra nội dung bình luận. 5. Hệ thống lưu bình luận. 6. Bình luận hiển thị dưới bài viết.
Luồng ngoại lệ	1. Bình luận rỗng. 2. Bình luận vượt quá giới hạn ký tự. 3. Bài viết không tồn tại hoặc đã bị xóa. 4. Hệ thống thông báo lỗi.

2.6.9. Use Case: Gửi tin nhắn realtime

Thành phần	Nội dung
Mã Use Case	UC09
Tên Use Case	Gửi tin nhắn realtime
Tác nhân	Người dùng
Mục đích	Cho phép người dùng gửi và nhận tin nhắn theo thời gian thực
Tiền điều kiện	Người dùng đã đăng nhập; người nhận tồn tại
Hậu điều kiện	Tin nhắn được lưu và gửi đến người nhận

Luồng cơ bản	1. Người dùng mở màn hình chat. 2. Người dùng chọn người nhận. 3. Người dùng nhập tin nhắn. 4. Người dùng nhấn gửi. 5. Hệ thống kiểm tra token/socket. 6. Hệ thống lưu tin nhắn vào cơ sở dữ liệu. 7. Nếu người nhận online, hệ thống gửi tin nhắn realtime.
Luồng ngoại lệ	1. Tin nhắn rỗng. 2. Người nhận không tồn tại. 3. Socket không xác thực. 4. Người nhận offline. 5. Hệ thống vẫn lưu tin nhắn để hiển thị khi người nhận online lại.

2.6.10. Use Case: Gọi ý nội dung

Thành phần	Nội dung
Mã Use Case	UC10
Tên Use Case	Gợi ý nội dung
Tác nhân	Người dùng, Hệ thống
Mục đích	Cung cấp danh sách bài viết phù hợp với người dùng
Tiền điều kiện	Người dùng đã đăng nhập
Hậu điều kiện	Danh sách bài viết gợi ý được hiển thị
Luồng cơ bản	1. Người dùng mở bảng tin hoặc trang gợi ý. 2. Hệ thống lấy dữ liệu tương tác của người dùng. 3. Hệ thống tính điểm gợi ý. 4. Hệ thống trả về danh sách bài viết phù hợp.
Luồng ngoại lệ	1. Người dùng mới chưa có dữ liệu tương tác. 2. Hệ thống sử dụng danh sách bài viết phổ biến hoặc mặc định. 3. Dữ liệu gợi ý rỗng. 4. Hệ thống hiển thị thông báo hoặc dữ liệu thay thế.

2.6.11. Use Case: Báo cáo bài viết vi phạm

Thành phần	Nội dung
Mã Use Case	UC11

Tên Use Case	Báo cáo bài viết vi phạm
Tác nhân	Người dùng
Mục đích	Cho phép người dùng báo cáo nội dung không phù hợp
Tiền điều kiện	Người dùng đã đăng nhập; bài viết tồn tại
Hậu điều kiện	Báo cáo được lưu để Admin xử lý
Luồng cơ bản	1. Người dùng mở bài viết. 2. Người dùng chọn báo cáo. 3. Người dùng chọn lý do báo cáo. 4. Hệ thống lưu báo cáo. 5. Hệ thống thông báo gửi báo cáo thành công.
Luồng ngoại lệ	1. Bài viết không tồn tại. 2. Người dùng chưa chọn lý do. 3. Người dùng báo cáo trùng lặp nhiều lần. 4. Hệ thống xử lý theo quy định.

2.6.12. Use Case: Admin khóa tài khoản người dùng

Thành phần	Nội dung
Mã Use Case	UC12
Tên Use Case	Khóa tài khoản người dùng
Tác nhân	Admin
Mục đích	Cho phép Admin khóa tài khoản vi phạm
Tiền điều kiện	Admin đã đăng nhập; tài khoản cần khóa tồn tại
Hậu điều kiện	Tài khoản bị khóa và không thể đăng nhập
Luồng cơ bản	1. Admin đăng nhập trang quản trị. 2. Admin mở danh sách người dùng. 3. Admin chọn tài khoản cần khóa. 4. Admin xác nhận thao tác. 5. Hệ thống cập nhật trạng thái tài khoản thành blocked. 6. Người dùng bị khóa không thể đăng nhập.

Luồng ngoại lệ	1. Người thực hiện không phải Admin. 2. Tài khoản cần khóa không tồn tại. 3. Tài khoản đã bị khóa trước đó. 4. Hệ thống hiển thị thông báo phù hợp.
----------------	---

2.6.13. Use Case: Admin xử lý bài viết vi phạm

Thành phần	Nội dung
Mã Use Case	UC13
Tên Use Case	Xử lý bài viết vi phạm
Tác nhân	Admin
Mục đích	Cho phép Admin kiểm duyệt và xử lý bài viết bị báo cáo
Tiền điều kiện	Admin đã đăng nhập; bài viết hoặc báo cáo tồn tại
Hậu điều kiện	Bài viết được giữ nguyên, ẩn hoặc xóa tùy kết quả xử lý
Luồng cơ bản	1. Admin mở danh sách báo cáo vi phạm. 2. Admin chọn một báo cáo. 3. Hệ thống hiển thị bài viết liên quan. 4. Admin xem nội dung và quyết định xử lý. 5. Nếu vi phạm, Admin ẩn hoặc xóa bài viết. 6. Hệ thống cập nhật trạng thái bài viết.
Luồng ngoại lệ	1. Báo cáo không tồn tại. 2. Bài viết đã bị xóa trước đó. 3. Người thao tác không có quyền Admin. 4. Hệ thống từ chối thao tác.

3. Yêu cầu phi chức năng

3.1 Giao diện người dùng

Giao diện của MiniSocial cần được thiết kế đơn giản, dễ sử dụng và phù hợp với thói quen sử dụng mạng xã hội của người dùng. Các thao tác chính như đăng nhập, đăng ký, tạo bài viết, like, comment, nhấn tin và chỉnh sửa hồ sơ cần được bố trí rõ ràng.

Đối với ứng dụng mobile, giao diện cần hiển thị tốt trên nhiều kích thước màn hình Android khác nhau. Các màn hình như bảng tin, chi tiết bài viết, tạo bài viết, chat và trang cá nhân cần tránh lỗi tràn giao diện, che nút hoặc hiển thị sai bố cục.

Đối với Admin Web, giao diện cần có bố cục rõ ràng, bảng dữ liệu dễ đọc, có chức năng tìm kiếm/lọc người dùng và bài viết. Các thao tác nguy hiểm như khóa tài khoản hoặc xóa bài viết cần có hộp thoại xác nhận trước khi thực hiện.

3.2 Tính bảo mật

Hệ thống cần đảm bảo an toàn cho tài khoản và dữ liệu người dùng. Các yêu cầu bảo mật chính bao gồm:

- Mật khẩu người dùng không được lưu dưới dạng plain text.
- Mật khẩu cần được mã hóa bằng bcrypt hoặc thuật toán tương đương.
- Các API yêu cầu đăng nhập phải kiểm tra JWT token hợp lệ.
- Token hết hạn, token sai hoặc thiếu token phải bị từ chối truy cập.
- Người dùng thông thường không được phép truy cập API dành cho Admin.
- Người dùng không được sửa hoặc xóa bài viết của người khác.
- Tài khoản bị khóa không được đăng nhập.
- Dữ liệu nhập từ người dùng cần được kiểm tra để hạn chế lỗi XSS hoặc nội dung độc hại.
- File upload cần được kiểm tra định dạng, dung lượng và MIME type.

3.3 Hiệu năng

Hệ thống cần phản hồi trong thời gian phù hợp khi người dùng thực hiện các thao tác chính. Các API quan trọng như đăng nhập, lấy bảng tin, tạo bài viết, like/comment và gửi tin nhắn cần hoạt động ổn định trong điều kiện tải nhỏ đến trung bình.

Ở phạm vi bài tập lớn, hệ thống cần đáp ứng các tiêu chí hiệu năng cơ bản:

- API đăng nhập phản hồi ổn định khi có nhiều người dùng thử đăng nhập đồng thời.
- API lấy bảng tin không bị lỗi khi dữ liệu bài viết tăng lên.
- API tạo bài viết và bình luận không sinh lỗi 5xx trong điều kiện kiểm thử tải nhỏ.
- Chức năng chat gửi và nhận tin nhắn trong thời gian chấp nhận được.
- Tỷ lệ lỗi khi kiểm thử tải nhỏ không vượt quá giới hạn cho phép của nhóm.

3.4 Tính tương thích

Hệ thống cần hoạt động ổn định trên các môi trường kiểm thử chính:

- Ứng dụng mobile chạy trên Android Emulator hoặc thiết bị Android thật.
- Admin Web hoạt động trên các trình duyệt phổ biến như Chrome, Edge và Firefox.
- Giao diện Admin Web hiển thị phù hợp trên màn hình laptop và desktop.
- Ứng dụng cần xử lý được các tình huống mạng chậm hoặc mất kết nối tạm thời.

3.5 Độ tin cậy và khả năng phục hồi

MiniSocial cần đảm bảo dữ liệu người dùng không bị mất trong các trường hợp lỗi thông thường. Khi xảy ra lỗi kết nối mạng, lỗi cơ sở dữ liệu hoặc lỗi upload ảnh, hệ thống cần hiển thị thông báo rõ ràng và không tạo dữ liệu sai.

Đối với chức năng chat, nếu người nhận offline hoặc kết nối socket bị gián đoạn, tin nhắn cần được lưu lại để hiển thị khi kết nối được khôi phục. Đối với chức năng tạo bài viết có ảnh, nếu upload ảnh thất bại, hệ thống không được lưu bài viết với dữ liệu ảnh sai hoặc không hợp lệ.

3.6. Tính ràng buộc

Hệ thống MiniSocial được xây dựng với các ràng buộc kỹ thuật sau:

- Ứng dụng người dùng được phát triển bằng Flutter/Dart.
- Trang quản trị được phát triển bằng Next.js.
- Backend được phát triển bằng TypeScript với NestJS.
- Cơ sở dữ liệu sử dụng MongoDB.
- Hình ảnh có thể được lưu trữ thông qua Cloudinary.
- Một số chức năng thông báo hoặc realtime có thể tích hợp Firebase.
- Người dùng cần có thiết bị kết nối Internet để sử dụng hệ thống.
- Admin cần đăng nhập đúng quyền để truy cập trang quản trị.

3.7. Khả năng mở rộng

Hệ thống cần có khả năng mở rộng trong tương lai khi số lượng người dùng, bài viết, bình luận và tin nhắn tăng lên. Cấu trúc backend cần tách biệt các module như Auth, Post, Comment, Chat, Recommendation và Admin để thuận tiện cho bảo trì, kiểm thử và phát triển thêm chức năng mới.

Trong tương lai, hệ thống có thể mở rộng thêm các chức năng như kết bạn/theo dõi, thông báo đẩy, phân tích hành vi, livestream hoặc đề xuất nội dung nâng cao.

PHẦN II: KẾ HOẠCH KIỂM THỬ PHẦN MỀM (TEST PLAN)

1. Giới thiệu

1.1 Mục đích

Tài liệu kế hoạch kiểm thử phần mềm được xây dựng nhằm xác định rõ phạm vi, mục tiêu, chiến lược, tài nguyên, môi trường, công cụ và quy trình kiểm thử cho dự án MiniSocial. Đây là cơ sở để nhóm thực hiện kiểm thử có hệ thống, tránh kiểm thử thiếu trọng tâm hoặc bỏ sót các chức năng quan trọng.

MiniSocial là một hệ thống mạng xã hội thu nhỏ, bao gồm ứng dụng người dùng, trang quản trị và backend API. Hệ thống có nhiều chức năng liên quan trực tiếp đến xác thực, bảo mật, dữ liệu người dùng, bài viết, tương tác, tin nhắn realtime và quản trị nội dung. Vì vậy, quá trình kiểm thử cần được lập kế hoạch rõ ràng để đảm bảo hệ thống hoạt động ổn định, đúng yêu cầu và hạn chế các lỗi ảnh hưởng đến người dùng.

Mục đích cụ thể của tài liệu Test Plan gồm:

- Xác định phạm vi kiểm thử của dự án MiniSocial.
- Xác định các chức năng sẽ được kiểm thử và chưa được kiểm thử.
- Lựa chọn các kỹ thuật kiểm thử phù hợp cho từng nhóm chức năng.
- Xác định môi trường, phần cứng, phần mềm và công cụ phục vụ kiểm thử.
- Thiết kế chiến lược kiểm thử gồm kiểm thử hộp trắng, kiểm thử hộp đen, kiểm thử hệ thống, kiểm thử hồi quy và kiểm thử phi chức năng.
- Xác định tiêu chí bắt đầu, tiêu chí kết thúc và điều kiện chấp nhận.
- Xây dựng quy trình ghi nhận, phân loại và xử lý lỗi.
- Xác định các tài liệu bàn giao sau quá trình kiểm thử.

Thông qua kế hoạch này, nhóm kiểm thử có thể thực hiện kiểm thử một cách thống nhất, có căn cứ đánh giá chất lượng phần mềm và có đủ bằng chứng để đưa vào báo cáo tổng hợp cuối cùng.

1.2 Tổng quan dự án

MiniSocial là một ứng dụng mạng xã hội cho phép người dùng đăng ký tài khoản, đăng nhập, cập nhật hồ sơ cá nhân, tạo bài viết, tương tác với bài viết, bình luận, nhắn tin realtime và nhận gợi ý nội dung. Ngoài ra, hệ thống có trang Admin Web để quản trị người dùng, kiểm duyệt nội dung và xử lý các báo cáo vi phạm.

Hệ thống gồm các thành phần chính:

Thành phần	Công nghệ sử dụng	Vai trò
Mobile App	Flutter/Dart	Giao diện dành cho người dùng mạng xã hội
Admin Web	Next.js	Giao diện quản trị dành cho Admin
Backend API	NestJS/TypeScript	Xử lý nghiệp vụ, xác thực, phân quyền, API
Database	MongoDB	Lưu trữ user, post, comment, like, message, report
Media Storage	Cloudinary	Lưu trữ ảnh bài viết, ảnh đại diện
Realtime/Notification	Firebase	Hỗ trợ chat realtime hoặc thông báo
Recommendation Module	Backend service	Tính điểm và gợi ý nội dung cho người dùng

Dự án có nhiều module, tuy nhiên trong phạm vi bài tập lớn, nhóm không kiểm thử toàn bộ hệ thống mà tập trung vào các module lõi có rủi ro cao và dễ chứng minh kết quả kiểm thử.

Các module trọng tâm gồm:

- Authentication.
- Post & Interaction.
- Chat realtime.
- Recommendation.
- Admin Management.

1.3 Danh sách các test case

1.3.1 Authentication

TC_ID	Mô tả test case	Priority	Expected result
AUTH-01	Đăng ký email hợp lệ, password hợp lệ	High	Tạo tài khoản thành công
AUTH-02	Đăng ký email sai định dạng	High	Hiển thị lỗi email không hợp lệ
AUTH-03	Đăng ký email đã tồn tại	High	Hiển thị lỗi email đã tồn tại
AUTH-04	Password dưới độ dài tối thiểu	High	Từ chối đăng ký/đổi mật khẩu

AUTH-05	Đăng nhập đúng tài khoản/mật khẩu	High	Trả JWT/access token hợp lệ
AUTH-06	Đăng nhập sai mật khẩu	High	Từ chối đăng nhập
AUTH-07	Đăng nhập tài khoản bị khóa	High	Từ chối và thông báo tài khoản bị khóa
AUTH-08	Dùng token hết hạn gọi API feed	High	Trả 401 Unauthorized
AUTH-09	Logout rồi dùng lại token	Medium	Token/session không còn hợp lệ nếu hệ thống hỗ trợ blacklist/session
AUTH-10	Gọi API admin bằng user token	High	Trả 403 Forbidden

1.3.2 Post & Interaction

TC ID	Mô tả test case	Priority	Expected result
POST-01	Tạo bài viết text hợp lệ	High	Bài viết được lưu và hiển thị trên feed
POST-02	Tạo bài viết rỗng	High	Hiển thị lỗi yêu cầu nhập nội dung/media
POST-03	Tạo bài có ảnh hợp lệ	High	Upload thành công và lưu URL
POST-04	Upload file sai định dạng/quá lớn	High	Từ chối upload
POST-05	User sửa bài viết của chính mình	High	Cập nhật nội dung thành công
POST-06	User sửa bài của người khác	High	Trả 403 Forbidden
POST-07	Xóa bài viết của chính mình	High	Bài viết không còn hiển thị
POST-08	Like bài viết lần đầu	High	Like count tăng 1
POST-09	Unlike bài đã like	High	Like count giảm 1
POST-10	Spam like/unlike nhanh	High	Không làm count sai
POST-11	Comment hợp lệ	High	Comment được lưu và hiển thị
POST-12	Comment quá dài	Medium	Từ chối hoặc yêu cầu rút gọn

1.3.3 Chat realtime

TC_ID	Mô tả test case	Priority	Expected result
CHAT-01	Gửi tin nhắn 1-1 hợp lệ	High	Tin nhắn lưu DB và hiển thị realtime
CHAT-02	Gửi tin nhắn rỗng	High	Không gửi, hiển thị lỗi

CHAT-03	Người nhận offline	Medium	Tin nhắn lưu và hiển thị khi online
CHAT-04	Socket không token/token sai	High	Không cho gửi event
CHAT-05	Gửi tin nhắn quá nhanh	Medium	Không lỗi hệ thống, có kiểm soát spam
CHAT-06	Tạo nhóm chat hợp lệ	Medium	Nhóm được tạo, thành viên được thêm
CHAT-07	Tạo nhóm không chọn thành viên	Medium	Hiển thị lỗi
CHAT-08	Block user rồi gửi tin	Medium	Tin nhắn bị chặn

1.3.4 Recommendation

TC_ID	Mô tả test case	Priority	Expected result
RECO-01	User like nhiều bài cùng tag	Medium	Gợi ý ưu tiên tag liên quan
RECO-02	User mới chưa có tương tác	Medium	Trả trending/default recommendation
RECO-03	Kiểm tra hybrid score	Medium	Score tính đúng theo alpha
RECO-04	ML/recommendation API lỗi	Medium	Trả lỗi/fallback phù hợp
RECO-05	API trả JSON schema	Medium	Có user_id/post_id/score/reason

1.3.5 Admin

TC_ID	Mô tả test case	Priority	Expected result
ADMIN-01	Admin khóa user	High	User bị khóa không login được
ADMIN-02	Admin mở khóa user	Medium	User login lại được
ADMIN-03	Admin xóa/ẩn bài vi phạm	High	Bài không còn trên feed
ADMIN-04	User thường gọi API khóa user	High	Trả 403 Forbidden
ADMIN-05	Admin thao tác xóa có confirm/log	Medium	Có xác nhận và ghi log

2. Yêu cầu tài nguyên

2.1 Phần cứng

Môi trường phần cứng cần đáp ứng đủ để chạy backend, database, admin web, mobile emulator và các công cụ kiểm thử.

Thiết bị	Cấu hình đề xuất
Máy tính cá nhân/Laptop	Có kết nối Internet ổn định
CPU	Intel Core i5/i7 hoặc tương đương
RAM	Tối thiểu 8GB, khuyến nghị 16GB
Ổ cứng	Tối thiểu 256GB SSD
Kiến trúc	64-bit
Thiết bị mobile	Android Emulator hoặc thiết bị Android thật
Mạng	Kết nối Internet để test API, upload ảnh, chạy admin web/mobile app

2.2 Phần mềm

Các phần mềm cần cài đặt phục vụ quá trình chạy hệ thống và kiểm thử:

STT	Phần mềm	Mục đích sử dụng
1	Node.js LTS	Chạy backend NestJS và Admin Web Next.js
2	npm/pnpm	Cài đặt dependency cho backend và admin
3	NestJS CLI	Hỗ trợ chạy và quản lý backend
4	Flutter SDK	Chạy ứng dụng mobile MiniSocial
5	Android Studio/Android Emulator	Chạy app trên thiết bị giả lập
6	MongoDB Local hoặc MongoDB Atlas	Lưu trữ dữ liệu test
7	Visual Studio Code	Môi trường phát triển và kiểm thử
8	Google Chrome	Kiểm thử Admin Web

9	Microsoft Edge/Firefox	Kiểm thử tương thích trình duyệt
10	Git	Quản lý mã nguồn
11	Microsoft Word/Google Docs	Soạn báo cáo
12	Microsoft Excel/Google Sheet	Quản lý test case và bug report

2.3 Công cụ hỗ trợ kiểm thử

Hoạt động kiểm thử	Công cụ đề xuất	Mục đích
Kiểm thử API	Postman/Newman	Gửi request API, kiểm tra response
Unit test backend	Jest	Kiểm thử service, function, method trong NestJS
Integration test API	Supertest	Kiểm thử luồng Controller – Service – Database
Kiểm thử UI Admin Web	Playwright/Cypress	Kiểm thử giao diện và cross-browser
Kiểm thử mobile	Flutter Integration Test	Kiểm thử luồng cơ bản trên app
Kiểm thử hiệu năng	k6 hoặc Apache JMeter	Đo response time, throughput, error rate
Vẽ biểu đồ	Mermaid	Vẽ sơ đồ quy trình, chiến lược, luồng xử lý lỗi

2.4 Môi trường kiểm thử

Môi trường kiểm thử được tách biệt với môi trường phát triển hoặc môi trường thật để tránh ảnh hưởng đến dữ liệu thật của hệ thống.

Thành phần	Cấu hình môi trường test
Backend	Chạy ở localhost, ví dụ http://localhost:3001
Admin Web	Chạy ở localhost, ví dụ http://localhost:3000
Mobile App	Chạy trên Android Emulator hoặc thiết bị Android
Database	MongoDB database riêng: minisocial_test

JWT Secret	Sử dụng key test riêng
Cloudinary	Sử dụng tài khoản sandbox hoặc mock service
Firebase/WebSocket	Sử dụng cấu hình test hoặc mock khi cần
API Base URL	Mobile Emulator sử dụng http://10.0.2.2:3001 nếu backend chạy local

3. Phạm vi kiểm thử

3.1 Các chức năng được kiểm thử

3.1.1. Authentication

Authentication là module quan trọng nhất của hệ thống vì liên quan đến việc xác thực và phân quyền người dùng. Kiểm thử module này giúp đảm bảo người dùng chỉ có thể truy cập hệ thống khi có tài khoản hợp lệ và token hợp lệ.

Các nội dung kiểm thử:

- Kiểm tra đăng ký tài khoản mới với thông tin hợp lệ.
- Kiểm tra đăng ký với email sai định dạng.
- Kiểm tra đăng ký với email đã tồn tại.
- Kiểm tra đăng ký với mật khẩu quá ngắn.
- Kiểm tra đăng ký khi xác nhận mật khẩu không khớp.
- Kiểm tra đăng nhập với email và mật khẩu đúng.
- Kiểm tra đăng nhập với email không tồn tại.
- Kiểm tra đăng nhập với mật khẩu sai.
- Kiểm tra đăng nhập với tài khoản bị khóa.
- Kiểm tra đăng xuất.
- Kiểm tra truy cập API với token hợp lệ.
- Kiểm tra truy cập API khi thiếu token, token sai hoặc token hết hạn.

3.1.2. Post & Interaction

Post & Interaction là nhóm chức năng trung tâm của mạng xã hội, cho phép người dùng tạo nội dung và tương tác với nội dung.

Các nội dung kiểm thử:

- Tạo bài viết với nội dung hợp lệ.
- Tạo bài viết với nội dung rỗng.

- Tạo bài viết có ảnh hợp lệ.
- Tạo bài viết với file ảnh sai định dạng.
- Tạo bài viết với file vượt quá dung lượng cho phép.
- Sửa bài viết do chính mình tạo.
- Người dùng khác sửa bài viết không thuộc quyền sở hữu.
- Xóa bài viết do chính mình tạo.
- Like bài viết lần đầu.
- Unlike bài viết đã like.
- Like bài viết không tồn tại.
- Bình luận bài viết hợp lệ.
- Bình luận rỗng hoặc vượt quá giới hạn ký tự.
- Báo cáo bài viết vi phạm.
- Kiểm tra số lượt like/comment được cập nhật đúng.

3.1.3. Chat realtime

Chat realtime giúp người dùng gửi và nhận tin nhắn trong thời gian thực. Module này cần kiểm thử cả lưu trữ dữ liệu và trạng thái online/offline.

Các nội dung kiểm thử:

- Gửi tin nhắn hợp lệ giữa hai người dùng.
- Gửi tin nhắn rỗng.
- Gửi tin nhắn đến người dùng không tồn tại.
- Kiểm tra tin nhắn được lưu trong cơ sở dữ liệu.
- Kiểm tra người nhận online nhận được tin nhắn realtime.
- Kiểm tra người nhận offline vẫn xem được tin nhắn khi online lại.
- Kiểm tra kết nối socket khi thiếu token hoặc token sai.
- Kiểm tra reconnect khi mất kết nối tạm thời.

3.1.4. Recommendation

Recommendation là module gợi ý nội dung cho người dùng dựa trên dữ liệu tương tác. Trong phạm vi bài tập lớn, module này được kiểm thử ở mức vừa đủ.

Các nội dung kiểm thử:

- Kiểm tra API trả về danh sách bài viết gợi ý.
- Kiểm tra người dùng có dữ liệu tương tác nhận được gợi ý liên quan.

- Kiểm tra người dùng mới chưa có dữ liệu tương tác nhận được danh sách fallback.
- Kiểm tra định dạng response của API gợi ý.
- Kiểm tra công thức tính điểm tương tác hoặc hybrid score.
- Kiểm tra khi không có dữ liệu bài viết phù hợp.

3.1.5. Admin Management

Admin Management đảm bảo hệ thống có khả năng quản trị, kiểm duyệt và bảo vệ cộng đồng người dùng.

Các nội dung kiểm thử:

- Admin đăng nhập vào trang quản trị.
- Admin xem danh sách người dùng.
- Admin tìm kiếm người dùng.
- Admin khóa tài khoản người dùng.
- Admin mở khóa tài khoản người dùng.
- Người dùng bị khóa không thể đăng nhập.
- Admin xem danh sách bài viết.
- Admin ẩn hoặc xóa bài viết vi phạm.
- Admin xem danh sách báo cáo vi phạm.
- Admin xử lý báo cáo vi phạm.
- Người dùng thường gọi API Admin bị từ chối.

3.2 Các chức năng chưa kiểm thử

Do giới hạn thời gian và phạm vi bài tập lớn, một số chức năng nâng cao không nằm trong phạm vi kiểm thử.

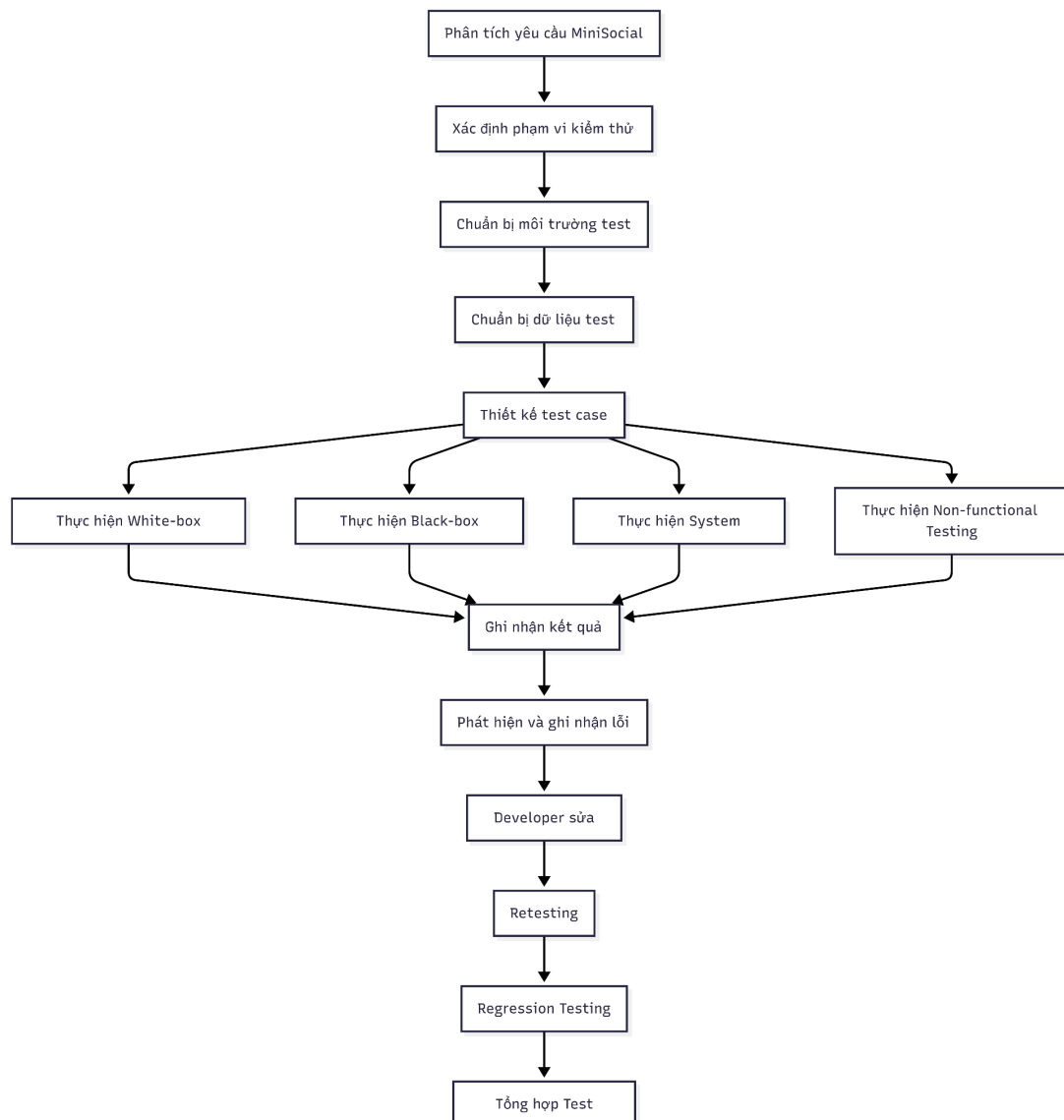
Chức năng chưa kiểm thử	Lý do
Push notification đầy đủ	Có thể phụ thuộc Firebase thật, khó kiểm soát trong môi trường test
Tìm kiếm nâng cao toàn hệ thống	Chỉ kiểm thử tìm kiếm cơ bản nếu có
Quản lý nhóm/cộng đồng nâng cao	Không phải module trọng tâm

Phân tích hành vi người dùng chuyên sâu	Cần dữ liệu lớn và thuật toán riêng
Kiểm thử tải lớn hàng nghìn user	Vượt phạm vi bài tập lớn, chỉ kiểm thử tải nhỏ/trung bình

4. Chiến lược kiểm thử

Chiến lược kiểm thử của MiniSocial được xây dựng theo hướng kết hợp nhiều mức kiểm thử và nhiều kỹ thuật kiểm thử. Mục tiêu là vừa kiểm tra được logic bên trong backend, vừa kiểm tra được chức năng theo góc nhìn người dùng và đánh giá được một số yếu tố phi chức năng quan trọng.

4.1. Sơ đồ tổng quan quy trình kiểm thử



Hình 2.7. Sơ đồ quy trình kiểm thử tổng quát của MiniSocial

4.2. Các mức kiểm thử

4.2.1 Kiểm thử đơn vị (Unit Testing)

Kiểm thử đơn vị tập trung vào từng hàm, service hoặc method riêng lẻ trong backend NestJS. Mục tiêu là kiểm tra logic nghiệp vụ trước khi tích hợp với API hoặc cơ sở dữ liệu thật.

Các module nên kiểm thử đơn vị:

Module	Đối tượng kiểm thử	Nội dung kiểm thử
AuthService	validate, login, register	Kiểm tra email, password, user tồn tại, account locked, sinh JWT
PostService	create, update, delete	Kiểm tra nội dung bài viết, quyền sửa/xóa, xử lý ảnh
LikeService	toggleLike	Kiểm tra trạng thái đã like/chưa like, cập nhật likeCount
CommentService	createComment	Kiểm tra comment rỗng, comment quá dài, lưu comment
Recommendation Service	calculateScore	Kiểm tra tính điểm tương tác, fallback khi thiếu dữ liệu
AdminService	lockUser, moderatePost	Kiểm tra quyền Admin, khóa user, ẩn/xóa bài viết

Công cụ sử dụng: Jest.

Bảng chứng đưa vào báo cáo:

- Ảnh kết quả chạy test.
- File test .spec.ts.
- Bảng pass/fail.
- Coverage report.

4.2.2 Kiểm thử tích hợp (Integration Testing)

Kiểm thử tích hợp dùng để kiểm tra sự phối hợp giữa nhiều thành phần trong hệ thống, ví dụ Controller – Service – Repository – Database hoặc API – Database – Cloudinary.

Các luồng tích hợp cần kiểm thử:

Luồng tích hợp	Thành phần liên quan	Mục tiêu kiểm thử
----------------	----------------------	-------------------

Đăng ký/đăng nhập	AuthController, AuthService, UserRepository, MongoDB, JWT	Tài khoản lưu đúng, password hash, token hợp lệ
Tạo bài viết có ảnh	PostController, PostService, Cloudinary mock, MongoDB	Ảnh upload thành công, URL lưu đúng
Like bài viết	LikeController, LikeService, Post collection, Like collection	Like record và likeCount đồng bộ
Gửi tin nhắn	Socket Gateway, MessageService, MongoDB	Tin nhắn được lưu và gửi realtime
Admin khóa user	AdminController, UserService, AuthGuard, MongoDB	Chỉ Admin được khóa user

Công cụ sử dụng: Supertest, Jest, socket.io-client.

4.2.3 Kiểm thử hệ thống (System Testing)

Kiểm thử hệ thống được thực hiện khi các thành phần chính đã được tích hợp. Mục tiêu là kiểm tra toàn bộ luồng nghiệp vụ từ phía người dùng, bao gồm mobile app, admin web, backend và database.

Các luồng system testing:

STT	Luồng hệ thống	Kết quả mong đợi
1	Đăng ký → đăng nhập → cập nhật hồ sơ → tạo bài	Người dùng sử dụng được hệ thống từ đầu đến cuối
2	User A tạo bài → User B like/comment	Dữ liệu tương tác hiển thị đúng
3	User A gửi tin → User B nhận realtime	Tin nhắn được lưu và nhận đúng realtime
4	User report bài → Admin xử lý report	Bài vi phạm bị ẩn/xóa khỏi bảng tin
5	Admin khóa user → user đăng nhập lại	User bị từ chối đăng nhập

Công cụ sử dụng: Postman, Flutter app, Admin Web, Playwright nếu có.

4.2.4 Kiểm thử chấp nhận (Acceptance Testing)

Kiểm thử chấp nhận nhằm xác định hệ thống có đáp ứng yêu cầu chính của đề tài hay không. Việc kiểm thử này dựa trên các use case đã mô tả trong phần đặc tả yêu cầu.

Các tiêu chí chấp nhận chính:

- Người dùng có thể đăng ký và đăng nhập thành công.
- Người dùng có thể tạo, sửa, xóa bài viết của mình.
- Người dùng có thể like, unlike, comment bài viết.
- Người dùng không thể sửa/xóa bài viết của người khác.
- Người dùng có thể gửi và nhận tin nhắn.
- Admin có thể khóa tài khoản và xử lý bài viết vi phạm.
- Tài khoản bị khóa không thể đăng nhập.
- Các lỗi quan trọng được ghi nhận và không còn lỗi mức High ở thời điểm kết thúc kiểm thử.

4.3 Các loại kiểm thử

4.3.1. Kiểm thử hộp trắng – White-box Testing

Kiểm thử hộp trắng tập trung vào cấu trúc bên trong của chương trình. Với MiniSocial, kiểm thử hộp trắng chủ yếu thực hiện ở backend NestJS.

Các kỹ thuật sử dụng:

Kỹ thuật	Nội dung áp dụng
Unit Testing	Kiểm thử từng service/method riêng lẻ
Branch Testing	Bao phủ các nhánh if/else trong login, like/unlike, admin
Condition Testing	Kiểm thử từng điều kiện logic trong validation và phân quyền
Path Testing	Xác định đường đi độc lập cho login flow và like/unlike flow
Integration Testing	Kiểm thử API đi qua Controller – Service – Database

Ví dụ flow đăng nhập có 3 điều kiện chính:

- User có tồn tại không?

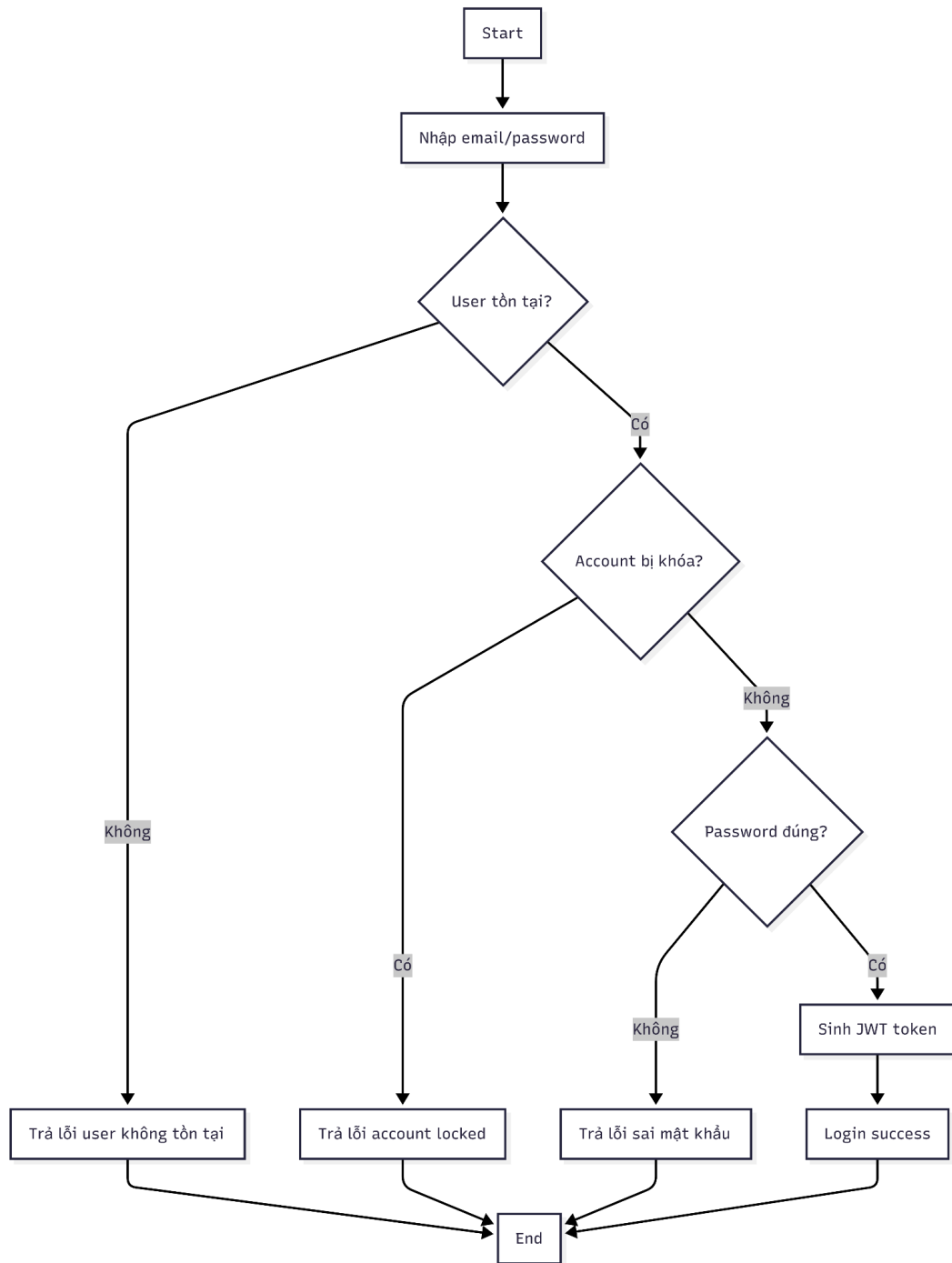
- Account có bị khóa không?
- Password có đúng không?

Cyclomatic Complexity:

$$V(G) = P + 1 = 3 + 1 = 4$$

Cần tối thiểu 4 đường đi độc lập:

Path	Mô tả	Expected result
P1	User không tồn tại	Trả lỗi đăng nhập
P2	User tồn tại nhưng bị khóa	Từ chối đăng nhập
P3	User tồn tại, account active, password sai	Trả lỗi sai mật khẩu
P4	User tồn tại, account active, password đúng	Sinh JWT và đăng nhập thành công



Hình 2.11. Sơ đồ CFG cho Login Flow

4.3.2. Kiểm thử hộp đen – Black-box Testing

Kiểm thử hộp đen kiểm tra chức năng hệ thống từ bên ngoài, không quan tâm đến cấu trúc code. Với MiniSocial, kiểm thử hộp đen được thực hiện thông qua API, Mobile App và Admin Web.

Các kỹ thuật sử dụng:

Kỹ thuật	Cách áp dụng
----------	--------------

Functional Testing	Kiểm tra từng chức năng theo use case
Equivalence Partitioning	Chia dữ liệu thành lớp hợp lệ/không hợp lệ
Boundary Value Analysis	Kiểm tra giá trị trước/tại/sau biên
Decision Table	Kiểm tra các tổ hợp điều kiện, ví dụ login hoặc quyền Admin
Error Guessing	Dự đoán lỗi thường gặp như bỏ trống input, token sai, upload sai file

Ví dụ phân vùng tương đương:

Trường dữ liệu	Lớp hợp lệ	Lớp không hợp lệ
Email	Đúng định dạng và chưa tồn tại	Sai định dạng, để trống, email trùng
Password	Đủ độ dài, đúng policy	Quá ngắn, để trống, sai mật khẩu
Post content	Có nội dung hợp lệ	Rỗng, quá dài
Image upload	jpg/png/webp đúng dung lượng	File sai định dạng, file quá lớn
JWT token	Token hợp lệ, chưa hết hạn	Thiếu token, token sai, token hết hạn

Ví dụ giá trị biên:

Đối tượng	Biên kiểm thử	Giá trị test	Expected
Password	Min = 6 ký tự	5, 6, 7	5 lỗi; 6 và 7 hợp lệ
Comment	Max = 500 ký tự	499, 500, 501	501 lỗi
Post content	Max = 5000 ký tự	4999, 5000, 5001	5001 lỗi

Số ảnh/post	Max = 5 ảnh	4, 5, 6	6 ảnh bị từ chối
File upload	Max = 5MB	4.9MB, 5MB, 5.1MB	5.1MB bị từ chối

4.3.3. Kiểm thử giao diện và tính dễ sử dụng – Usability Testing

Usability testing được thực hiện nhằm kiểm tra mức độ dễ sử dụng của Mobile App và Admin Web.

Các tiêu chí kiểm tra:

Khu vực	Tiêu chí
Login/Register	Thông báo lỗi rõ ràng, form dễ nhập, không lộ mật khẩu
Newsfeed	Bài viết hiển thị đúng, nút like/comment/share dễ nhìn
Create Post	Chọn ảnh dễ dàng, có preview, có loading khi đăng
Chat	Tin nhắn hiển thị đúng chiều gửi/nhận, có trạng thái gửi
Admin Web	Bảng dữ liệu dễ đọc, filter/search rõ, thao tác xóa/khóa có xác nhận

4.3.4. Kiểm thử tương thích – Cross-browser/Cross-device Testing

Kiểm thử tương thích nhằm đảm bảo hệ thống hoạt động ổn định trên nhiều môi trường.

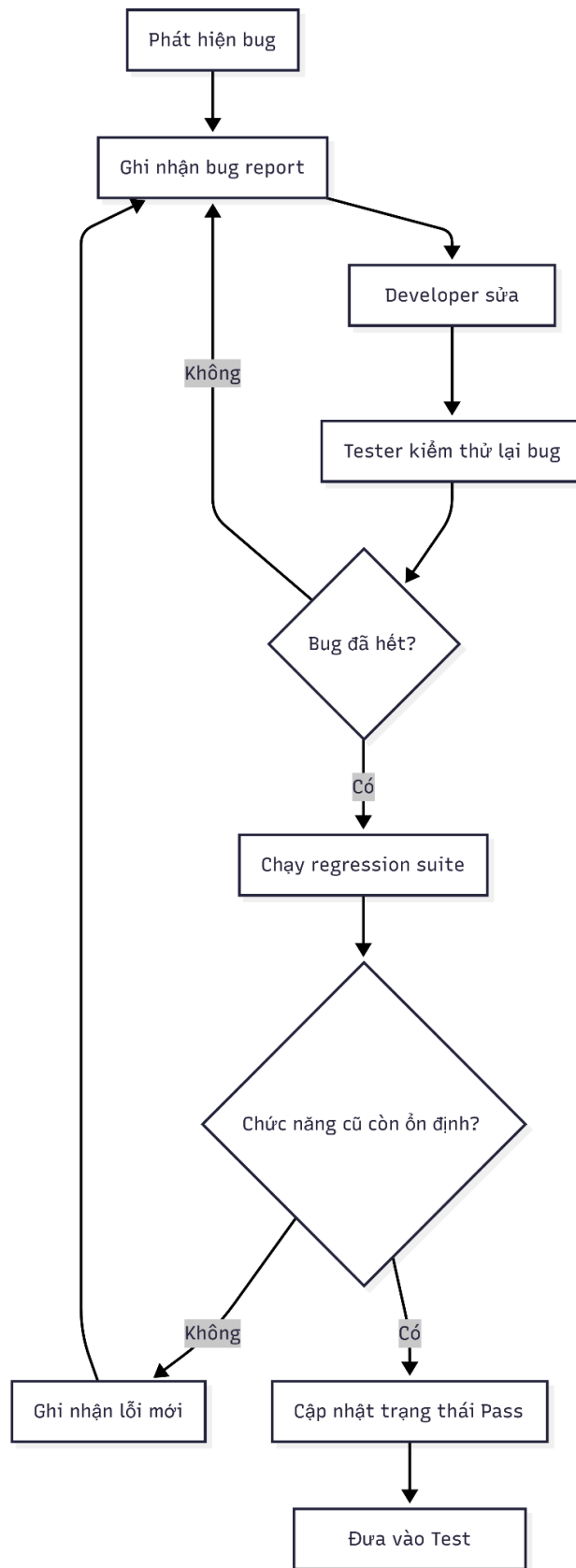
Thành phần	Môi trường kiểm thử	Nội dung kiểm tra
Admin Web	Chrome	Login Admin, bảng user, bảng post, report
Admin Web	Edge/Firefox	Hiển thị layout, modal, filter/search
Flutter App	Android Emulator màn hình nhỏ	Login, feed, create post, chat
Flutter App	Android Emulator màn hình lớn	Feed, profile, post detail
Network	Mạng bình thường/chậm/mất mạng	Loading, retry, thông báo lỗi

4.3.5. Kiểm thử hồi quy – Regression Testing

Regression testing được thực hiện sau khi sửa lỗi hoặc thay đổi code để đảm bảo chức năng cũ không bị ảnh hưởng.

Bộ regression đề xuất:

Nhóm regression	Test case cần chạy lại	Khi nào chạy
Smoke regression	Login, create post, like, chat, admin lock user	Sau mỗi lần build
Auth regression	Login đúng/sai, account locked, token hết hạn	Sau khi sửa Auth/JWT/Guard
Post regression	Tạo/sửa/xóa bài, like/unlike, comment	Sau khi sửa PostService/LikeService
Chat regression	Gửi/nhận tin, socket token, offline message	Sau khi sửa socket/message service
Security regression	User thường gọi API admin, token sai, account locked	Sau khi sửa phân quyền



Hình 2.15. Sơ đồ quy trình kiểm thử hồi quy

4.3.6. Kiểm thử hiệu năng – Performance Testing

Performance testing kiểm tra khả năng phản hồi của hệ thống dưới tải nhỏ đến trung bình. Trong phạm vi bài tập lớn, không cần mô phỏng hàng nghìn người dùng mà chỉ cần kiểm thử các API quan trọng.

Công cụ sử dụng: Apache JMeter.

Kịch bản đề xuất:

Kịch bản	API/Chức năng	Tải đề xuất	Chỉ số đo	Tiêu chí pass
Login load	POST /auth/login	20–50 VUs trong 1–3 phút	avg, p95, error rate	p95 < 1000ms, error < 5%
Feed load	GET /posts/feed	30–50 VUs	response time, throughput	p95 < 1500ms, error < 5%
Create post	POST /posts	10–20 VUs	response time, DB write success	p95 < 2000ms, error < 5%

4.4 Ma trận kỹ thuật kiểm thử

Bảng dưới đây tổng hợp các kỹ thuật kiểm thử được sử dụng trong dự án MiniSocial. Việc lựa chọn kỹ thuật kiểm thử dựa trên đặc điểm của từng module và mức độ quan trọng của chức năng.

Nhóm kiểm thử	Kỹ thuật áp dụng	Module áp dụng	Kết quả cần có
White-box	Unit Testing	AuthService, PostService, LikeService, RecommendationService	Kết quả chạy Jest, coverage
White-box	Branch/Condition/Path Testing	Login, Like/Unlike, phân quyền Admin	CFG, đường đi độc lập, bảng nhánh
White-box	Integration Testing	Auth API, Post API, Admin API	Kết quả Supertest/API test
Black-box	Functional Testing	Authentication, Post, Chat, Admin	Bảng test case pass/fail

Black-box	Equivalence Partitioning	Email, password, token, post content	Bảng phân vùng tương đương
Black-box	Boundary Value Analysis	Password, comment, post content, file upload	Bảng giá trị biên
System Testing	End-to-End Testing	Luồng người dùng và Admin	Kịch bản E2E
Regression Testing	Chạy lại test case quan trọng	Auth, Post, Chat, Admin	Bảng regression pass/fail
Non-functional	Performance, Security, Reliability	API, JWT, phân quyền, upload, realtime chat	Bảng kết quả và nhận xét

5. Điều kiện chấp nhận

Hệ thống MiniSocial được xem là đạt yêu cầu nếu thỏa mãn các điều kiện sau:

Nhóm tiêu chí	Điều kiện chấp nhận
Chức năng	Các chức năng chính hoạt động đúng theo đặc tả: đăng ký, đăng nhập, tạo bài viết, like/comment, chat, admin xử lý vi phạm
Bảo mật	API yêu cầu xác thực phải kiểm tra token; user thường không được truy cập API Admin
Phân quyền	Người dùng chỉ được sửa/xóa bài viết của mình; Admin có quyền quản lý user và bài viết
Dữ liệu	Dữ liệu user, post, comment, like, message được lưu và cập nhật đúng
Giao diện	Mobile App và Admin Web hiển thị ổn định, dễ thao tác
Hiệu năng	Các API chính phản hồi trong ngưỡng chấp nhận khi kiểm thử tải nhỏ/trung bình
Hồi quy	Sau khi sửa lỗi, các chức năng cũ vẫn hoạt động bình thường

Điều kiện pass tổng quát:

- Tối thiểu 90% tổng số test case đạt trạng thái Pass.

- 100% test case mức ưu tiên High được thực hiện.
- Không còn lỗi High chưa xử lý.
- Các lỗi Medium hoặc Low còn lại không ảnh hưởng nghiêm trọng đến luồng chính của hệ thống.

6. Defect Tracking

6.1. Mục đích quản lý lỗi

Defect Tracking là quá trình ghi nhận, phân loại, theo dõi và xử lý các lỗi phát hiện trong quá trình kiểm thử. Mỗi lỗi cần được mô tả rõ ràng để nhóm phát triển có thể tái hiện và sửa lỗi.

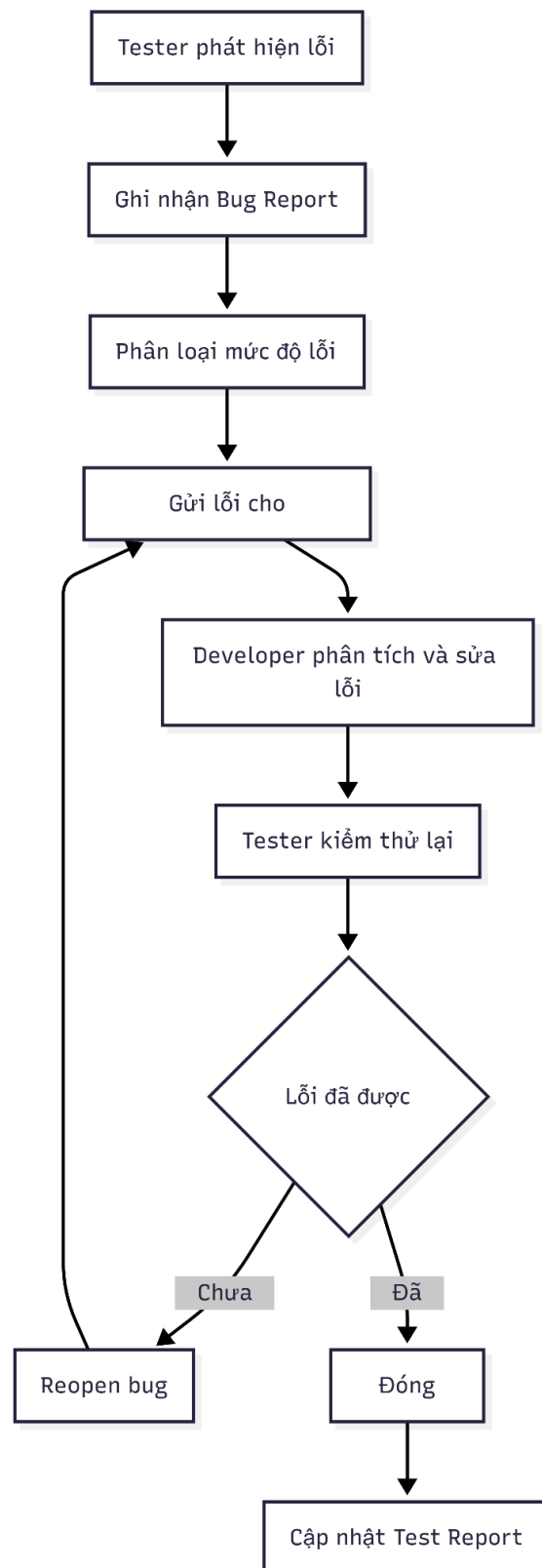
Thông tin cần có trong một bug report:

- Bug ID.
- Module/chức năng xảy ra lỗi.
- Mô tả lỗi.
- Các bước tái hiện lỗi.
- Kết quả mong đợi.
- Kết quả thực tế.
- Mức độ nghiêm trọng.
- Trạng thái lỗi.
- Ảnh minh họa hoặc log nếu có.

6.2. Phân loại lỗi

Mức độ	Ý nghĩa	Ví dụ trong MiniSocial
High	Lỗi nghiêm trọng, ảnh hưởng trực tiếp đến chức năng chính hoặc bảo mật	Không đăng nhập được, user thường truy cập được API Admin, tài khoản bị khóa vẫn đăng nhập được
Medium	Lỗi ảnh hưởng chức năng nhưng chưa làm hệ thống dừng hoàn toàn	LikeCount sai, comment không hiển thị ngay, upload ảnh báo lỗi không rõ
Low	Lỗi nhỏ, chủ yếu ảnh hưởng giao diện hoặc trải nghiệm	Text bị lệch, thông báo lỗi chưa thân thiện, loading hiển thị chưa rõ

6.3. Quy trình xử lý lỗi



Hình 2.19. Sơ đồ quy trình xử lý lỗi

PHẦN III: THỰC HIỆN KIỂM THỬ (TEST EXECUTION)

1. Cài đặt môi trường kiểm thử

1.1 Thiết lập máy chủ và cơ sở dữ liệu

Hệ thống MiniSocial được triển khai trong môi trường kiểm thử riêng nhằm tách biệt dữ liệu test với dữ liệu thật. Backend của hệ thống được xây dựng bằng NestJS, cơ sở dữ liệu sử dụng MongoDB, Admin Web sử dụng Next.js và ứng dụng người dùng sử dụng Flutter.

Đối với backend, nhóm cấu hình môi trường test bằng file `.env.test`. File này chứa các thông tin phục vụ kiểm thử như cổng chạy server, chuỗi kết nối MongoDB test, JWT secret test, thời gian hết hạn token, cấu hình Cloudinary/Firebase ở dạng test hoặc mock. Cơ sở dữ liệu test được đặt riêng với tên `minisocial_test` để tránh ảnh hưởng tới dữ liệu thật trong quá trình chạy unit test, integration test và kiểm thử API.

MongoDB được chạy ở môi trường local hoặc MongoDB Atlas test database. Trường hợp kiểm thử upload ảnh và thông báo realtime, nhóm ưu tiên mock Cloudinary/Firebase trong unit test để kết quả kiểm thử ổn định, không phụ thuộc vào mạng hoặc dịch vụ bên ngoài.

Các dữ liệu test chính được chuẩn bị gồm:

Loại dữ liệu	Dữ liệu kiểm thử	Mục đích
User thường	user1, user2, user3	Đăng nhập, tạo bài, like, comment, chat
User bị khóa	locked_user	Kiểm tra tài khoản bị khóa
Admin	admin	Kiểm thử chức năng quản trị
Post mẫu	post công khai, post của user1, post bị ẩn/xóa	Kiểm thử feed, sửa/xóa bài, like/comment
Conversation	chat 1-1	Kiểm thử gửi/nhận tin nhắn
Interaction	view, like, comment, share	Kiểm thử module gợi ý nội dung

1.2. Cài đặt môi trường phát triển và công cụ kiểm thử

Các công cụ được sử dụng trong quá trình kiểm thử gồm:

Thành phần	Công cụ	Mục đích
Backend	Node.js, npm, NestJS CLI	Chạy API và viết test

Database	MongoDB	Lưu dữ liệu kiểm thử
Unit test / coverage	Jest	Kiểm thử hộp trắng và đo coverage
API black-box	Postman/Newman	Kiểm thử API từ bên ngoài
Admin Web	Playwright/Cypress hoặc kiểm thử thủ công	Kiểm thử giao diện admin và tương thích trình duyệt
Mobile App	Flutter SDK, Android Studio/Emulator	Kiểm thử ứng dụng mobile
Performance	Apache JMeter	Kiểm thử tải và hiệu năng
WebSocket	Postman WebSocket hoặc socket.io-client	Kiểm thử chat realtime

2. Kiểm thử hộp trắng

Kiểm thử hộp trắng được thực hiện nhằm kiểm tra trực tiếp logic xử lý bên trong backend và ML service. Trọng tâm kiểm thử là các service có vai trò quan trọng trong hệ thống MiniSocial, gồm Post, Like, Comment, Chat Realtime và Recommendation.

Phạm vi kiểm thử hộp trắng trong lần thực hiện này bao gồm:

Nhóm chức năng	File test
Post	api/src/tests/post-interaction/posts.service.spec.ts
Like	api/src/tests/post-interaction/likes.service.spec.ts
Comment	api/src/tests/post-interaction/comments.service.spec.ts
Chat Realtime	api/src/tests/chat-realtime/messages.service.spec.ts
Recommendation	ml_server/tests/test_content_based.py

2.1. Unit testing

2.1.1. Unit test cho PostService

Mục tiêu của unit test PostService là kiểm tra logic tạo bài, sửa bài, xóa bài và kiểm tra quyền sở hữu bài viết.

Các nhánh chính đã kiểm thử:

Test case	Nội dung kiểm thử	Kết quả
POST-01	Tạo bài viết text hợp lệ	Pass
POST-02	Tạo bài viết rỗng, không có media	Pass sau khi sửa
POST-03	Tạo bài viết chỉ có media	Pass
POST-05	User sửa bài viết của chính mình	Pass
POST-06	User khác sửa bài viết không thuộc sở hữu	Pass

Lỗi chính được phát hiện trước khi sửa là hệ thống vẫn cho phép tạo bài viết rỗng. Nguyên nhân là `PostsService.create()` chưa kiểm tra điều kiện tối thiểu của bài viết. Sau khi sửa, service kiểm tra:

- content sau khi trim() có nội dung hay không;
- media_urls có tồn tại media hợp lệ hay không;
- nếu không có cả text và media thì trả về `BadRequestException`.

Ngoài ra, nhóm bổ sung kiểm tra quyền sở hữu khi sửa/xóa bài viết. Trước khi sửa, `PostsService.update()` và `PostsService.delete()` chỉ thao tác theo id, chưa kiểm tra user hiện tại có phải chủ bài viết hay không. Sau khi sửa, service lấy post theo id, nếu không tồn tại thì trả về `NotFoundException`, nếu user hiện tại không phải owner thì trả về `ForbiddenException`.

2.1.2. Unit test cho MessagesService

Mục tiêu của unit test MessagesService là kiểm tra logic gửi tin nhắn, chặn tin nhắn rỗng, kiểm tra quyền sửa tin nhắn và kiểm tra trường hợp user bị block.

Các test chính đã thực hiện:

Test case	Nội dung kiểm thử	Kết quả
CHAT-01	Gửi tin nhắn text hợp lệ	Pass
CHAT-02	Gửi tin nhắn rỗng, không có media/file	Pass sau khi sửa
CHAT-08	Sender bị block không được gửi tin	Pass
CHAT-10	User sửa tin nhắn của người khác	Pass

Lỗi chính trước khi sửa là `MessagesService.send()` vẫn cho phép lưu tin nhắn rỗng với content: "", media_urls: [] và không có file_url. Sau khi sửa, service kiểm tra ba điều kiện:

- có text hợp lệ sau khi trim();

- có media;
- có file đính kèm.

Nếu cả ba điều kiện đều không thỏa mãn, hệ thống trả về `BadRequestException`. Ngoài ra, phần chỉnh sửa tin nhắn cũng được bổ sung kiểm tra để không cho phép sửa tin nhắn text thành chuỗi rỗng.

2.1.3. Unit test cho LikesService

Mục tiêu của unit test LikesService là kiểm tra logic like/unlike và giảm rủi ro duplicate khi nhiều request được gửi đồng thời.

Các test chính đã thực hiện:

Test case	Nội dung kiểm thử	Kết quả
LIKE-01	User like bài viết lần đầu	Pass
LIKE-02	User unlike bài viết đã like	Pass
LIKE-03	Kiểm tra cập nhật likes_count bằng \$inc	Pass
LIKE-04	Mô phỏng duplicate key khi spam like	Pass

Trước khi sửa, logic toggle like theo kiểu tìm bản ghi like trước rồi mới tạo/xóa. Cách này có rủi ro race condition nếu nhiều request song song cùng thao tác trên một bài viết. Nhóm đã bổ sung unique index cho cặp (user_id, post_id) và (user_id, comment_id), đồng thời xử lý lỗi duplicate key 11000. Việc cập nhật số lượng like được chuyển sang dùng \$inc để tăng/giảm count theo hướng an toàn hơn.

2.1.4. Unit test cho CommentsService

Mục tiêu của unit test CommentsService là kiểm tra logic tạo comment, kiểm tra comment rỗng và comment vượt quá độ dài cho phép.

Các test chính đã thực hiện:

Test case	Nội dung kiểm thử	Kết quả
COMMENT-01	Tạo comment hợp lệ	Pass
COMMENT-02	Comment rỗng hoặc chỉ chứa khoảng trắng	Pass
COMMENT-03	Comment dài hơn 1000 ký tự	Pass

Trước khi sửa, comment chưa được chặn đầy đủ ở các giá trị biên. Sau khi sửa, nhóm bổ sung validation ở cả DTO và service. DTO sử dụng `@MinLength(1)` và `@MaxLength(1000)`. Service tiếp tục xử lý `trim()` nội dung comment, nếu

rỗng thì trả về `BadRequestException`, nếu dài hơn 1000 ký tự thì trả về `BadRequestException`.

2.1.5. Unit test cho Recommendation ML service

Module Recommendation được kiểm thử bằng Python unittest tại thư mục `ml_server`. Kết quả chạy test:

Ran 5 tests in 0.003s

OK

Các test đã pass:

Test case	Nội dung kiểm thử	Kết quả
<code>test_build_tag_profile_accumulates_weights</code>	Kiểm tra xây dựng hồ sơ tag và cộng dồn trọng số	Pass
<code>test_compute_content_scores_skips_seen_posts_and_normalizes</code>	Kiểm tra bỏ qua bài đã xem và chuẩn hóa điểm	Pass
<code>test_get_best_matching_tag_returns_none_when_no_match</code>	Không có tag phù hợp thì trả về None	Pass
<code>test_get_best_matching_tag_returns_top_weighted_tag</code>	Lấy tag có trọng số cao nhất	Pass
<code>test_recommend_response_schema_accepts_valid_payload</code>	Kiểm tra schema response hợp lệ	Pass

Kết quả cho thấy module Recommendation không bị ảnh hưởng sau khi sửa lỗi backend.

2.1.6. Unit test cho AuthService

Mục tiêu của unit test AuthService là kiểm tra logic đăng ký tài khoản, đăng nhập, xác thực người dùng và xử lý các trường hợp ngoại lệ liên quan đến tài khoản.

Các nhánh chính đã kiểm thử:

Test case	Nội dung kiểm thử	Kết quả
AUTH-01	Đăng ký với email và mật khẩu hợp lệ	Pass

AUTH-02	Đăng ký với email không đúng định dạng	Pass
AUTH-03	Đăng ký với email đã tồn tại	Pass
AUTH-04	Đăng ký với mật khẩu không đủ độ dài tối thiểu	Pass
AUTH-05	Đăng nhập với thông tin hợp lệ	Pass
AUTH-06	Đăng nhập sai mật khẩu	Pass
AUTH-07	Đăng nhập bằng tài khoản bị khóa	Pass
AUTH-08	Sử dụng token không hợp lệ hoặc hết hạn	Pass
AUTH-09	Truy cập API bảo vệ khi không có token	Pass
AUTH-10	Người dùng thường truy cập API dành cho Admin	Pass

Lỗi chính được phát hiện trong quá trình kiểm thử là các trường hợp dữ liệu không hợp lệ có thể dẫn đến việc tạo tài khoản hoặc xác thực sai nếu không được kiểm tra đầy đủ. Để khắc phục, AuthService thực hiện kiểm tra định dạng email, độ dài mật khẩu và sự tồn tại của tài khoản trước khi thực hiện đăng ký hoặc đăng nhập.

Ngoài ra, nhóm kiểm thử các nhánh xử lý xác thực JWT nhằm đảm bảo chỉ các token hợp lệ mới được phép truy cập các API được bảo vệ. Hệ thống cũng kiểm tra trạng thái tài khoản trước khi cho phép đăng nhập. Nếu tài khoản bị khóa, service sẽ trả về UnauthorizedException và từ chối truy cập. Các trường hợp token không hợp lệ, token hết hạn hoặc không có token đều được xử lý đúng và trả về mã lỗi bảo mật phù hợp.

2.1.7. Unit test cho AdminService

Mục tiêu của unit test AdminService là kiểm tra các chức năng quản trị hệ thống bao gồm khóa tài khoản người dùng, mở khóa tài khoản, quản lý bài viết vi phạm và kiểm tra quyền truy cập của quản trị viên.

Các nhánh chính đã kiểm thử:

Test case	Nội dung kiểm thử	Kết quả
ADMIN-01	Admin khóa tài khoản người dùng	Pass
ADMIN-02	Admin mở khóa tài khoản người dùng	Pass
ADMIN-03	Admin ẩn hoặc xóa bài viết vi phạm	Pass
ADMIN-04	User thường gọi API quản trị	Pass
ADMIN-05	Ghi nhận thao tác quản trị vào hệ thống	Pass

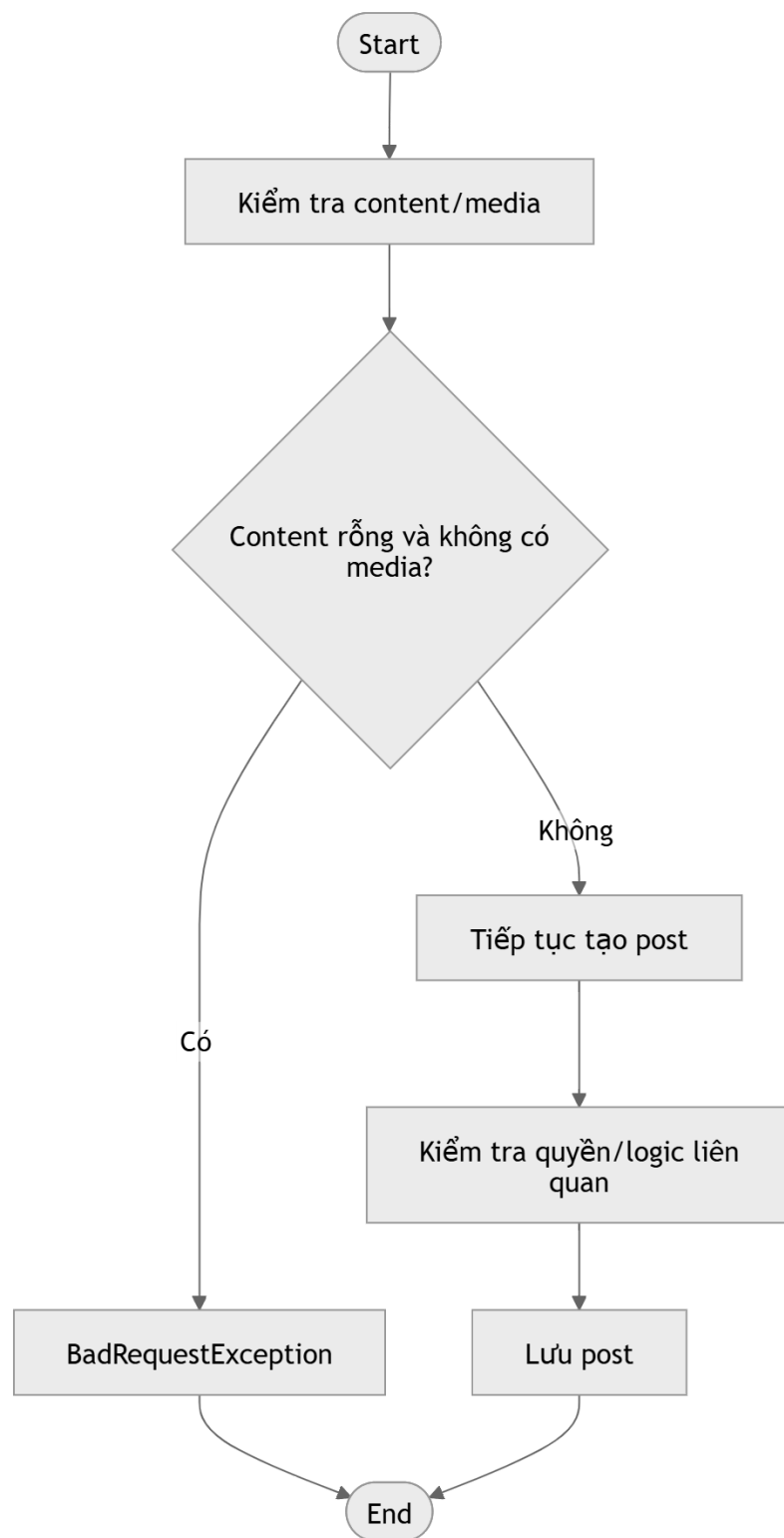
Lỗi chính được phát hiện trước khi hoàn thiện là các thao tác quản trị chưa được kiểm tra quyền truy cập đầy đủ. Điều này có thể dẫn đến việc người dùng thông thường thực hiện các chức năng chỉ dành cho quản trị viên. Để khắc phục, AdminService bổ sung kiểm tra role của người dùng trước khi thực hiện các thao tác quản trị.

Ngoài ra, nhóm kiểm thử các trường hợp khóa và mở khóa tài khoản nhằm đảm bảo trạng thái người dùng được cập nhật chính xác trong cơ sở dữ liệu. Đối với các thao tác xử lý bài viết vi phạm, hệ thống kiểm tra sự tồn tại của bài viết trước khi thực hiện cập nhật trạng thái hoặc xóa dữ liệu. Nếu đối tượng không tồn tại, service sẽ trả về NotFoundException; nếu người thực hiện không có quyền quản trị, hệ thống sẽ trả về ForbiddenException. Sau khi hoàn tất kiểm thử, các chức năng quản trị đều hoạt động đúng theo yêu cầu và đảm bảo tính an toàn trong quá trình vận hành hệ thống.

2.2. Branch / Condition / Path testing

2.2.1. Branch testing cho tạo bài viết

Luồng tạo bài viết có các nhánh chính:



Hình 3.10 Sơ đồ branch testing tạo bài viết

Các nhánh đã được kiểm thử:

Nhánh	Điều kiện	Expected	Kết quả
-------	-----------	----------	---------

B1	Có content hợp lệ	Tạo post thành công	Pass
B2	Content rỗng và không có media	Reject BadRequestException	Pass
B3	Content rỗng nhưng có media	Tạo media-only post	Pass
B4	User khác sửa bài	Reject ForbiddenException	Pass

2.2.2. Condition testing cho Post ownership

Điều kiện chính:

post tồn tại AND user hiện tại là owner

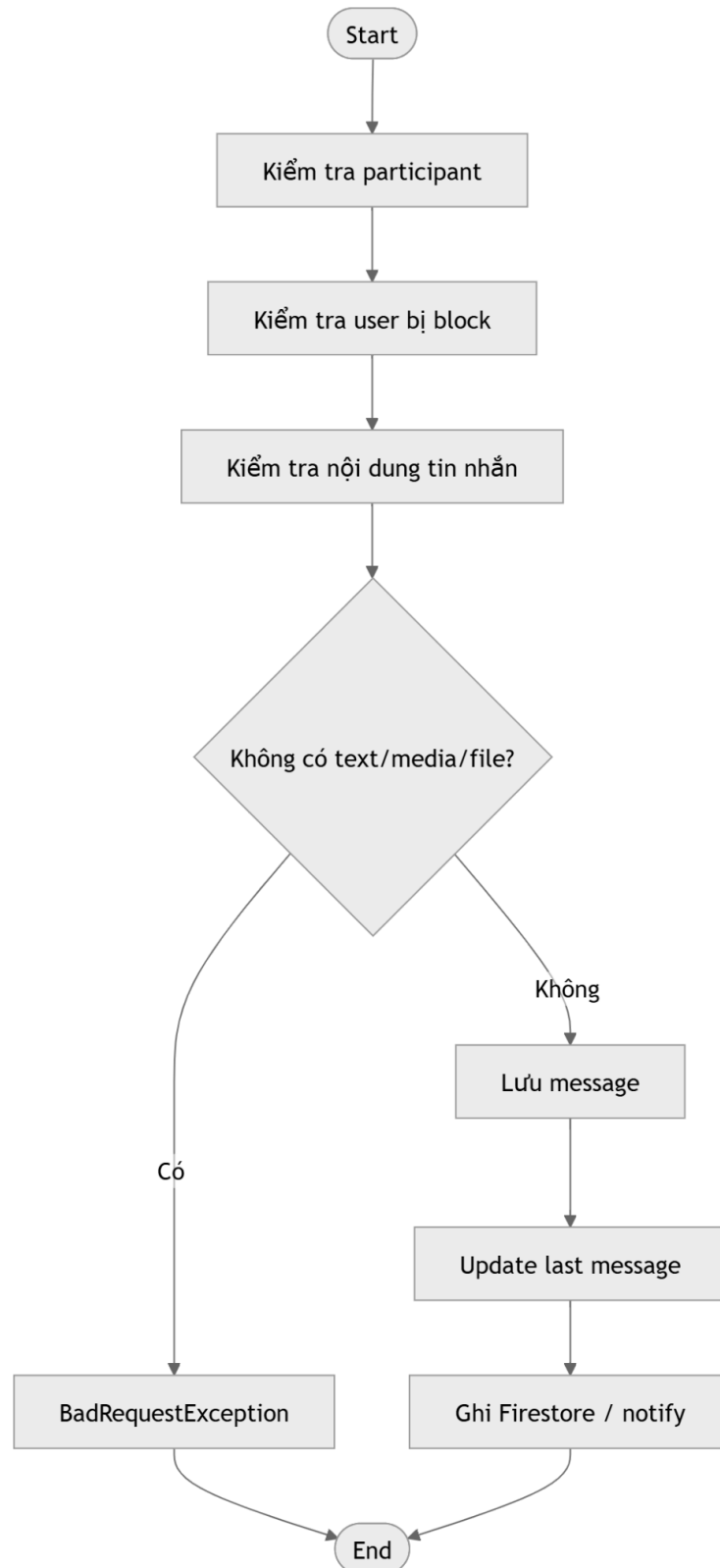
Các trường hợp đã kiểm thử:

Trường hợp	post tồn tại	user là owner	Expected	Kết quả
C1	True	True	Cho phép update/delete	Pass
C2	True	False	ForbiddenException	Pass
C3	False	-	NotFoundException	Đã bổ sung logic xử lý

Điều kiện này giúp đảm bảo user không thể sửa hoặc xóa bài viết không thuộc sở hữu của mình.

2.2.3. Branch testing cho gửi tin nhắn

Luồng gửi tin nhắn có các nhánh quan trọng:



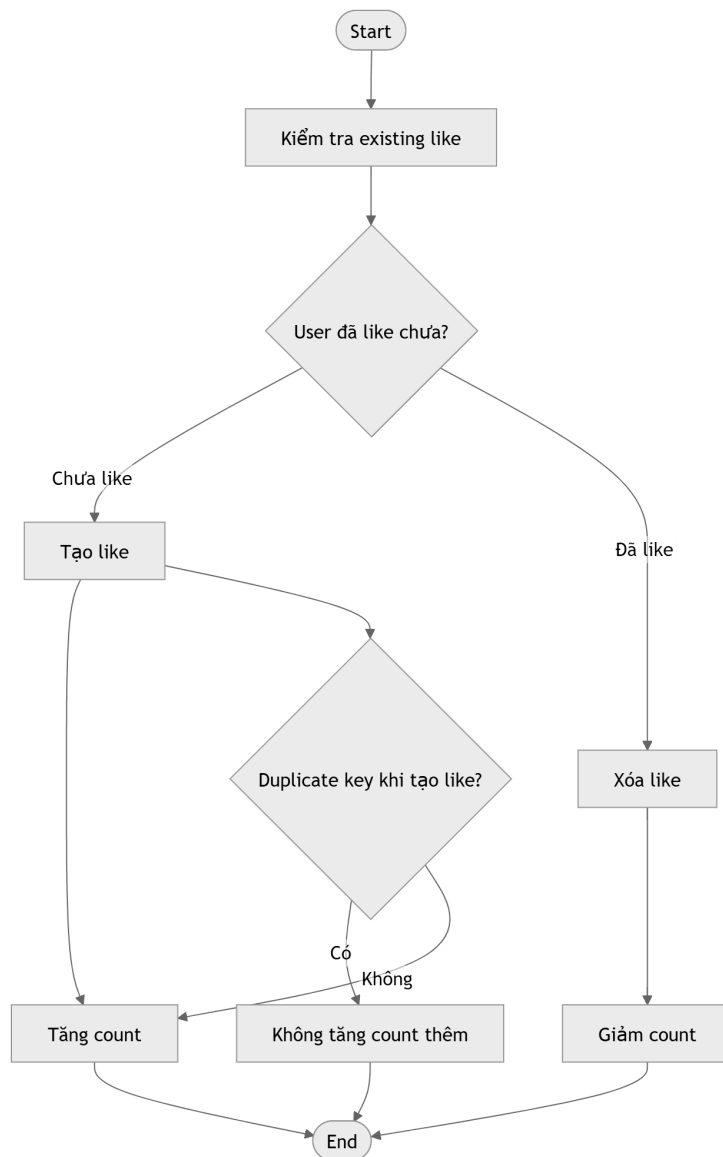
Hình 3.11 Sơ đồ branch testing gửi tin nhắn

Các nhánh đã được kiểm thử:

Nhánh	Điều kiện	Expected	Kết quả
B1	Tin nhắn text hợp lệ	Lưu message thành công	Pass
B2	Tin nhắn rỗng	BadRequestException	Pass
B3	Sender bị block	ForbiddenException	Pass
B4	User sửa tin nhắn người khác	ForbiddenException	Pass

2.2.4. Branch testing cho Like/Unlike

Luồng like/unlike có các nhánh:



Hình 3.12 Sơ đồ branch testing like/unlike bài viết

Các nhánh đã được kiểm thử:

Nhánh	Điều kiện	Expected	Kết quả
B1	User chưa like	Tạo like, tăng likes_count	Pass
B2	User đã like	Unlike, giảm likes_count	Pass
B3	Duplicate key 11000	Không tạo duplicate, không tăng count sai	Pass

2.2.5. Condition testing cho comment

Điều kiện chính:

content sau trim không rỗng AND content.length <= 1000

Các trường hợp kiểm thử:

Trường hợp	Nội dung comment	Expected	Kết quả
C1	Comment hợp lệ	Lưu comment	Pass
C2	Chuỗi rỗng hoặc toàn khoảng trắng	BadRequestException	Pass
C3	1001 ký tự	BadRequestException	Pass

2.2.6. Path testing cho Recommendation

Đối với Recommendation, nhóm kiểm tra các đường đi logic chính trong hàm xử lý content-based:

Path	Mô tả	Expected	Kết quả
P1	Có dữ liệu tương tác, có tag phù hợp	Tính được điểm gợi ý	Pass
P2	Bài viết đã xem	Bỏ qua bài đã xem	Pass
P3	Không có tag phù hợp	Trả về None	Pass
P4	Payload response hợp lệ	Schema chấp nhận	Pass

2.3. Integration testing

Trong phạm vi kết quả hiện tại, nhóm đã thực hiện kiểm thử tích hợp ở mức service với các dependency được mock như model MongoDB, Firebase/Firestore, notification hoặc repository liên quan. Mục tiêu là kiểm tra

sự phối hợp giữa logic service và các thành phần phụ thuộc mà không cần gọi database thật.

Các nhóm tích hợp đã kiểm tra:

Nhóm	Thành phần liên quan	Nội dung kiểm thử	Kết quả
Post	PostService, PostModel, User/Category interaction	Tạo post, validate content/media, kiểm tra ownership	Pass
Like	LikesService, LikeModel, PostModel/CommentModel	Like/unlike, cập nhật count, xử lý duplicate	Pass
Comment	CommentsService, CommentModel, notification mock	Tạo comment, validate boundary	Pass
Chat	MessagesService, ParticipantModel, Firestore mock	Gửi tin, block user, reject message rỗng	Pass
Recommendation	Python recommender, schema model	Tính điểm và kiểm tra response schema	Pass

Lưu ý: nhóm chưa mở rộng đầy đủ sang E2E test qua controller/API thật trong lần chạy này. Phần npm run test:e2e có thể được thực hiện ở vòng sau để kiểm tra luồng HTTP request từ Controller → Service → Database test.

2.4. Kết quả kiểm thử hộp trắng

Backend Jest regression subset

Kết quả chạy backend sau khi sửa lỗi:

Chỉ số	Kết quả
Test suites	4 passed / 4 total
Tests	21 passed / 21 total
Snapshots	0 total
Trạng thái	OK

Các file test đã pass:

File test	Kết quả
-----------	---------

src/tests/post-interaction/posts.service.spec.ts	Pass
src/tests/post-interaction/likes.service.spec.ts	Pass
src/tests/post-interaction/comments.service.spec.ts	Pass
src/tests/chat-realtime/messages.service.spec.ts	Pass

ML service unittest

Kết quả chạy ML service:

Chỉ số	Kết quả
Tổng số test	5
Test pass	5
Test fail	0
Thời gian chạy	0.003s
Trạng thái	OK

Coverage sau sửa lỗi

Kết quả coverage toàn project sau khi chạy subset:

Coverage scope	Statements	Branches	Functions	Lines
All files	15.84%	14.75%	7.70%	16.07%
comments.service.ts	63.88%	58.46%	37.50%	65.15%
likes.service.ts	81.33%	59.70%	62.50%	80.82%
messages.service.ts	47.36%	46.51%	42.85%	49.62%
posts.service.ts	34.33%	41.73%	16.12%	34.61%

Coverage toàn project còn thấp vì nhóm chỉ chạy một subset phục vụ kiểm thử hộp trắng cho các module trọng tâm. Kết quả này không đại diện cho toàn bộ hệ thống, mà chủ yếu phản ánh mức độ bao phủ của các service được chọn trong phạm vi kiểm thử.

3. Kiểm thử hộp đen

3.1 Kiểm thử hộp đen chức năng Post

3.1.1. Bảng điều kiện kiểm thử chức năng tạo bài viết

Điều kiện	Token đăng nhập	Nội dung bài viết	File ảnh/media	Định dạng file	Kết quả
TH1	True	True	Không có	-	Tạo bài viết thành công
TH2	True	True	Có	True	Tạo bài viết có ảnh thành công
TH3	True	False	Không có	-	Hiển thị lỗi: Vui lòng nhập nội dung hoặc chọn ảnh
TH4	True	False	Có	True	Tạo bài viết thành công
TH5	True	True	Có	False	Hiển thị lỗi: File không đúng định dạng
TH6	True	True	File quá dung lượng	False	Hiển thị lỗi: Ảnh quá lớn, vui lòng chọn ảnh dưới 10MB
TH7	False	True	Không có	-	Từ chối tạo bài, yêu cầu đăng nhập
TH8	True	Nội dung vượt giới hạn	Không có	-	Hiển thị lỗi: Nội dung vượt quá độ dài cho phép

3.1.2. Diễn giải test case chức năng tạo bài viết

Test case 1: Người dùng đã đăng nhập, nhập nội dung bài viết hợp lệ, không upload ảnh ⇒ Tạo bài viết thành công.

Test case 2: Người dùng đã đăng nhập, nhập nội dung hợp lệ và upload ảnh đúng định dạng ⇒ Tạo bài viết có ảnh thành công.

Test case 3: Người dùng đã đăng nhập nhưng không nhập nội dung và không upload media ⇒ Hệ thống báo lỗi nội dung không được để trống.

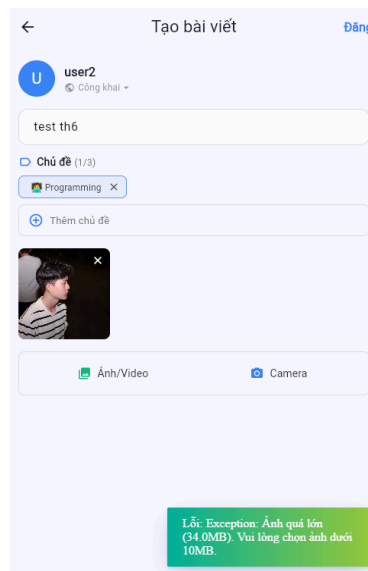
Test case 4: Người dùng đã đăng nhập, không nhập text nhưng có upload media hợp lệ $\Rightarrow$ Hệ thống cho phép tạo bài nếu nghiệp vụ chấp nhận bài viết chỉ có media.

Test case 5: Người dùng nhập nội dung hợp lệ nhưng upload file sai định dạng $\Rightarrow$ Hệ thống từ chối upload và báo lỗi định dạng file.

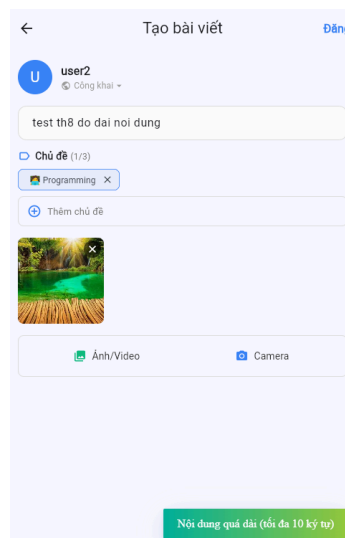
Test case 6: Người dùng nhập nội dung hợp lệ nhưng upload file vượt dung lượng $\Rightarrow$ Hệ thống từ chối upload và báo lỗi dung lượng.

Test case 7: Người dùng chưa đăng nhập thực hiện tạo bài $\Rightarrow$ Hệ thống từ chối và yêu cầu đăng nhập.

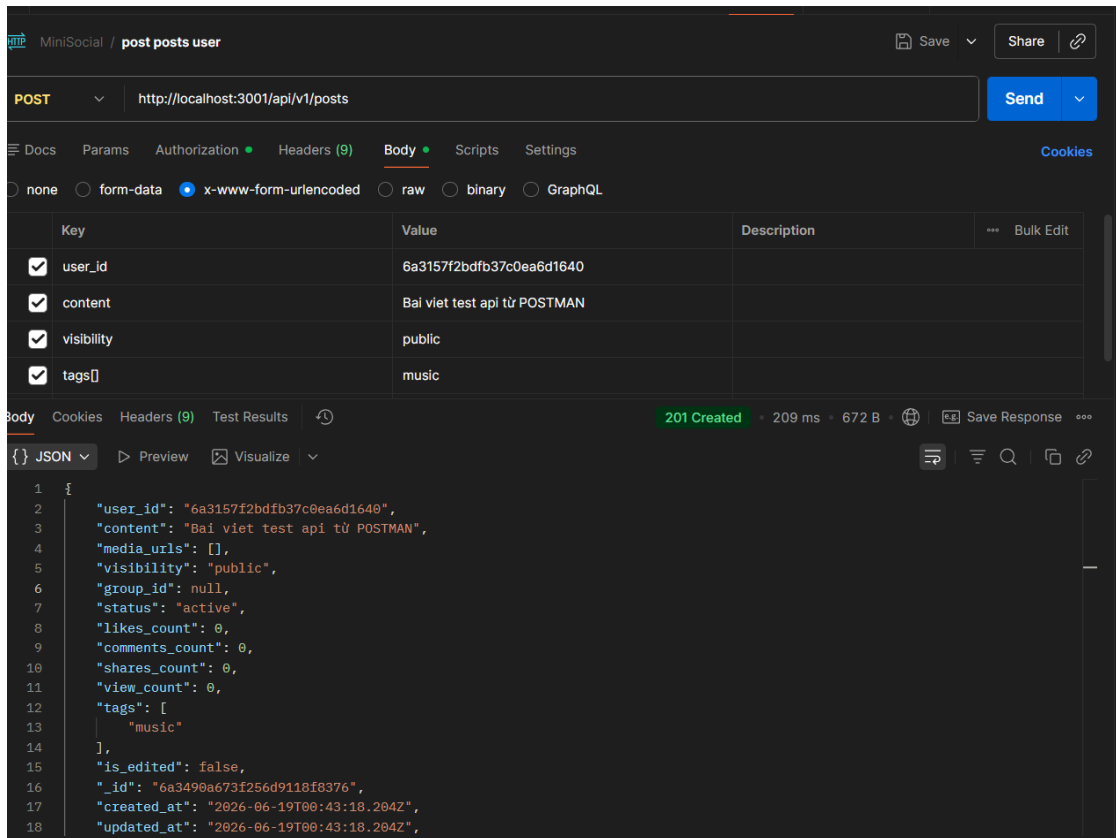
Test case 8: Người dùng nhập nội dung vượt quá giới hạn ký tự $\Rightarrow$ Hệ thống báo lỗi nội dung vượt quá độ dài cho phép.



Hình 3.1 Giao diện kiểm thử dung lượng ảnh bài viết



Hình 3.2 Giao diện kiểm thử độ dài nội dung bài viết



Hình 3.11 POST-POSTS tạo bài viết bằng api với POSTMAN

3.1.3. Bảng điều kiện kiểm thử chức năng sửa/xóa bài viết

Điều kiện	Token đăng nhập	Bài viết tồn tại	Người thao tác là chủ bài	Nội dung sửa hợp lệ	Kết quả
TH1	True	True	True	True	Sửa bài viết thành công
TH2	True	True	True	False	Cập nhập thất bại
TH3	True	True	False	True	Từ chối thao tác, trả lỗi không có quyền
TH4	True	False	-	True	Hiện thị lỗi bài viết không tồn tại
TH5	False	True	-	True	Từ chối thao tác, yêu cầu đăng nhập
TH6	True	True	True	-	Xóa bài viết thành công

TH7	True	True	False	-	Không cho xóa bài của người khác
TH8	True	False	-	-	Hiện thị lỗi không tìm thấy bài viết

3.1.4. Diễn giải test case chức năng sửa/xóa bài viết

Test case 1: Chủ bài viết đăng nhập và sửa nội dung hợp lệ $\Rightarrow$ Cập nhật bài viết thành công.

Test case 2: Chủ bài viết sửa nội dung rỗng hoặc không hợp lệ $\Rightarrow$ Hệ thống hiện thị lỗi.

Test case 3: Người dùng khác cố sửa bài viết không phải của mình $\Rightarrow$ Hệ thống từ chối và trả lỗi không có quyền.

Test case 4: Người dùng sửa bài viết không tồn tại $\Rightarrow$ Hệ thống báo lỗi không tìm thấy bài viết.

Test case 5: Người dùng chưa đăng nhập sửa bài $\Rightarrow$ Hệ thống yêu cầu đăng nhập.

Test case 6: Chủ bài viết xóa bài của mình $\Rightarrow$ Xóa bài thành công, bài không còn hiện thị trên feed.

Test case 7: Người dùng khác xóa bài của người khác $\Rightarrow$ Hệ thống từ chối thao tác.

Test case 8: Xóa bài viết không tồn tại $\Rightarrow$ Hệ thống báo lỗi không tìm thấy bài viết.

3.1.5. Bảng điều kiện kiểm thử chức năng tương tác bài viết

Điều kiện	Token đăng nhập	Bài viết tồn tại	Loại tương tác	Dữ liệu hợp lệ	Kết quả
TH1	True	True	Like	True	Like thành công, số lượt like tăng
TH2	True	True	Unlike	True	Unlike thành công, số lượt like giảm
TH3	True	False	Like	True	Hiện thị lỗi bài viết không tồn tại

TH4	False	True	Like	True	Từ chối thao tác, yêu cầu đăng nhập
TH5	True	True	Comment	True	Bình luận thành công
TH6	True	True	Comment	False	Hiển thị lỗi bình luận không được để trống
TH7	True	True	Report	True	Báo cáo bài viết thành công
TH8	True	True	Like/Unlike liên tục	True	Trạng thái like ổn định, không bị lệch số lượng

3.1.6. Diễn giải test case chức năng tương tác bài viết

Test case 1: Người dùng đăng nhập và like bài viết tồn tại $\Rightarrow$ Like thành công, bài viết cập nhật trạng thái đã like.

Test case 2: Người dùng đã like bài viết và nhấn unlike $\Rightarrow$ Unlike thành công, trạng thái like được hủy.

Test case 3: Người dùng like bài viết không tồn tại $\Rightarrow$ Hệ thống trả lỗi không tìm thấy bài viết.

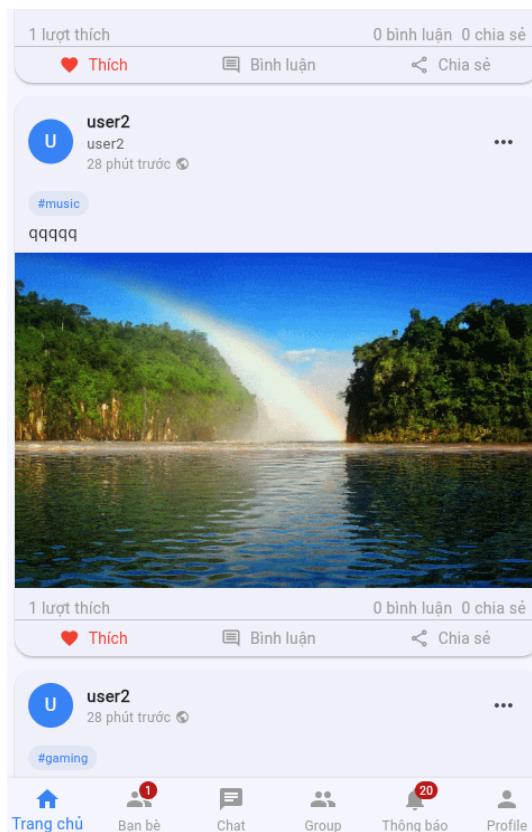
Test case 4: Người dùng chưa đăng nhập nhấn like $\Rightarrow$ Hệ thống yêu cầu đăng nhập.

Test case 5: Người dùng nhập bình luận hợp lệ $\Rightarrow$ Bình luận được lưu và hiển thị dưới bài viết.

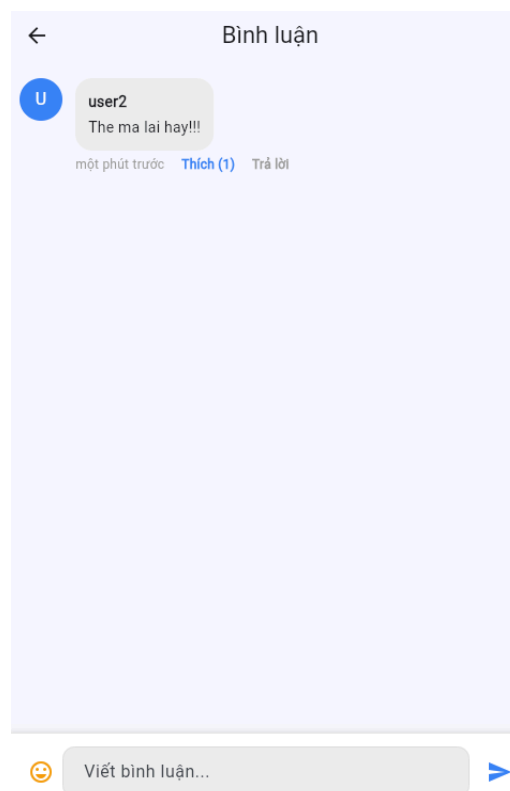
Test case 6: Người dùng gửi bình luận rỗng $\Rightarrow$ Hệ thống báo lỗi bình luận không được để trống.

Test case 7: Người dùng báo cáo bài viết vi phạm $\Rightarrow$ Hệ thống ghi nhận report thành công.

Test case 8: Người dùng nhấn like/unlike liên tục nhiều lần $\Rightarrow$ Hệ thống không làm sai lệch trạng thái like và tổng số like.



Hình 3.3 Giao diện kiểm thử like bài viết



Hình 3.4 Giao diện kiểm thử comment bài viết

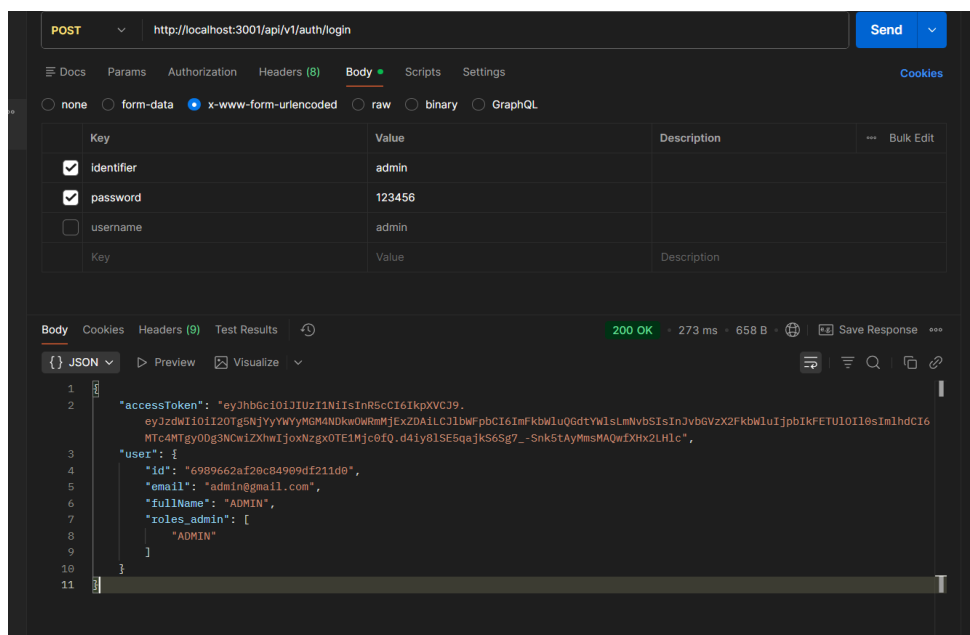
3.1.7. Bảng điều kiện kiểm thử chức năng xác thực người dùng

TC	Email hợp lệ	Password hợp lệ	Trạng thái tài khoản	Token hợp lệ	Kết quả mong đợi
TH1	True	True	Chưa tồn tại	-	Tạo tài khoản thành công
TH2	False	True	-	-	Hiển thị lỗi: Email không hợp lệ
TH3	True	True	Đã tồn tại	-	Hiển thị lỗi: Email đã tồn tại
TH4	True	False	Chưa tồn tại	-	Hiển thị lỗi: Mật khẩu không đủ độ dài tối thiểu
TH5	True	True	Active	-	Đăng nhập thành công, trả về JWT Token
TH6	True	False	Active	-	Từ chối đăng nhập, thông báo sai mật khẩu
TH7	True	True	Blocked	-	Từ chối đăng nhập, thông báo tài khoản bị khóa
TH8	True	True	Active	False	Trả về lỗi 401 Unauthorized
TH9	True	True	Active	Token đã logout	Trả về lỗi 401 Unauthorized (nếu hệ thống hỗ trợ logout/revoke token)
TH10	True	True	User thường	True	Trả về lỗi 403 Forbidden khi truy cập API Admin

3.1.8. Diễn giải test case chức năng xác thực người dùng

Test case 1: Người dùng đăng ký tài khoản với email hợp lệ và mật khẩu hợp lệ
 ⇒ Hệ thống tạo tài khoản thành công và lưu thông tin người dùng vào cơ sở dữ liệu.

Test case 10: Người dùng thông thường sử dụng token hợp lệ để truy cập API quản trị $\Rightarrow$ Hệ thống từ chối truy cập và trả về lỗi 403 Forbidden.



Hình 3.12 POST-LOGIN đăng nhập bằng api với POSTMAN

3.1.9. Bảng điều kiện kiểm thử chức năng Admin

TC	Có quyền Admin	User tồn tại	Bài viết tồn tại	Yêu cầu hợp lệ	Kết quả mong đợi
TH1	True	True	-	Khóa user	User bị khóa thành công, không thể đăng nhập
TH2	True	True	-	Mở khóa user	User được mở khóa và đăng nhập lại được
TH3	True	-	True	Xóa/ẩn bài viết	Bài viết không còn hiển thị trên Feed
TH4	False	True	-	Khóa user	Trả về lỗi 403 Forbidden

3.1.10. Diễn giải test case chức năng Admin

Test case 1: Quản trị viên thực hiện khóa tài khoản người dùng $\Rightarrow$ Tài khoản bị khóa thành công và người dùng không thể đăng nhập vào hệ thống.

Test case 2: Quản trị viên mở khóa tài khoản người dùng đã bị khóa $\Rightarrow$ Tài khoản được kích hoạt trở lại và người dùng có thể đăng nhập bình thường.

Test case 3: Quản trị viên xóa hoặc ẩn bài viết vi phạm $\Rightarrow$ Bài viết không còn hiển thị trên danh sách bài viết hoặc trang Feed của người dùng.

Test case 4: Người dùng thông thường gọi API khóa tài khoản hoặc các API quản trị $\Rightarrow$ Hệ thống từ chối truy cập và trả về lỗi 403 Forbidden.

Test case 5: Quản trị viên thực hiện thao tác xóa bài viết hoặc khóa tài khoản $\Rightarrow$ Hệ thống hiển thị xác nhận thao tác và ghi nhận log phục vụ việc theo dõi, kiểm tra và truy vết sau này.

TH8	True	True	Có ký tự đặc biệt/script	Online	Tin nhắn được xử lý an toàn, không chạy script trên giao diện
-----	------	------	--------------------------	--------	---

3.2.2. Diễn giải test case chức năng gửi tin nhắn

Test case 1: User A đăng nhập, gửi tin nhắn hợp lệ cho User B đang online $\Rightarrow$ User B nhận được tin nhắn realtime.

Test case 2: User A gửi tin nhắn rỗng $\Rightarrow$ Hệ thống báo lỗi tin nhắn không được để trống.

Test case 3: User A gửi tin cho người nhận không tồn tại $\Rightarrow$ Hệ thống báo lỗi người nhận không hợp lệ.

Test case 4: Người dùng chưa đăng nhập gửi tin nhắn $\Rightarrow$ Hệ thống từ chối và yêu cầu đăng nhập.

Test case 5: User A gửi tin cho User B đang offline $\Rightarrow$ Tin nhắn được lưu và hiển thị khi User B online lại.

Test case 6: Đang gửi tin thì mất mạng hoặc mất kết nối socket $\Rightarrow$ Hệ thống hiển thị trạng thái gửi thất bại hoặc cho phép gửi lại.

Test case 7: Người dùng gửi tin nhắn vượt quá số ký tự cho phép $\Rightarrow$ Hệ thống báo lỗi vượt giới hạn.

Test case 8: Người dùng gửi nội dung chứa script hoặc ký tự đặc biệt $\Rightarrow$ Hệ thống hiển thị an toàn, không thực thi mã độc trên giao diện.

3.2.3. Bảng điều kiện kiểm thử chức năng block/unblock trong chat

3.2.4. Diễn giải test case chức năng block/unblock

Test case 1: Hai người dùng không block nhau, gửi tin hợp lệ $\Rightarrow$ Tin nhắn được gửi thành công.

Test case 2: User B đã block User A, User A gửi tin cho User B $\Rightarrow$ Hệ thống từ chối gửi tin.

Test case 3: User A đã block User B, User A gửi tin cho User B $\Rightarrow$ Hệ thống không cho gửi hoặc không hiển thị hội thoại tùy theo thiết kế.

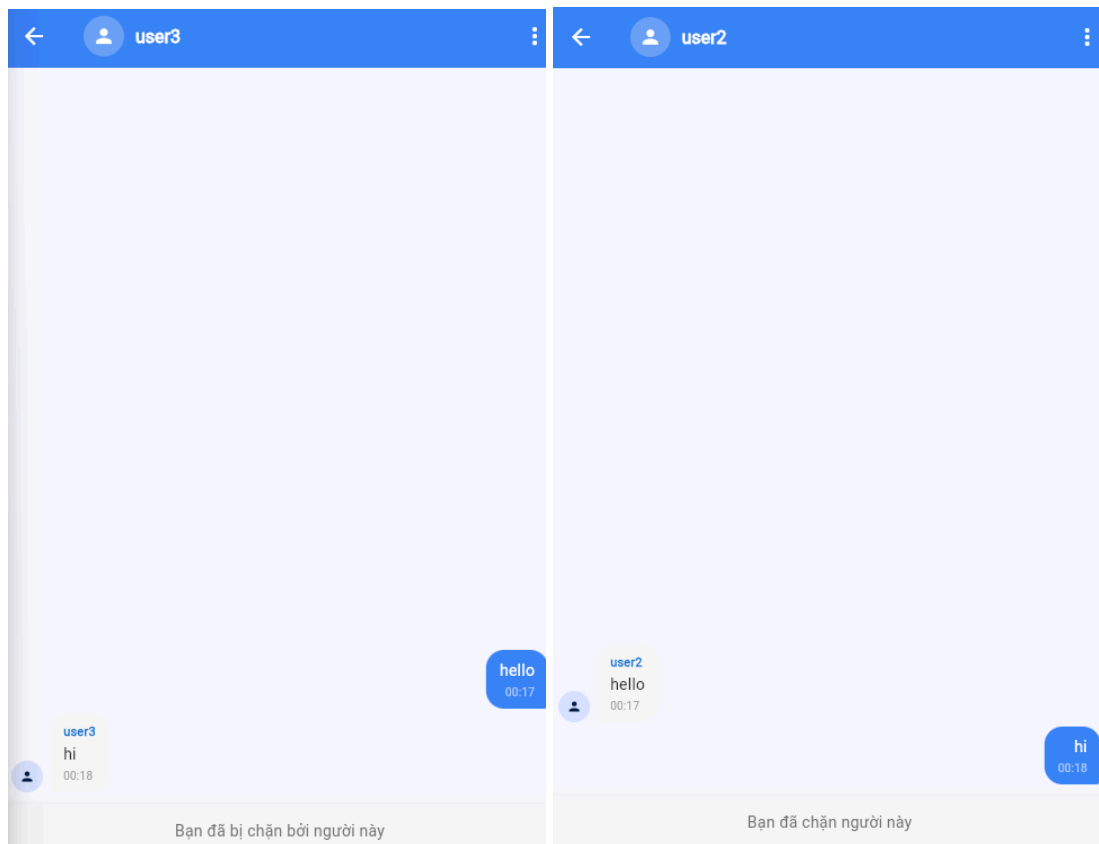
Test case 4: User B unblock User A, User A gửi lại tin nhắn $\Rightarrow$ Tin nhắn được gửi thành công.

Test case 5: Gửi tin tới tài khoản không tồn tại $\Rightarrow$ Hệ thống báo lỗi người dùng không tồn tại.

Test case 6: Người dùng chưa đăng nhập thao tác gửi tin $\Rightarrow$ Hệ thống yêu cầu đăng nhập.

Test case 7: User bị block và gửi tin nhắn rồi $\Rightarrow$ Hệ thống không cho gửi tin.

Test case 8: Người dùng block/unblock nhiều lần liên tục $\Rightarrow$ Trạng thái cuối cùng phải được cập nhật đúng.



Hình 3.5 Giao diện người block và người bị block

3.3. Kiểm thử giá trị biên

3.3.2. Kiểm thử giá trị biên cho chức năng bài viết (Post)

a. Số ký tự tối đa của bài viết

Theo cấu hình hệ thống:

- `max_post_length` = 10 ký tự

Miền giá trị kiểm thử: 0 → 10 ký tự

Điều kiện biên	Giá trị kiểm thử	Kết quả mong đợi
Min-1	0 ký tự	Không cho phép tạo bài viết (báo lỗi rỗng)
Min	1 ký tự	Tạo bài viết thành công
Min+1	2 ký tự	Tạo bài viết thành công
Max-1	9 ký tự	Tạo bài viết thành công
Max	10 ký tự	Tạo bài viết thành công
Max+1	11 ký tự	Báo lỗi vượt giới hạn ký tự

b. Số lượng ảnh trong một bài viết

Theo cấu hình hệ thống:

- `max_images_per_post` = 3 ảnh

Miền giá trị kiểm thử: 0 → 3 ảnh

Điều kiện biên	Giá trị kiểm thử	Kết quả mong đợi
Min	0 ảnh	Cho phép tạo bài viết không có ảnh
Min+1	1 ảnh	Upload thành công
Mid	2 ảnh	Upload thành công
Max	3 ảnh	Upload thành công
Max+1	4 ảnh	Báo lỗi vượt số lượng ảnh cho phép

3.3.3. Kiểm thử giá trị biên cho chức năng Upload file

a. Dung lượng file upload tối đa

Theo cấu hình hệ thống:

- `max_upload_size_mb` = 10MB

Miền giá trị kiểm thử: 0 → 10 MB

Điều kiện biên	Giá trị kiểm thử	Kết quả mong đợi
Min	0 MB	Không có file hoặc bỏ qua upload
Min+1	0.1 MB	Upload thành công
Max-1	9.9 MB	Upload thành công
Max	10 MB	Upload thành công
Max+1	10.1 MB	Từ chối upload, báo lỗi vượt dung lượng

b. Định dạng file upload

Các định dạng hợp lệ:

- jpg, jpeg, png, webp, gif

Miền kiểm thử tập trung vào tính hợp lệ của định dạng file:

Điều kiện biên	Giá trị kiểm thử	Kết quả mong đợi
Valid-1	.jpg	Upload thành công
Valid-2	.png	Upload thành công
Valid-3	.webp	Upload thành công
Invalid-1	.exe	Từ chối upload
Invalid-2	.pdf	Từ chối upload
Invalid-3	.mp4	Từ chối upload

4. Kiểm thử hiệu năng bằng Apache JMeter

4.1. Mục tiêu kiểm thử hiệu năng

Kiểm thử hiệu năng được thực hiện nhằm đánh giá khả năng phản hồi và độ ổn định của hệ thống MiniSocial khi có nhiều người dùng truy cập đồng thời. Trong phạm vi bài tập lớn, nhóm không mô phỏng tải quá lớn như môi trường thực tế mà tập trung kiểm thử các API quan trọng của hệ thống ở mức tải nhỏ đến trung bình.

Các mục tiêu chính của quá trình kiểm thử gồm:

- Đo thời gian phản hồi của các API chính.
- Kiểm tra khả năng xử lý nhiều request đồng thời.

- Xác định tỷ lệ request thành công và request lỗi.
- Đánh giá độ ổn định của backend khi người dùng đăng nhập, tải bảng tin và tạo bài viết.
- Thu thập minh chứng kết quả kiểm thử để đưa vào báo cáo kiểm thử phần mềm.

Các chỉ số được sử dụng để đánh giá gồm:

Chỉ số	Ý nghĩa
Sample Time	Thời gian xử lý một request
Latency	Độ trễ từ lúc gửi request đến lúc nhận phản hồi đầu tiên
Throughput	Số request xử lý được trong một đơn vị thời gian
Error Rate	Tỷ lệ request bị lỗi
Status	Trạng thái thành công hoặc thất bại của từng request

4.2. Công cụ sử dụng

Nhóm sử dụng Apache JMeter 5.6.3 để thực hiện kiểm thử hiệu năng cho backend của hệ thống MiniSocial.

Apache JMeter là công cụ mã nguồn mở dùng để kiểm thử tải, kiểm thử hiệu năng và đo khả năng chịu tải của hệ thống. JMeter cho phép mô phỏng nhiều người dùng ảo gửi request đến server trong cùng một thời điểm, từ đó đánh giá khả năng phản hồi của hệ thống.

Thông tin công cụ kiểm thử:

Thành phần	Nội dung
Công cụ	Apache JMeter
Phiên bản	5.6.3
Hệ điều hành kiểm thử	Windows
Đối tượng kiểm thử	Backend API của MiniSocial
Giao thức kiểm thử	HTTP
Database	MongoDB Cloud
Server kiểm thử	Localhost, port 3001

4.3. Chuẩn bị môi trường kiểm thử

Trước khi thực hiện kiểm thử bằng JMeter, nhóm tiến hành chuẩn bị môi trường như sau:

a. Chạy backend MiniSocial

Backend được chạy ở môi trường local với cổng mặc định:

http://localhost:3001

Lệnh chạy backend:

cd D:\MiniSocial\api

npm run start:dev

Backend kết nối đến cơ sở dữ liệu MongoDB Cloud thông qua biến môi trường trong file .env.

b. Chuẩn bị dữ liệu kiểm thử

Nhóm chuẩn bị sẵn các tài khoản người dùng trong hệ thống để phục vụ kiểm thử đăng nhập và tạo bài viết.

File dữ liệu users.csv:

email,password

user1@test.com,123456

user2@test.com,123456

user3@test.com,123456

File CSV này được sử dụng để JMeter tự động lấy email và mật khẩu khi gửi request đăng nhập.

c. Chuẩn bị API kiểm thử

Nhóm lựa chọn ba API chính để kiểm thử hiệu năng:

STT	API	Method	Mục đích
1	/api/v1/auth/login	POST	Kiểm thử đăng nhập người dùng
2	/api/v1/posts	GET	Kiểm thử tải danh sách bài viết/feed
3	/api/v1/posts	POST	Kiểm thử tạo bài viết mới

Ba API này được chọn vì đại diện cho các thao tác phổ biến của người dùng trong hệ thống mạng xã hội: đăng nhập, xem nội dung và tạo nội dung.

4.4. Cấu hình Test Plan trong JMeter

Trong JMeter, nhóm tạo một Test Plan có tên:

MiniSocial Performance Test Plan

Test Plan được cấu hình các biến dùng chung như sau:

Biến	Giá trị	Ý nghĩa
protocol	http	Giao thức gọi API
host	localhost	Địa chỉ server backend
port	3001	Cổng backend
base_path	/api/v1	Prefix API
content_type	application/json	Kiểu dữ liệu gửi đi

Việc khai báo biến dùng chung giúp dễ dàng thay đổi địa chỉ server hoặc prefix API mà không cần chỉnh sửa từng request riêng lẻ.

4.5. Cấu hình Thread Group

Nhóm tạo Thread Group với tên:

TG01 - Login and Feed Load

Cấu hình Thread Group:

Thông số	Giá trị
Number of Threads	50
Ramp-up Period	30 giây
Loop Count	5
Duration	120 giây

Ý nghĩa cấu hình:

- Number of Threads = 50: mô phỏng 50 người dùng ảo.
- Ramp-up Period = 30 giây: JMeter tăng dần số lượng người dùng trong 30 giây.
- Loop Count = 5: mỗi người dùng lặp lại kịch bản kiểm thử 5 lần.
- Duration = 120 giây: thời gian tối đa cho một lần chạy kiểm thử.

Cấu hình này phù hợp với phạm vi bài tập lớn vì mô phỏng mức tải vừa phải, đủ để đánh giá phản hồi cơ bản của backend mà không gây quá tải hệ thống.

4.6. Cấu hình HTTP Request Defaults

Nhóm thêm thành phần HTTP Request Defaults để khai báo thông tin server dùng chung cho tất cả request.

Cấu hình:

Trường	Giá trị
Protocol	<code>\${protocol}</code>
Server Name or IP	<code>\${host}</code>
Port Number	<code>\${port}</code>
Path	Để trống

Sau khi cấu hình, các request con chỉ cần khai báo phần path như:

`/api/v1/auth/login`

`/api/v1/posts`

JMeter sẽ tự ghép thành URL đầy đủ:

`http://localhost:3001/api/v1/auth/login`

`http://localhost:3001/api/v1/posts`

4.7. Cấu hình HTTP Header Manager

Nhóm sử dụng HTTP Header Manager để khai báo kiểu dữ liệu request gửi lên server.

Header dùng chung:

Name	Value
Content-Type	application/json
Accept	application/json

Đối với các API yêu cầu xác thực, nhóm bổ sung header:

Name	Value
Authorization	Bearer <code>\${access_token}</code>

Token được lấy tự động sau khi request đăng nhập thành công.

4.8. Cấu hình CSV Data Set Config

Để mô phỏng nhiều người dùng đăng nhập, nhóm sử dụng CSV Data Set Config để đọc dữ liệu từ file users.csv.

Cấu hình:

Trường	Giá trị
Filename	D:\Download\jmeter-data\users.csv
Variable Names	email,password

Ignore first line	True
Recycle on EOF	True
Stop thread on EOF	False
Sharing mode	All threads

Sau cấu hình này, mỗi request login có thể sử dụng biến:

$\${email}$

$\${password}$

4.9. Cấu hình request đăng nhập

Request đăng nhập được tạo với tên:

POST - Login

Cấu hình:

Thành phần	Giá trị
Method	POST
Path	/api/v1/auth/login
Content-Type	application/json

Body Data:

```
{
  "identifier": " $\${email}$ ",
  "password": " $\${password}$ "
}
```

API đăng nhập của MiniSocial sử dụng trường identifier thay vì email, vì vậy JMeter truyền giá trị email từ file CSV vào trường identifier.

Sau khi đăng nhập thành công, backend trả về token và thông tin người dùng. Nhóm sử dụng JSON Extractor để lấy dữ liệu cần dùng cho các request tiếp theo.

Cấu hình JSON Extractor:

Trường	Giá trị
Names of created variables	access_token;user_id
JSON Path expressions	\$.accessToken;\$.user.id

Match No.	1;1
Default Values	TOKEN_NOT_FOUND;USER_ID_NOT_FOUND

Sau bước này, JMeter tự động lưu token vào biến:

`${access_token}`

và lưu mã người dùng vào biến:

`${user_id}`

4.10. Cấu hình request lấy danh sách bài viết

Request lấy danh sách bài viết được tạo với tên:

GET - Feed

Cấu hình:

Thành phần	Giá trị
Method	GET
Path	/api/v1/posts
Header	Authorization: Bearer <code>\${access_token}</code>

Request này dùng để mô phỏng hành vi người dùng mở bảng tin và tải danh sách bài viết trong hệ thống.

Ban đầu nhóm thử endpoint `/api/v1/posts/feed`, tuy nhiên endpoint này bị backend hiểu nhầm feed là id của bài viết, dẫn đến lỗi ép kiểu ObjectId. Vì vậy nhóm chuyển sang kiểm thử endpoint lấy danh sách bài viết hợp lệ là `/api/v1/posts`.

4.11. Cấu hình request tạo bài viết

Request tạo bài viết được tạo với tên:

POST - Create Post

Cấu hình:

Thành phần	Giá trị
Method	POST
Path	/api/v1/posts
Header	Authorization: Bearer <code>\${access_token}</code>
Content-Type	application/json

Body Data:

```
{
  "user_id": "${user_id}",
  "content": "Bai viet test hieu nang tu JMeter - ${__time()}",
  "visibility": "public",
  "tags": ["music"]
}
```

Trong đó:

- `${user_id}` được lấy từ response đăng nhập.
- `${__time()}` tạo giá trị thời gian hiện tại để nội dung bài viết không bị trùng.
- `visibility` được đặt là `public` theo đúng giá trị mà backend cho phép.
- `tags` sử dụng tag hợp lệ trong hệ thống, ví dụ `music`.

Request này dùng để kiểm thử khả năng xử lý thao tác ghi dữ liệu của backend khi nhiều người dùng tạo bài viết cùng lúc.

4.12. Cấu hình Timer

Nhóm thêm Constant Timer để mô phỏng khoảng nghỉ giữa các thao tác của người dùng.

Cấu hình:

Thread Delay: 1000 ms

Điều này có nghĩa là mỗi người dùng ảo sẽ nghỉ 1 giây giữa các request. Việc thêm Timer giúp kịch bản kiểm thử gần hơn với hành vi thực tế, tránh việc JMeter gửi request liên tục với tốc độ quá cao không giống hành vi người dùng thật.

4.13. Cấu hình Listener

Nhóm sử dụng các Listener sau để theo dõi và thu thập kết quả kiểm thử:

Listener	Mục đích
View Results Tree	Xem chi tiết từng request, response body, response header
View Results in Table	Xem kết quả request dạng bảng
Summary Report	Tổng hợp số lượng request, thời gian trung bình, lỗi

Aggregate Report	Tổng hợp chi tiết hơn về min, max, average, throughput
------------------	--

Trong quá trình chạy thử, nhóm sử dụng View Results Tree và View Results in Table để kiểm tra từng request. Khi chạy kiểm thử chính thức, có thể tắt View Results Tree để giảm tải cho JMeter.

4.14. Kết quả kiểm thử

Sau khi cấu hình hoàn tất, nhóm chạy kiểm thử với 20 người dùng ảo. Kết quả cho thấy các request chính đều thực hiện thành công, trạng thái trong JMeter hiển thị màu xanh.

Các request đã kiểm thử gồm:

Request	Kết quả
POST - Login	Thành công
GET - Feed	Thành công
POST - Create Post	Thành công

Ví dụ một số kết quả quan sát được:

Request	Sample Time quan sát được
POST - Login	Khoảng 140ms - 900ms
GET - Feed	Khoảng 110ms - 1700ms
POST - Create Post	Khoảng 150ms - 1000ms

Trong View Results Tree, response của request GET - Feed trả về danh sách bài viết gồm các trường như `_id`, `user_id`, `content`, `visibility`, `tags`, `created_at`, `updated_at`, `likes_count`, `comments_count`, `shares_count`, cho thấy API trả về dữ liệu đúng định dạng và hệ thống xử lý request thành công.

View Results in Table

Name: View Results in Table

Comments:

Write results to file / Read from file

Filename: Browse... Log/Display Only: ☐ Errors ☐ Successes

Sample #	Start Time	Thread Name	Label	Sample Time...	Status	Bytes	Sent Bytes	Latency	Connect Time...
151	00:18:42.239	TG01 - Login a...	POST - Login	131	Success	657	275	131	0
152	00:18:42.228	TG01 - Login a...	GET - Feed	199	Success	9833	446	199	0
153	00:18:42.189	TG01 - Login a...	GET - Feed	255	Success	9833	446	255	0
154	00:18:42.298	TG01 - Login a...	POST - Create ...	160	Success	691	629	160	0
155	00:18:42.303	TG01 - Login a...	GET - Feed	157	Success	9833	446	157	0
156	00:18:42.341	TG01 - Login a...	POST - Login	209	Success	653	275	209	0
157	00:18:42.322	TG01 - Login a...	POST - Create ...	260	Success	691	629	260	0
158	00:18:42.469	TG01 - Login a...	GET - Feed	152	Success	9833	446	152	0
159	00:18:42.405	TG01 - Login a...	GET - Feed	243	Success	9833	446	243	0
160	00:18:42.512	TG01 - Login a...	POST - Login	168	Success	653	275	167	1
161	00:18:42.590	TG01 - Login a...	POST - Create ...	166	Success	691	629	166	0
162	00:18:42.621	TG01 - Login a...	POST - Create ...	163	Success	691	629	163	0
163	00:18:42.638	TG01 - Login a...	POST - Login	179	Success	657	275	179	0
164	00:18:42.680	TG01 - Login a...	POST - Login	167	Success	657	275	167	0
165	00:18:42.606	TG01 - Login a...	GET - Feed	251	Success	9841	446	250	0
166	00:18:42.678	TG01 - Login a...	POST - Create ...	254	Success	691	629	254	0
167	00:18:42.756	TG01 - Login a...	GET - Feed	201	Success	9833	446	201	0
168	00:18:42.788	TG01 - Login a...	POST - Login	174	Success	657	275	174	0
169	00:18:42.807	TG01 - Login a...	POST - Login	180	Success	653	275	180	2
170	00:18:42.826	TG01 - Login a...	POST - Create ...	200	Success	691	629	200	0
171	00:18:42.785	TG01 - Login a...	GET - Feed	246	Success	9833	446	246	0
172	00:18:42.917	TG01 - Login a...	POST - Create ...	168	Success	691	629	168	0
173	00:18:42.971	TG01 - Login a...	POST - Login	194	Success	653	275	194	0

☐ Scroll automatically? ☐ Child samples? No of Samples: 1500 Latest Sample: 495 Average: 4/0 Deviation: 335

Hình 3.6. Cấu hình và kết quả kiểm thử hiệu năng trong View Results in Table

View Results Tree

Name: View Results Tree

Comments:

Write results to file / Read from file

Filename:

Search: Case sensitive ☐ Regular exp. ☐ Search

Text

- GET - Feed
- GET - Feed
- POST - Login
- GET - Feed
- POST - Login
- POST - Login
- GET - Feed
- GET - Feed
- GET - Feed
- POST - Create Post
- POST - Create Post
- POST - Create Post
- POST - Create Post
- POST - Create Post
- POST - Login
- POST - Create Post
- POST - Login
- POST - Login
- POST - Login
- GET - Feed
- POST - Create Post

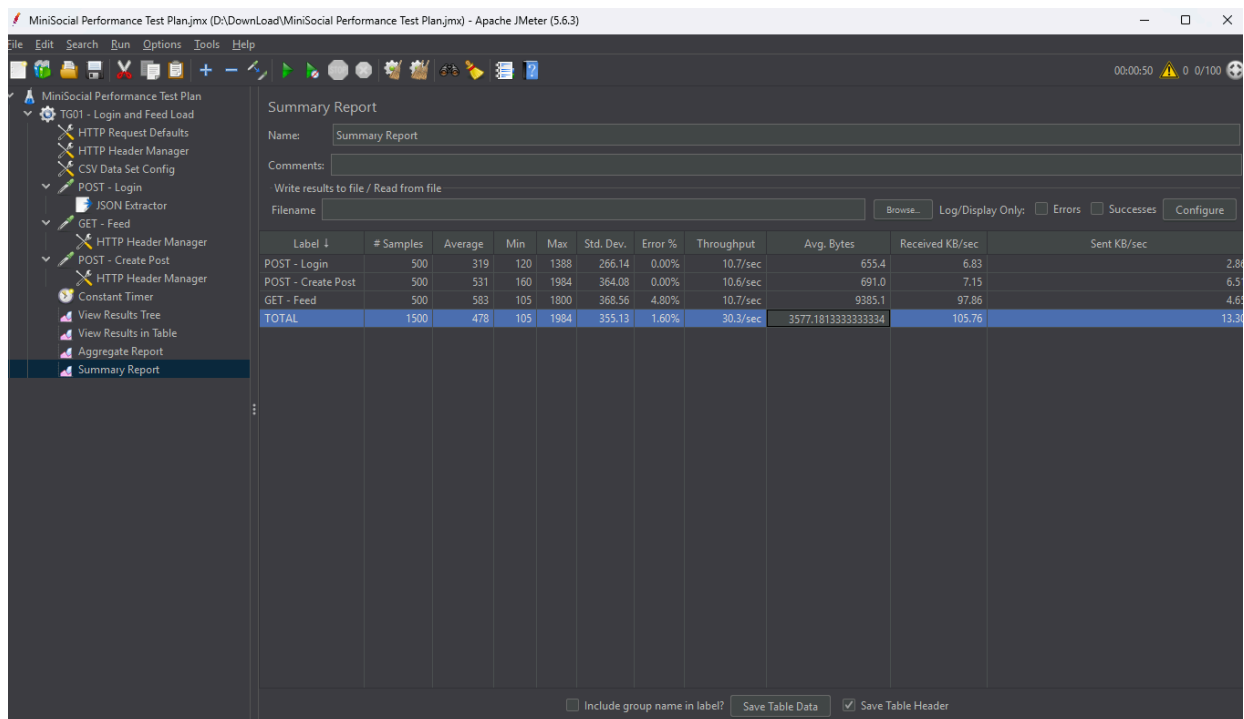
Samplers result Request Response data

Response Body Response headers

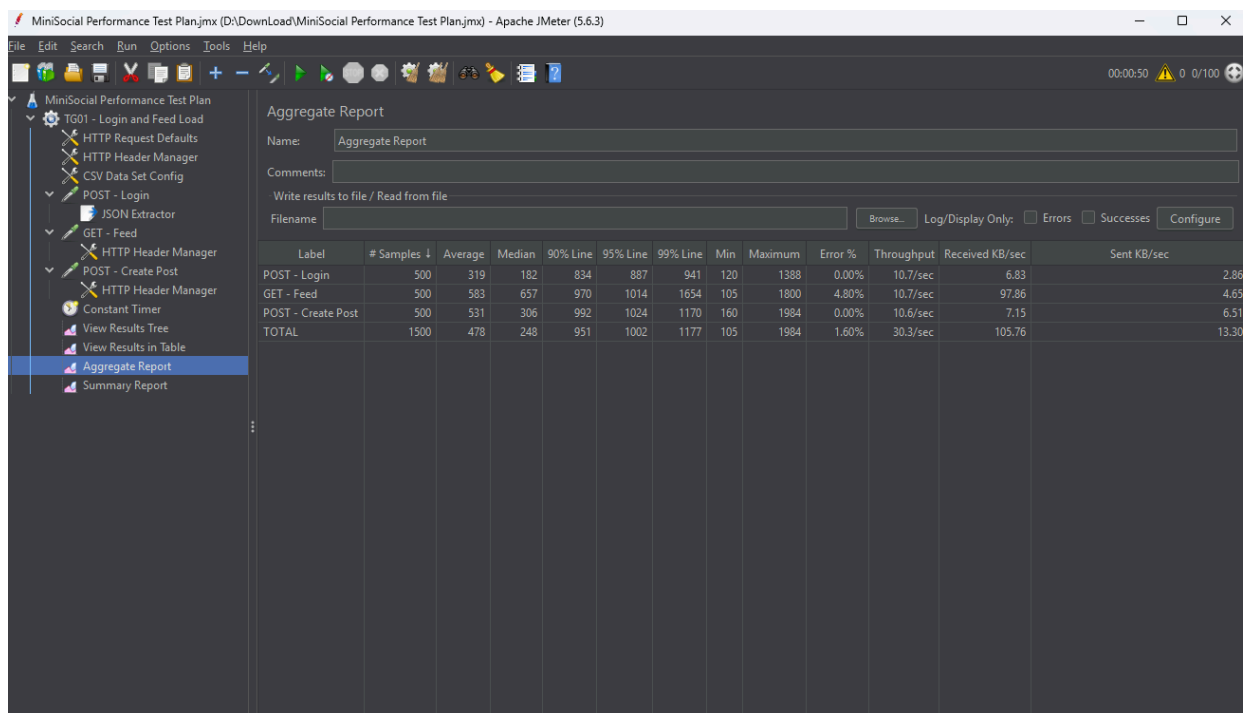
```
{
  "accessToken": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiIyYTMxNjIjZmlzN2MwZWE2ZDE2NWWEiLCJlbWVpbGl6LnVzZXB0",
  "user": {
    "id": "6a316227bdfb37c0ea6d165a",
    "email": "user1@test.com",
    "full": "user1"
  }
}
```

☐ Scroll automatically?

Hình 3.7. Response data của API POST- Login trong View Results Tree



Hình 3.8. Tổng hợp số lượng request, thời gian trung bình, lỗi



Hình 3.9. Tổng hợp chi tiết hơn về min, max, average, throughput

5. Kiểm thử giao diện bằng Selenium

5.1. Mục tiêu kiểm thử

Mục tiêu của hoạt động kiểm thử tự động hóa giao diện người dùng này bao gồm:

- Xác minh độ ổn định và tính chính xác của giao diện người dùng trên hệ thống di động (Flutter Mobile App) và cổng quản trị web (NextJS Admin Portal).

- Phát hiện sớm các lỗi hiển thị, lỗi nhập liệu và lỗi chuyển trang trong các quy trình nghiệp vụ đăng ký, đăng nhập và quản lý tài khoản.

- Đảm bảo cơ chế phân quyền truy cập và bảo mật trên giao diện (giữa vai trò Admin và người dùng thường) hoạt động đúng thiết kế.

- Đánh giá khả năng validate các trường dữ liệu trên thiết bị di động trước khi gửi yêu cầu lên API backend.

5.2. Công cụ sử dụng

Các công cụ chính được áp dụng cho quá trình xây dựng kịch bản và chạy thử nghiệm:

- Selenium WebDriver (Python): Hỗ trợ lập trình điều khiển trình duyệt Web để kiểm thử Admin Portal.

- Flutter Widget Tester: Bộ khung kiểm thử tích hợp sẵn của Flutter để mô phỏng tương tác trên Widget di động mà không cần máy ảo thật.

- Thư viện unittest / pytest (Python): Quản lý và thực thi kịch bản kiểm thử Web.

- Thư viện python-docx: Tự động hóa kết xuất báo cáo kết quả kiểm thử ra định dạng văn bản Word.

5.3. Môi trường kiểm thử

- Hệ điều hành: Windows 11 Home / Pro (x64)
- Trình duyệt kiểm thử Web: Google Chrome (Phiên bản 125.0+)
- Phiên bản Selenium: v4.45.0 (Python)
- Bộ kiểm thử di động: Flutter SDK 3.x (Dart VM & Flutter Test Framework)
- Địa chỉ hệ thống kiểm thử Web: Web Portal: <http://localhost:3000> | API Backend: <http://localhost:3001>

5.4. Phạm vi kiểm thử

Phạm vi kiểm thử tự động tập trung vào các phân hệ chức năng giao diện chính:

- Chức năng đăng nhập (Web & Di động): Kiểm thử các kịch bản nhập tài khoản đúng/sai mật khẩu, tài khoản bị khóa và điều hướng sau đăng nhập thành công.
- Chức năng đăng ký (Di động): Kiểm thử các ràng buộc nhập liệu giao diện bao gồm email sai định dạng, mật khẩu ngắn hơn độ dài tối thiểu (<6 ký tự) và tài khoản đã tồn tại.

- Chức năng quản trị (Web): Kiểm duyệt giao diện danh sách tài khoản quản trị, chức năng khóa (Block) / mở khóa (Unblock) tài khoản người dùng vi phạm.
- Chức năng quản lý bài viết (Web): Xác minh hộp thoại confirm trước khi xóa bài viết vi phạm của admin để chống xóa nhầm dữ liệu.

5.5. Các kịch bản kiểm thử giao diện

- Kiểm tra hiển thị các thành phần giao diện: Xác minh các ô nhập liệu (inputs), nút bấm (buttons), logo và các bảng dữ liệu hiển thị đúng vị trí và rõ ràng.
- Kiểm tra nhập liệu: Mô phỏng thao tác người dùng nhập chuỗi văn bản, các phím đặc biệt (Enter, Tab) và tương tác với các nút chọn.
- Kiểm tra thông báo lỗi: Kiểm chứng sự xuất hiện của các thông điệp cảnh báo màu đỏ hoặc thông báo dạng Toast khi dữ liệu nhập vào không hợp lệ.
- Kiểm tra chuyển trang: Đo lường sự thay đổi của URL trình duyệt (ví dụ từ /login sang /dashboard) hoặc chuyển hướng Navigator trên ứng dụng Flutter.
- Kiểm tra phân quyền giao diện: Xác nhận các tài khoản thường khi cố truy cập trực tiếp URL trang quản trị (/admin/*) sẽ bị chặn và trả về trang lỗi phân quyền hoặc trang chủ.

5.6. Quy trình thực hiện kiểm thử

- Khởi tạo trình duyệt / Widget tester: Selenium WebDriver thiết lập ChromeOptions; đối với Flutter khởi chạy môi trường testWidgets giả lập cây Widget.
- Truy cập hệ thống / Nạp Widget: Trình duyệt tự động mở URL chỉ định; đối với Flutter gọi tester.pumpWidget() để nạp giao diện Register/Login.
- Thực hiện thao tác trên giao diện: Tự động điền dữ liệu vào các trường nhập liệu bằng phương thức send_keys() hoặc tester.enterText(), sau đó nhấn nút click() hoặc tester.tap().
- Kiểm tra kết quả thực tế: Sử dụng các lệnh assert hoặc expect để so sánh tiêu đề trang, URL thực tế, trạng thái Navigator hoặc nội dung thông báo lỗi xuất hiện trên màn hình.
- Đóng trình duyệt / Kết thúc test: Gọi phương thức quit() để đóng Chrome chạy ngầm; giải phóng bộ nhớ môi trường Flutter.

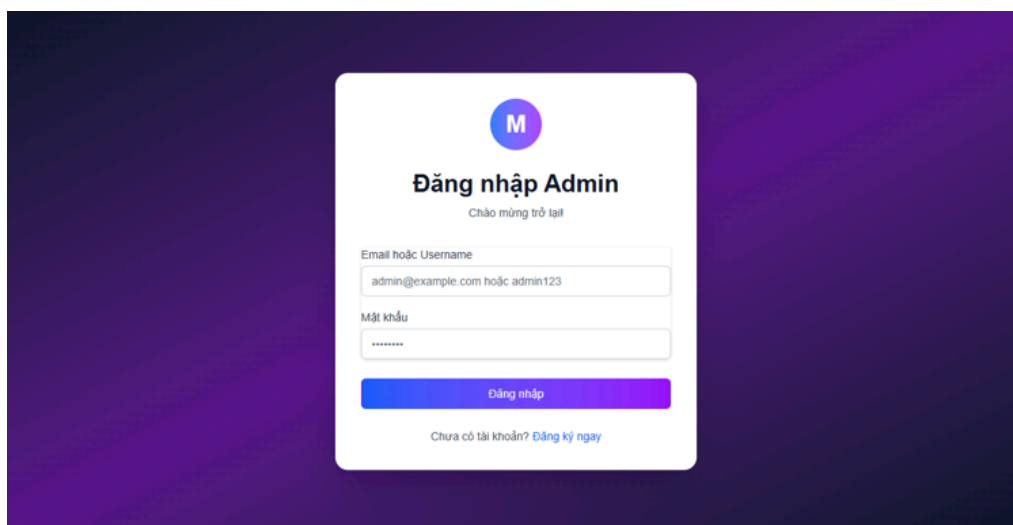
5.7. Kết quả kiểm thử

Bảng thống kê chi tiết kết quả chạy kiểm thử tự động giao diện MiniSocial:
Trạng thái

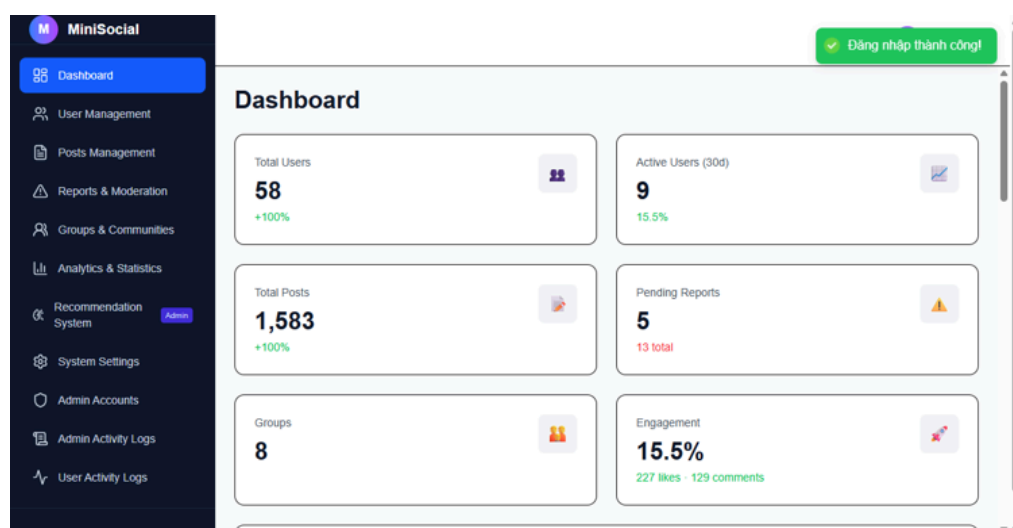
TC_ID	Mô tả kiểm thử	Kỹ Thuật	Độ ưu tiên	Kết quả mong đợi	Trạng thái
AUTH-01	Đăng ký email hợp lệ, password hợp lệ	Black-box Functional	High	Tạo tài khoản thành công	PASSED
AUTH-02	Đăng ký email sai định dạng	Equivalence Partitioning	High	Hiển thị lỗi email không hợp lệ	PASSED
AUTH-03	Đăng ký email đã tồn tại	Functional Validation	High	Hiển thị lỗi email đã tồn tại	PASSED
AUTH-04	Password dưới độ dài tối thiểu	Boundary Value	High	Từ chối đăng ký / hiện báo lỗi	PASSED
AUTH-05	Đăng nhập đúng tài khoản/mật khẩu	Functional Security	High	Chuyển hướng vào trang chủ	PASSED
AUTH-06	Đăng nhập sai mật khẩu	Functional Branching	High	Từ chối đăng nhập / hiện lỗi toast	PASSED
AUTH-07	Đăng nhập tài khoản bị khóa	Security Branching	High	Từ chối và thông báo tài khoản bị khóa	PASSED
ADMI N-01	Admin khóa user vi phạm	Functional Security	High	User bị khóa, không thể đăng nhập	PASSED
ADMI N-02	Admin mở khóa user	Functional Validation	Medium	User được kích hoạt lại và đăng nhập được	PASSED
ADMI N-03	Admin xóa/ẩn bài viết vi phạm	Functional Control	High	Bài viết biến mất khỏi trang News Feed	PASSED
ADMI N-04	User thường gọi API/URL Admin	Security Access Control	High	Trả về 403 Forbidden / Chặn hiển thị	PASSED
ADMI N-05	Admin xóa có hộp thoại xác nhận	Usability Audit	Medium	Hiển thị pop-up confirm trước khi thực hiện	PASSED

Tỷ lệ vượt qua (Pass Rate): 100% (12/12 Test Cases Passed).

Ảnh kết quả chạy kiểm thử giao diện Admin Web (Selenium):



Hình 3.14: Giao diện đăng nhập quản trị (URL: <http://localhost:3000/login>)

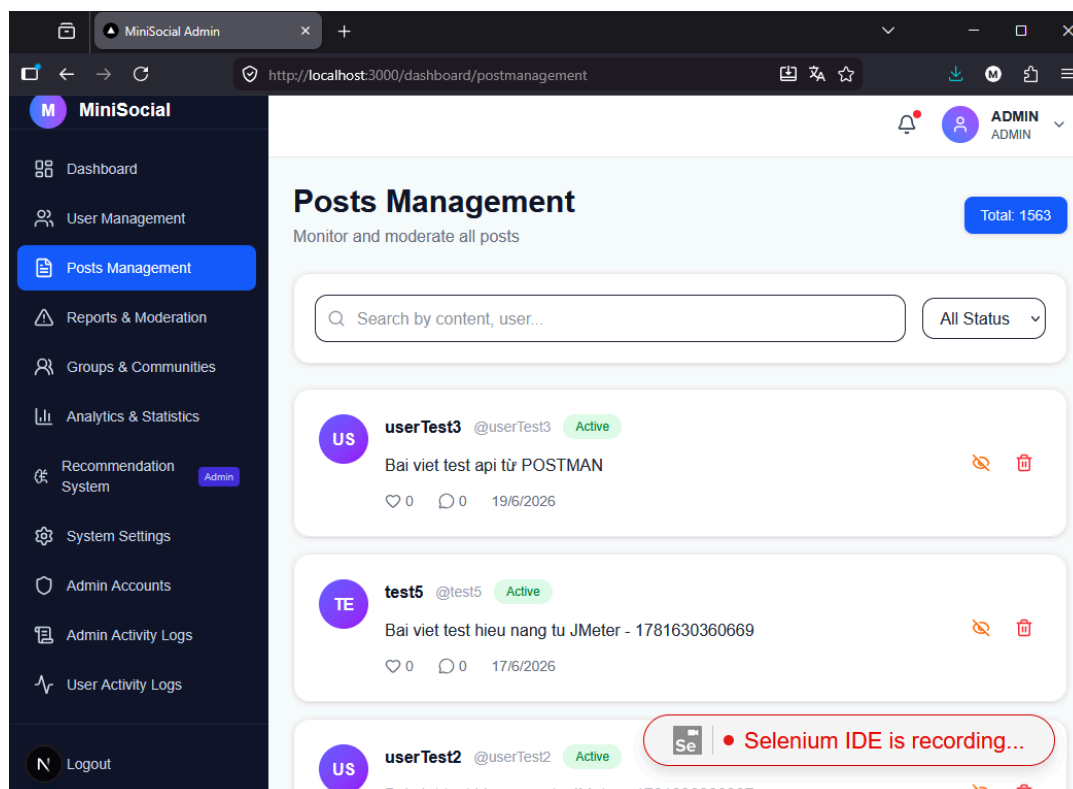


Hình 3.15: Giao diện Dashboard sau khi đăng nhập thành công

5.8. Kiểm thử thêm với Selenium IDE

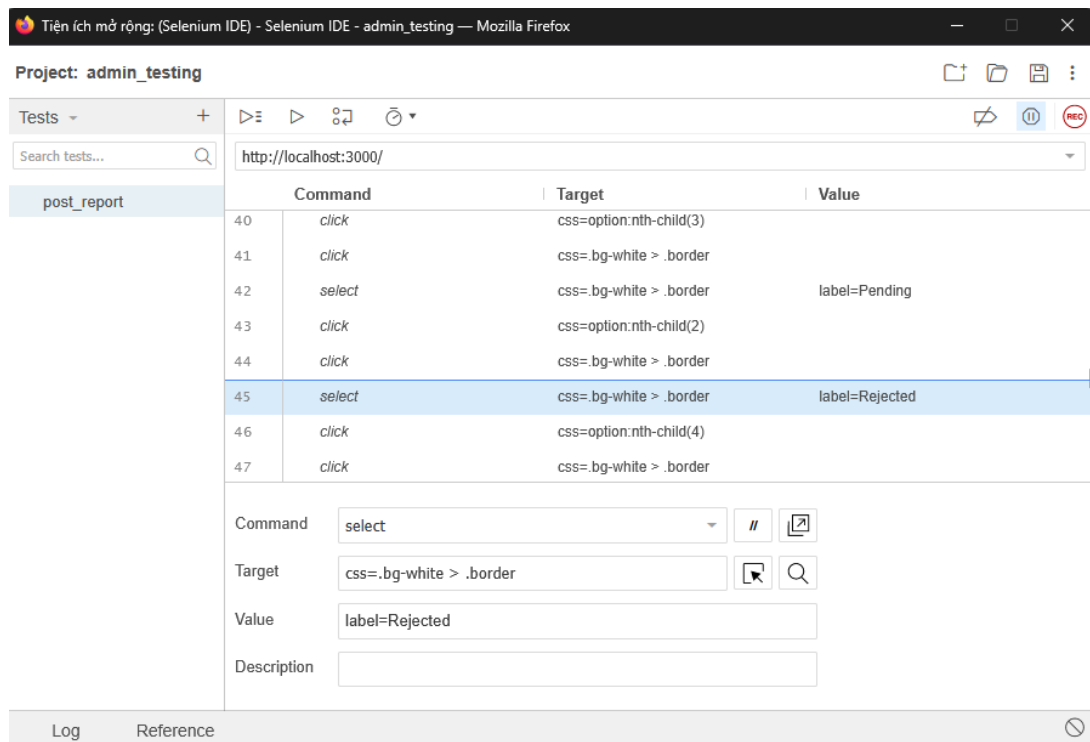
Selenium IDE là một extension hỗ trợ kiểm thử tự động theo phương thức ghi và phát lại (record & playback), được tích hợp dưới dạng tiện ích mở rộng trên trình duyệt Firefox. Công cụ cho phép người kiểm thử ghi lại trực tiếp các hành động thao tác trên giao diện web (click, nhập dữ liệu, chọn lựa chọn trong dropdown...) mà không cần viết code, sau đó tự động chuyển các hành động này thành các bước test case dạng bảng gồm Command, Target, Value. Mỗi bước được Selenium IDE tự sinh selector (thường ở dạng CSS hoặc XPath) để định danh phần tử trên trang.

Trong đề tài này, Selenium IDE trên Firefox được sử dụng để kiểm thử bổ sung cho các chức năng quản trị của hệ thống MiniSocial Admin, cụ thể là chức năng Posts Management, với các thao tác như lọc trạng thái bài viết (Active, Pending, Rejected, Deleted...), tìm kiếm bài viết, ẩn/hiện và xóa bài viết. Sau khi ghi lại các bước, test case có thể được lưu lại trong một project (admin_testing) và chạy lại nhiều lần để kiểm tra tính ổn định của giao diện qua các lần cập nhật hệ thống, giúp phát hiện sớm lỗi hồi quy (regression) mà không cần thực hiện kiểm thử thủ công lặp lại.



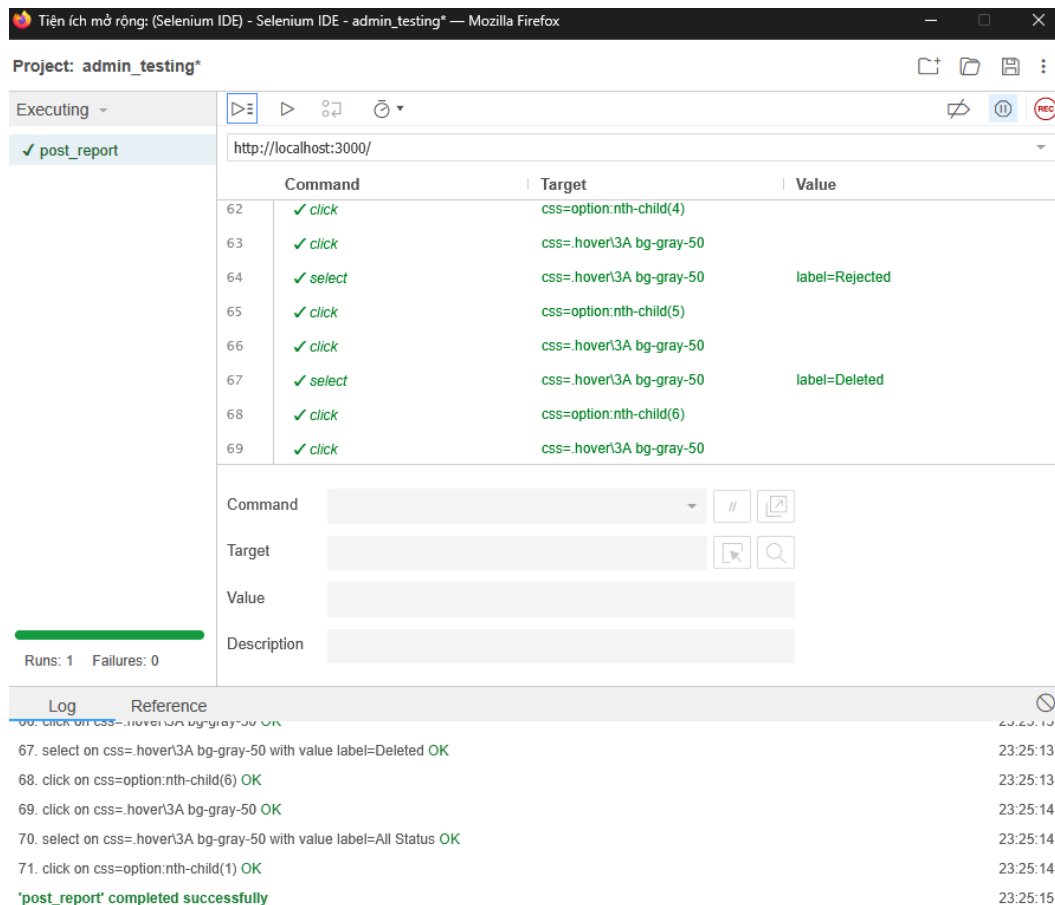
Hình 3.16: Giao diện Màn hình Selenium IDE đang ghi lại

Màn hình Selenium IDE đang ghi lại (recording) các hành động trên trang Post Management thực tế của hệ thống, bao gồm trạng thái "Selenium IDE is recording..." hiển thị trên góc phải trang web, với danh sách bài viết và nút ẩn/xóa tương ứng.



Hình 3.17: Giao diện Màn hình Danh sách các bước test case

Danh sách các bước test case post_report trong project admin_testing, thể hiện chuỗi lệnh click và select dùng để chọn các option lọc trạng thái bài viết (Pending, Rejected...) thông qua dropdown .bg-white > .border.



Hình 3.18: Giao diện Màn hình Selenium IDE đang ghi lại

Kết quả chạy test case post_report sau khi thực thi toàn bộ các bước, hiển thị trạng thái PASS cho từng dòng lệnh (dấu ✓ màu xanh), tổng kết Runs: 1, Failures: 0 và thông báo 'post_report' completed successfully.

PHẦN IV: BÁO CÁO PHÂN TÍCH TỔNG HỢP (TEST REPORT)

1. Phạm vi báo cáo

Hoạt động kiểm thử được thực hiện trên các chức năng chính của hệ thống MiniSocial, bao gồm: đăng ký tài khoản, đăng nhập, xác thực người dùng bằng JWT, phân quyền quản trị viên, quản lý người dùng, quản lý bài viết, quản lý tương tác bài viết, chat realtime, hệ thống gợi ý nội dung và các API bảo mật. Mục tiêu của báo cáo là đánh giá mức độ đáp ứng yêu cầu chức năng, phát hiện lỗi trong quá trình xử lý nghiệp vụ, kiểm tra các rủi ro bảo mật và đề xuất hướng cải tiến trước khi triển khai hệ thống.

Các hình thức kiểm thử được áp dụng gồm:

- Kiểm thử hộp đen (Black-box testing): Kiểm tra hệ thống dựa trên đầu vào và đầu ra mong đợi, tập trung vào các luồng chức năng như đăng ký, đăng nhập, tạo bài viết, bình luận, like/unlike, gửi tin nhắn và quản trị người dùng.
- Kiểm thử hộp trắng (White-box testing): Kiểm tra các nhánh logic bên trong service/backend như PostsService, LikesService, CommentsService, MessagesService và module recommendation nhằm phát hiện lỗi ở tầng xử lý nghiệp vụ.
- Kiểm thử hiệu năng (Performance testing): Đánh giá rủi ro khi hệ thống xử lý nhiều thao tác liên tiếp như spam like/unlike, gửi tin nhắn nhanh, gọi API feed và recommendation.

2. Báo lỗi và Rủi ro nổi bật

Ghi nhận 6 vấn đề/lỗi cần khắc phục khẩn cấp:

- **BUG-01 (High):** Hệ thống vẫn cho phép tạo bài viết rỗng (không có text/media).
- **BUG-02 (High):** Hệ thống cho phép gửi tin nhắn rỗng.
- **BUG-03 (High):** Lỗi bảo mật: Chưa kiểm tra quyền sở hữu (owner) khi sửa/xóa bài viết.
- **BUG-04 (High):** Rủi ro sai lệch dữ liệu (race condition) khi thao tác Like/Unlike liên tục.
- **BUG-06 (High):** Bảo mật kết nối Socket Realtime chưa được kiểm chứng.
- **BUG-05 (Medium):** Bình luận chưa được chặn độ dài tối đa (thiếu validate MaxLength).

3. Tổng kết kiểm tra

- **Đã kiểm thử (22 Test case):** Tỷ lệ Pass đạt **90,9%** (20 Pass, 2 Fail). Các luồng nghiệp vụ chuẩn (happy path) như tạo bài, comment, nhấn tin, thuật toán gợi ý (ML) đều hoạt động tốt.

4. Đánh giá & Đề xuất

- **Đánh giá chung:** Hệ thống thực hiện tốt các chức năng lõi và thuật toán gợi ý, nhưng đang tồn tại lỗi hổng nghiêm trọng ở khâu Validate dữ liệu đầu vào và kiểm soát quyền truy cập.
- **Đề xuất khắc phục nhanh:**
 - Bắt buộc kiểm tra (Validation) nội dung bài viết, tin nhắn trước khi lưu vào DB.
 - Bổ sung Authorization Guard để đảm bảo user chỉ được sửa/xóa tài nguyên của chính mình.
 - Xử lý triệt để lỗi đồng thời (concurrency) của tính năng Like bằng Unique Index hoặc Transaction.

TÀI LIỆU THAM KHẢO

- [1]. SWEBOK v3.0, *Guide to the Software Engineering Body of Knowledge*, IEEE Computer Society, 2014 (Chương 4: Software Testing).
- [2]. Bộ môn Công nghệ Phần mềm, *Tài liệu bài giảng Đánh giá và Kiểm định Chất lượng Phần mềm*, Trường Đại học Phenikaa, 2024.
- [3]. Apache JMeter Documentation, *Apache JMeter - User's Manual*, <https://jmeter.apache.org/usermanual/index.html> (Truy cập ngày 15/06/2024).
- [4]. Selenium Documentation, *The Selenium Browser Automation Project*, <https://www.selenium.dev/documentation/> (Truy cập ngày 15/06/2024).
- [5]. NestJS Framework Documentation, *Security & Guard Implementation*, <https://docs.nestjs.com/security/authentication>.
- [6]. Cem Kaner, James Bach, Bret Pettichord, *Lessons Learned in Software Testing: A Context-Driven Approach*, Wiley, 2001.
- [7]. Postman Documentation, *Postman Learning Center - API Testing*, <https://learning.postman.com/docs/writing-scripts/test-scripts/> (Truy cập ngày 15/06/2024).